

00 roadmap general

Roadmap general — SGD-GADPR-LM

Objetivo

Ordenar el desarrollo del prototipo por **fases dependientes**, sin adelantar pantallas antes de tener base técnica, datos y seguridad mínima definidos en el expediente `GADPR-LM-ETI-SGD-2026-001`.

Alcance

Desde auditoría inicial hasta hardening final; el detalle por módulo vive en `05 – 17` y en el expediente.

Estado actual

ETAPA 0 (auditoría y saneamiento): cerrada al 100 % según evidencias (`docs/29-etapa-0-cierre-y-evidencias.md` , 2026-05-06). El informe `etapa-0-auditoria-inicial-y-diagnostico.md` permanece como **documento histórico** (2026-04-19).

ETAPA 1 (base técnica — shell API + SPA): cerrada al 100 % según evidencias (`docs/30-etapa-1-cierre-y-evidencias.md` , 2026-05-06).

ETAPA 2 (BD + Prisma + XAMPP): cerrada al 100 % según evidencias (`docs/31-etapa-2-cierre-y-evidencias.md` , 2026-05-06). Modelo y migraciones detallados en `docs/04-modelo-base-de-datos.md`.

ETAPA 3 (seguridad y auth — MVP): cerrada al 100 % según evidencias (`docs/32-etapa-3-cierre-y-evidencias.md` , 2026-05-06). Permisos granulares en guard: backlog `docs/07-modulo-roles-permisos.md`.

ETAPA 4 (navegación y shell UI): cerrada al 100 % según evidencias (`docs/33-etapa-4-cierre-y-evidencias.md` , 2026-05-06).

ETAPA 5 (catálogos institucionales): cerrada al 100 % según evidencias (`docs/34-etapa-5-cierre-y-evidencias.md` , 2026-05-06). Estados formales/parametría amplia viven en backlog (`12` , `17`).

ETAPA 6 (gestión documental — MVP + trazabilidad “6A”): cerrada al 100 % según evidencias (docs/35-etapa-6-cierre-y-evidencias.md , 2026-05-06). Máquina de estados/ aprobación/por dependencia: backlog en 12-modulo-documentos.md .

ETAPA 7 (archivos — storage, versiones, borrado lógico, trazabilidad): cerrada al 100 % según evidencias (docs/36-etapa-7-cierre-y-evidencias.md , 2026-05-06). AV/cuotas/política por dependencia: backlog (13 , 21 , 28).

ETAPA 8 (búsqueda + ordenamiento + criterios por adjuntos): cerrada al 100 % según evidencias (docs/37-etapa-8-cierre-y-evidencias.md , 2026-05-06). Índices/búsqueda avanzada institucional: backlog (14 , 21).

ETAPA 9 (reportes Excel/PDF — documentos): cerrada al 100 % según evidencias (docs/38-etapa-9-cierre-y-evidencias.md , 2026-05-06). **Post-cierre:** también existen exports de auditoría y pendientes de revisión (16 , 22). Reporte dedicado de usuarios: backlog (16 , 21).

ETAPA 10 (hardening y cierre — MVP de tesis): cerrada al 100 % según evidencias (docs/39-etapa-10-cierre-y-evidencias.md , 2026-05-07). Controles línea base, throttling documentado y bitácora transversal (API ADMIN); mejoras institucionales posteriores: backlog (21 , 28).

MVP funcional documentado (ETAPAS 0–10): cerradas al 100 % en evidencias formales docs/29-etapa-0-cierre-y-evidencias.md ... docs/39-etapa-10-cierre-y-evidencias.md .

Siguiente foco: Post-MVP / institucionalización según backlog de 00-roadmap-general.md (sección Backlog de pendientes) y docs/28-listado-lo-que-deberia-tener-el-sistema.md .

Actualización posterior al cierre formal 0–10 (2026-05-06): el código ya incorpora lockout por cuenta, estados/transiciones documentales con flujo de revisión (R-27/R-28), **dependencia/ confidencialidad** en consulta de documentos y archivos, UI /admin/auditoria , exports de auditoría y de **pendientes de revisión (ADMIN/REVISOR)**, y **notificaciones por correo** opcionales en el flujo de revisión. Detalle: docs/22-changelog-tecnico.md , docs/README.md (snapshot).

Fases (orden obligatorio)

Etap a	Nombre	Entregables principales
0	Auditoría y saneamiento	/docs completo, .gitignore , storage/ , .env.example , README, deuda registrada
1	Base técnica	frontend/ Vite+React+TS+MUI, axios, routing; NestJS: Config, validación global, /api/v1 , CORS

Etap a	Nombre	Entregables principales
2	BD + Prisma + XAMPP	<code>schema.prisma</code> , migraciones, BD creada en XAMPP, validación en phpMyAdmin
3	Seguridad y auth	Usuarios, roles, permisos, JWT + refresh HttpOnly, Argon2id, guards, auditoría de login
4	Navegación y shell UI	Layout, dashboard, menú, 403/404, estados de error/red
5	Catálogos	Dependencias, cargos, tipos documentales, series/subseries, estados, configuración
6	Gestión documental	CRUD documento, metadatos, estados, historial (incluye trazabilidad mínima por dominio)
7	Archivos	Subida, validación, <code>storage/</code> , versiones, descarga con trazabilidad
8	Búsqueda	Simple y avanzada, filtros, paginación, permisos por rol
9	Reportes	ExcelJS, pdfkit, permisos
10	Hardening y cierre	Limpieza, revisión seguridad, documentación final, backlog

Nota sobre “6A” (sub-entregable)

En el expediente y en evaluaciones académicas suele aparecer “6A” como sub-entregable asociado a **trazabilidad/auditoría mínima** dentro de Gestión Documental.

En este proyecto se considera “6A” como **toda evidencia verificable de historial de cambios del documento** (y su atribución a usuario), implementada mediante `documento_eventos` y sus endpoints asociados (ver `12-modulo-documentos.md` y `19-mapeo-iso27001-iso15489-owasp-asvs.md`).

La **auditoría transversal institucional** (bitácora central unificada para seguridad/ administración) se gestiona dentro del módulo `15-modulo-auditoria.md` ; el cierre MVP de hardening está en `39-etapa-10-cierre-y-evidencias.md` . **Estado vivo:** consulta **API + UI** / `admin/auditoria` ; **retención** institucional de `audit_logs` : backlog (15 , 21).

Decisiones técnicas

- Stack cerrado: ver `02-stack-y-convenciones.md` .
- No microservicios ni PostgreSQL como línea base.
- ngrok solo para exposición temporal (`23-entorno-local-xampp-ngrok.md`).

Problemas y riesgos

Seguimiento en `20-problemas-detectados.md` y `21-riesgos-pendientes.md`.

Mejoras futuras

Institucionalización, despliegue en intranet, backups operativos — fuera del MVP de tesis salvo extensión acordada.

Backlog de pendientes (para iniciar desarrollo de brechas)

Este backlog traduce el documento de brechas `28-listado-lo-que-deberia-tener-el-sistema.md` a un orden ejecutable.

Prioridad Alta (seguridad + evidencia)

1. Auditoría transversal (`audit_logs`)

- Ver `15-modulo-auditoria.md` ; cierre MVP (API consulta ADMIN) en `39-etapa-10-cierre-y-evidencias.md` .
- **Hecho post-cierre:** UI `/admin/auditoria` y export Excel/PDF vía `GET /reportes/auditoria.{xlsx,pdf}` (ADMIN); exportaciones registran `REPORT_EXPORTED` .
- Pendiente institucional: política de retención de bitácora, cobertura exhaustiva de denegaciones y firma/checksum si aplica.

1. Rate limiting / logout en autenticación

- **MVP aplicado:** `@Throttle` global y en rutas `auth` ; `AUTH_RATE_LIMITED` ; **logout por cuenta** (`AUTH_LOCKOUT_*` , columnas `users.failed_login_attempts` / `locked_until`) — ver `05-modulo-auth.md` , `04-modelo-base-de-datos.md` .
- **Institucional:** endurecer umbrales, MFA, CAPTCHA — ver `05-modulo-auth.md` y `21` .

1. Permisos granulares (PermissionsGuard)

- Ver `07-modulo-roles-permisos.md`

1. Control de acceso por documento (dependencia/confidencialidad)

- **Base en código aplicada:** ver `12-modulo-documentos.md` y `13-modulo-archivos.md` (anti-IDOR en listado, detalle, descarga adjuntos y reportes para no-ADMIN).

- Pendiente: reglas institucionales más finas, elevaciones auditadas, PermissionsGuard .

1. Backups + restauración (BD + storage + logs)

- Ver 21-riesgos-pendientes.md (R-016) y módulo 17 (parámetros)

Prioridad Media (ISO 15489 “completo”)

1. Estados formales + transiciones

- Ver 12-modulo-documentos.md

1. Flujo de aprobación

- Ver 12-modulo-documentos.md

1. Retención y conservación

- Crear módulo específico (pendiente) o ampliar configuración (17) + reportes (16)

Prioridad Baja (institucionalización avanzada)

1. Notificaciones (pendientes / vencimientos)
2. AV/cuotas (archivos) y controles avanzados (firma digital, WORM, SIEM/WAF/MFA)

01 arquitectura general

Arquitectura general — SGD-GADPR-LM

Documento: línea base de arquitectura para el prototipo (tesis).

Referencia: expediente técnico GADPR-LM-ETI-SGD-2026-001 (cap. 11).

1. Propósito y alcance

Este documento describe la **arquitectura lógica y física de referencia** del sistema: cliente SPA, API REST, persistencia relacional, almacenamiento de archivos y entornos de ejecución. No sustituye el expediente completo; profundiza en **cómo se conectan los componentes en el entorno real del desarrollador**.

2. Visión de capas

Capa	Rol	Tecnología de referencia
Presentación	SPA, formularios, navegación	React 18 + TypeScript + Vite
Aplicación / API	REST, autenticación, reglas de negocio	NestJS + TypeScript
Datos	Modelo relacional, transacciones	Prisma → MySQL/MariaDB (XAMPP)
Archivos	Binarios fuera del webroot	Carpeta local <code>storage/</code>

Flujo típico: **navegador** → **axios** → **NestJS (Controllers → Guards → Services)** → **Prisma** → **MySQL/MariaDB**; las operaciones con archivo pasan por un servicio de almacenamiento sobre disco.

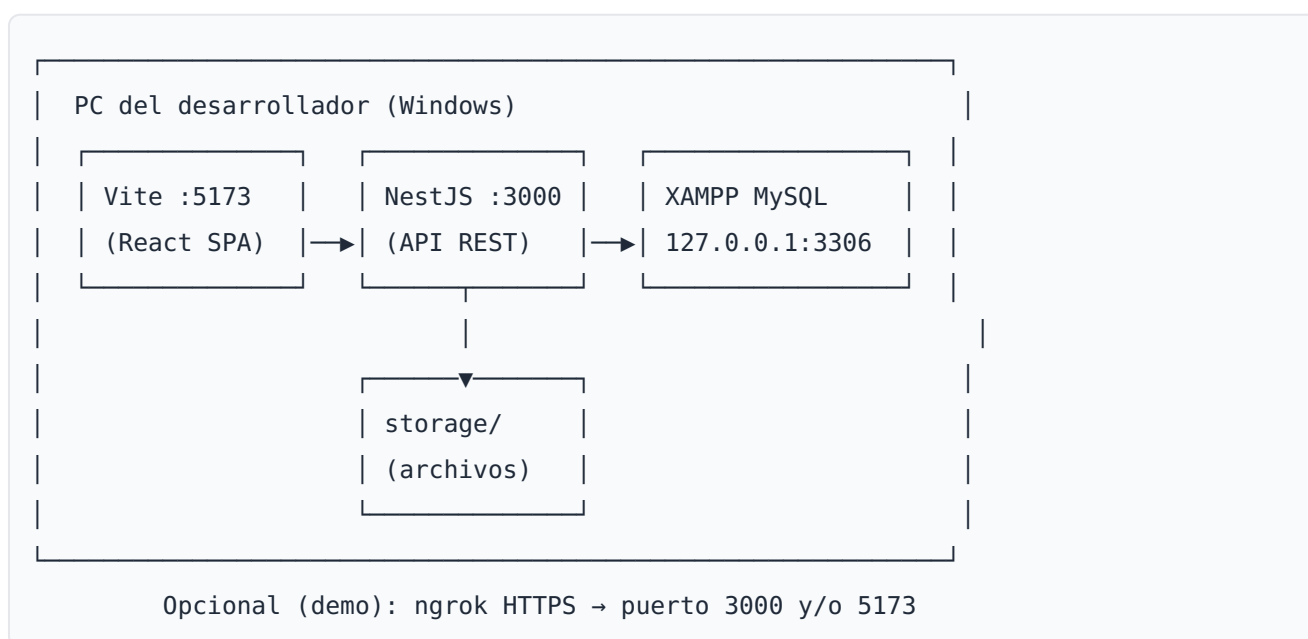
3. Entornos: local, prueba y futuro

Entorno	Qué es	Infraestructura de referencia
Local (desarrollo)	Máquina del desarrollador	XAMPP (MySQL/MariaDB), NestJS y Vite en <code>localhost</code> , sin exposición pública obligatoria
Prueba / demo remota	Acceso temporal desde otra red o dispositivo	Mismo stack local + ngrok como túnel HTTPS hacia el puerto del backend y/o frontend

Entorno	Qué es	Infraestructura de referencia
Futuro (no es base del proyecto)	Intranet institucional o despliegue formal	Proxy TLS, políticas de red, backups operativos — fuera del alcance mínimo de tesis

Importante: no se asume **Docker** ni **cloud** como mecanismo principal de desarrollo. Si en el futuro se adoptan, se documentarán como evolución explícita.

4. Arquitectura física en el PC de desarrollo (Windows + XAMPP)



- **Proxy inverso (Nginx):** no forma parte de la línea base; solo si se solicita explícitamente para un escenario concreto.
- **Base de datos:** siempre **MySQL/MariaDB** servido por XAMPP; **Prisma** se conecta mediante `DATABASE_URL` (ver `02-stack-y-convenciones.md` y `04-modelo-base-de-datos.md`).

5. Contrato de interfaz (resumen)

- **Estilo:** REST, JSON, recursos versionados (p. ej. `/api/v1/...`).
- **Autenticación:** JWT en cabecera; refresh en cookie `HttpOnly` según diseño del backend.
- **CORS:** en desarrollo, origen del Vite (`http://localhost:5173`); si se usa ngrok, añadir el origen HTTPS que entregue ngrok para esa sesión.

6. Relación con otros documentos

Documento	Contenido relacionado
02-stack-y-convenciones.md	Puertos, variables de entorno, comandos
03-estructura-de-carpetas.md	Organización del repositorio
04-modelo-base-de-datos.md	Prisma, migraciones, XAMPP, phpMyAdmin
18-seguridad-y-hardening.md	ngrok, CORS, cookies, riesgos

7. Estado actual del código (referencia rápida — 2026-05-06)

SPA **React/Vite** → API **NestJS** (/api/v1) → **MySQL/MariaDB** vía Prisma y carpeta **storage/** para binarios; autenticación JWT + cookie de refresh HttpOnly.

Extensiones pertinentes para arquitectura de confianza: **throttling** y **lockout por cuenta**, **auditoría transversal** con consulta ADMIN + UI, **reportes servidor** con permisos por rol (**ADMIN**; **ADMIN+REVISOR** en “pendientes de revisión”), y **filtrado de visibilidad** de documentos/archivos/reportes por **dependencia del JWT** + **confidencialidad**.

Índice y snapshot consolidado: docs/README.md y docs/28-listado-lo-que-deberia-tener-el-sistema.md .

8. Limitaciones conscientes (tesis)

- Dimensionamiento para **producción** no es objetivo; el hardware local acota rendimiento y concurrencia.
- **Certificación ISO** u **ASVS** no se pretenden; el diseño se alinea como referencia académica.

02 stack y convenciones

Stack y convenciones — SGD-GADPR-LM

Referencia: expediente técnico §11.2 (stack cerrado).

1. Stack tecnológico (línea base)

Área	Tecnología
Frontend	React 18, TypeScript, Vite (frontend/ ; lock en package . json)
UI	Material UI (MUI), React Router
Formularios	React Hook Form + Zod
HTTP cliente	axios
Backend	NestJS, TypeScript
Validación API	class-validator / class-transformer
ORM	Prisma 5.x (@prisma/client en backend; único ORM oficial)
Base de datos	MySQL/MariaDB vía XAMPP (no PostgreSQL)
Hash de contraseñas	Argon2id
Reportes	ExcelJS (Excel), pdfkit (PDF)

Qué no se asume por defecto: Docker como runtime principal, servicios cloud, Redis/ RabbitMQ, microservicios.

2. Puertos de referencia (ajustar si el proyecto define otros)

Servicio	URL / host	Puerto típico
Frontend Vite	http://localhost:5173	5173
Backend NestJS	http://localhost:3000	3000
MySQL/MariaDB (XAMPP)	127.0.0.1	3306
phpMyAdmin (XAMPP)	http://localhost/phpmyadmin	80 (Apache del XAMPP)

Si `vite.config` o `main.ts` usan otros puertos, **documentar el valor real** en este archivo y en `.env.example`.

2.1 Desarrollo local — backend (NestJS)

Desde `backend/` (scripts en `package.json`):

- `npm run start:dev` — ejecuta antes `npm run tsbuildinfo:clean` (borra `.tsbuildinfo` que en Windows pueden dejar `dist/` incoherente con `nest start --watch`), luego `nest start --watch`.
- `npm run start:dev:free` — libera el puerto **3000** (`kill-port`) y arranca igual que `start:dev` (útil ante `EADDRINUSE`).
- `npm run start:prod` — sirve `node dist/main` tras `npm run build`.

Convención: levantar **MySQL (XAMPP)** → **backend :3000** → **frontend :5173** para evitar errores de proxy `ECONNREFUSED` hacia la API.

3. Variables de entorno (referencia)

Backend (NestJS)

Definir en `.env` en la raíz del backend (o según estructura del repo):

Variable	Propósito
<code>DATABASE_URL</code>	Cadena Prisma hacia MySQL/MariaDB de XAMPP
<code>JWT_SECRET</code> / claves relacionadas	Firma de tokens (valores fuertes; no commitear secretos reales)
<code>PORT</code>	Puerto del API (p. ej. 3000)
Orígenes CORS	Lista que incluya <code>http://localhost:5173</code> y, solo cuando se use ngrok , el origen <code>https://xxxx.ngrok-free.app</code> de esa sesión

Frontend (Vite)

Variable	Propósito
<code>VITE_API_URL</code>	Base URL del API (en desarrollo con proxy : dejar sin definir → <code>/api/v1</code> en el mismo origen que la UI). Solo fijar en build o si el navegador llama API en otro host. Si accedés por IP de LAN desde otro equipo, no uses <code>localhost</code> aquí.
<code>__VITE_ADDITIONAL_SERVER_ALLOWED_HOSTS</code>	(Solo servidor de desarrollo Vite) Host permitido extra para túneles (ngrok, etc.). Variable oficial de Vite: se fusiona sin quitar IPs/LAN permitidas por defecto. Ver allowedHosts .

Los prefijos `VITE_` son expuestos al cliente; **no** poner secretos de servidor en variables `VITE_*`.

Política `server.allowedHosts` en `vite.config.ts` (este repositorio)

- **Convención:** no listar aquí dominios sólo como “whitelist” cerrada (`ngrok` + `localhost`) sin IPs: rompe navegación por `http://<IP-LAN>:5173` y el proxy `/api`.
- **Alternativa admitida:** dejar `allowedHosts` omitido (comportamiento por defecto de Vite) y, si corresponde, variables de `__VITE_ADDITIONAL_SERVER_ALLOWED_HOSTS` por sesión de túnel.

Ejemplo de `DATABASE_URL` (desarrollo local)

```
DATABASE_URL="mysql://root:@127.0.0.1:3306/gestion_documental_gadpr_lm"
```

- Usuario/contraseña deben coincidir con el usuario MySQL configurado en XAMPP (p. ej. `root` sin contraseña solo en desarrollo aislado).
- Preferir `127.0.0.1` en lugar de `localhost` si se evitan ambigüedades con resolución a socket en algunos entornos.

4. Flujo de conexión local (Prisma ↔ XAMPP)

1. Iniciar **MySQL** (o **MariaDB**) desde el **Panel de control de XAMPP**.
2. Crear la base de datos (nombre coherente con `DATABASE_URL`), vía **phpMyAdmin** o cliente SQL.
3. Colocar `DATABASE_URL` en `.env`.
4. Desde la carpeta del backend: `npx prisma migrate dev` (o flujo acordado) y `npx prisma generate`.
5. Levantar NestJS y Vite según scripts del `package.json`.

Detalle de validación en tablas: `04-modelo-base-de-datos.md`.

5. Convenciones de código (resumen)

- **API:** recursos en plural, códigos HTTP semánticos, errores sin filtrar stack traces al cliente.
- **Datos:** migraciones versionadas con Prisma; no introducir otro ORM sin acuerdo explícito.
- **Archivos:** rutas físicas no confiables; metadatos en BD; almacenamiento bajo `storage/` (ver expediente §11.7).

6. ngrok (solo temporal)

Uso, riesgos y registro obligatorio: [18-seguridad-y-hardening.md](#) y [22-changelog-tecnico.md](#).

Comandos de referencia:

```
ngrok http 3000  
ngrok http 5173
```

Adaptar al puerto real del servicio expuesto.

03 estructura de carpetas

Estructura de carpetas — SGD-GADPR-LM

Este documento describe la **organización esperada** del repositorio alineada al expediente técnico (cap. 11). Cuando el código exista, debe actualizarse para reflejar la **estructura real**.

1. Principios

- **Separación** entre frontend (SPA), backend (API) y definición de datos (Prisma).
- **storage/** en la raíz del proyecto o junto al backend (según se implemente), **fuera** de carpetas servidas como estáticos públicos sin control.
- **docs/** para documentación de infraestructura, seguridad y modelo de datos.

2. Estructura real del repositorio (2026-05-06)

```
/
├─ .cursor/rules/           # Reglas del IDE (Prisma/XAMPP, ngrok, seguridad)
├─ backend/                 # NestJS + Prisma
│   ├─ scripts/             # Utilidades locales (p. ej. limpieza tsbuildinfo)
│   └─ prisma/
│       └─ schema.prisma
│       └─ migrations/
│       └─ src/
│           └─ main.ts        # ValidationPipe, /api/v1, CORS, helmet, cookies
│           └─ app.module.ts
│           └─ app.controller.ts
│           └─ auth/          # JWT, refresh cookie, reset password
│           └─ auditoria/     # Bitácora transversal (ADMIN)
│           └─ cargos/
│           └─ common/        # Filtros, utilidades (p. ej. prisma-util)
│           └─ dependencias/
│           └─ documentos/
│           └─ mail/
│           └─ prisma/
│           └─ reportes/
│           └─ series/
```

```

|   └─ subseries/
|   └─ tipos-documentales/
|   └─ usuarios/
└─ frontend/                # Vite + React 18 + TS + MUI
  └─ src/
    └─ api/                  # Cliente axios (apiClient)
    └─ app/                  # App + rutas React Router
    └─ auth/
    └─ layouts/
    └─ nav/
    └─ routes/
    └─ pages/                # dashboard, documentos, catálogos, admin, login...
    └─ theme/
└─ docs/                    # Documentación (índice: README.md; cierres ETAPA
`29`,`30`)
└─ storage/                 # Archivos digitales (.gitkeep; contenido ignorado)
└─ Nueva carpeta/           # Material del expediente / anexos
└─ README.md
└─ EJECUTAR.txt
└─ iniciar-desarrollo.cmd
└─ .gitignore

```

Los módulos de dominio NestJS viven **directamente** bajo `backend/src/<dominio>/` (convención del repo), no es obligatorio el prefijo `src/modules/`.

3. Estructura objetivo (monorepo o carpeta única)

```

/
└─ docs/                    # Documentación (este conjunto de archivos)
└─ backend/                 # NestJS + Prisma (nombre puede variar: server/, api/)
  └─ prisma/
    └─ schema.prisma
    └─ migrations/
  └─ src/
    └─ .env                  # No commitear secretos; usar .env.example
└─ frontend/                # React + Vite (nombre puede variar: client/, web/)
  └─ src/
    └─ .env / .env.local
└─ storage/                 # Archivos digitales (gitignore recomendado salvo

```

ejemplos)
└─ README.md

Si el repositorio usa **otra disposición** (por ejemplo `apps/web` y `apps/api`), mantener el mismo **espíritu** de separación y documentar aquí las rutas reales.

4. Ubicaciones clave

Elemento	Ubicación típica	Notas
Esquema Prisma	<code>backend/prisma/</code> <code>schema.prisma</code>	<code>provider = "mysql"</code>
Migraciones	<code>backend/prisma/migrations/</code>	Versionadas en Git
Scripts auxiliares	<code>backend/scripts/</code>	Ej. limpieza de <code>.tsbuildinfo</code> para desarrollo
Código NestJS	<code>backend/src/</code>	Módulos por dominio
SPA React	<code>frontend/src/</code>	Features, componentes, rutas
Binarios documentales	<code>storage/</code>	Permisos de escritura solo para el proceso Node

5. Archivos que no deben versionarse con datos sensibles

- `.env` con `DATABASE_URL`, secretos JWT, etc.
- Contenido real de `storage/` en entornos con datos personales o institucionales.

Usar `.env.example` con placeholders y valores de ejemplo seguros.

6. phpMyAdmin

phpMyAdmin **no** es una carpeta del proyecto: viene con XAMPP y sirve para **inspección** de la base en `http://localhost/phpmyadmin`. La fuente de verdad del esquema aplicado al código es **Prisma** (`schema.prisma` + migraciones).

04 modelo base de datos

Modelo de base de datos — SGD-GADPR-LM

Motor: MySQL/MariaDB servido por **XAMPP**.
ORM: Prisma (`provider = "mysql"`).
Referencia: expediente técnico (modelo entidad-relación y diccionario de datos).

Estado actual del repositorio (2026-05-08)

Elemento	Situación
<code>backend/prisma/schema.prisma</code>	Existe — <code>provider = "mysql"</code> . Prisma 5.22.0 fijado en <code>backend/package.json</code> (la línea base del proyecto no asume Prisma 7).
<code>backend/prisma/migrations/</code>	22 migraciones ordenadas cronológicamente (ver tabla inferior). Aplicar con <code>npx prisma migrate deploy</code> o <code>migrate dev</code> desde <code>backend/</code> con MySQL activo.
<code>DATABASE_URL</code>	Definir en <code>backend/.env</code> (plantilla en <code>.env.example</code>). Crear la base vacía en phpMyAdmin antes de migrar.
Cliente generado	Tras cambios en el schema: <code>npm run prisma:generate</code> en <code>backend/</code> (o <code>npx prisma generate</code>). En Windows ante EPERM : <code>npm run prisma:generate:clean</code> .
Cierre ETAPA 2	Evidencias formales en <code>docs/31-etapa-2-cierre-y-evidencias.md</code> .

Inventario ordenado de migraciones (cronológicas)

#	Carpeta migración	Contenido principal
1	<code>20260420001500_init_rbac</code>	<code>users</code> , <code>roles</code> , <code>permissions</code> , <code>user_roles</code> , <code>role_permissions</code> .
2	<code>20260420103000_add_refresh_tokens</code>	Sesión prolongada: tabla <code>refresh_tokens</code> (hash, expiración, revocación).
3	<code>20260420120000_add_password_reset_tokens</code>	Recuperación de contraseña: <code>password_reset_tokens</code> .
4	<code>20260421120000_add_dependencies</code>	Catálogo <code>dependencias</code> .
5	<code>20260421140000_add_cargos</code>	Catálogo <code>cargos</code> (FK opcional a <code>dependencias</code>).

#	Carpeta migración	Contenido principal
6	20260421160000_add_tipos_documentales	Catálogo tipos_documentales .
7	20260421170000_add_series_subseries	series + subseries .
8	20260421180000_add_documentos_mvp	documentos + FK catálogos + creador.
9	20260421190000_add_documento_eventos	Trazabilidad dominio documento (documento_eventos).
10	20260421193000_add_documento_archivos	Adjuntos (documento_archivos , documento_archivo_eventos).
11	20260421194500_documento_archivos_versionado	Columna/versionado incremental por archivo.
12	20260505021000_add_user_dependencia_cargo	Usuario institucional: users.dependencia_id , users.cargo_id (FK opcionales).
13	20260505123600_add_audit_logs	Bitácora transversal audit_logs .
14	20260505125800_refresh_tokens_last_used_at	refresh_tokens.last_used_at (inactividad / ASVS sesión).
15	20260506143000_user_ultimo_login	Usuario: users.ultimo_login_at (último login OK con credenciales).
16	20260507010600_documento_acl	ACL por documento: documento_user_access , documento_role_access y documentos.access_policy (INHERIT/RESTRICTED).
17	20260507030000_security_policy	Política de seguridad institucional (singleton): tabla security_policy (gobierno/evidencia).
18	20260507153000_documento_dependencia_confidencialidad	Documento: dependencia_id (propietaria) + nivel_confidencialidad (+ backfill desde creador).
19	20260508120000_user_login_lockout	Usuario: failed_login_attempts , locked_until (bloqueo temporal tras N fallos).
20	20260509153000_normalizar_documento_estados	Normaliza documentos.estado a catálogo formal (R-27).
21	20260509160000_editor_doc_role	Rol EDITOR_DOC y enlaces por defecto en role_permissions si faltaban.
22	20260510090000_user_permissions	Permisos directos por usuario: tabla user_permissions (además de role_permissions).

Tablas resumen por dominio

RBAC (núcleo usuarios)

Tabla	Propósito
users	Cuentas (password_hash Argon2id); opcionalmente dependencia_id , cargo_id ; contador de intentos fallidos y locked_until (R-9 MVP); ultimo_login_at (login exitoso con contraseña).
roles / permissions	Catálogo de roles y permisos granulares.
user_roles / role_permissions	N:M usuario ↔ rol y rol ↔ permiso. Seed (prisma/seed.ts): inserta/actualiza catálogo permissions y reemplaza enlaces por rol (idempotente).
user_permissions	N:M usuario ↔ permiso directo : excepciones individuales (p. ej. solo DOC_FILES_UPLOAD) gestionadas por administración; unión con permisos de roles para el efecto en API (PermissionsService). Auditoría USER_DIRECT_PERMISSIONS_UPDATED cuando cambian.

Sesión y credenciales

Tabla	Migración inicial	Propósito
refresh_tokens	20260420103000_* (+ 20260505125800_*)	Cookie refresh HttpOnly + rotación; control de uso/inactividad.
password_reset_tokens	20260420120000_*	Tokens opacos de restablecimiento (solo hash en BD).

Catálogos institucionales

Tabla	Migración	Propósito
dependencias	20260421120000_*	Unidades organizativas.
cargos	20260421140000_*	Puestos; FK opcional a dependencias .
tipos_documentales	20260421160000_*	Tipologías.
series / subseries	20260421170000_*	Clasificación documental.

Gestión documental y archivos

Tabla	Migración	Propósito
documentos	20260421180000_* +	

Tabla	Migración	Propósito
	<code>20260507153000_*</code>	Registro documental; FK opcional a <code>dependencias</code> y nivel PUBLICO / INTERNO / RESERVADO / CONFIDENCIAL (control acceso en backend).
<code>documento_eventos</code>	<code>20260421190000_*</code>	Historial CREAR/EDITAR dominio documento.
<code>documento_archivos / documento_archivo_eventos</code>	<code>20260421193000_*</code> , <code>20260421194500_*</code>	Adjuntos versionados + eventos (p. ej. SUBIDO/ DESCARGADO/ELIMINADO).

Auditoría transversal

Tabla	Migración	Propósito
<code>audit_logs</code>	<code>20260505123600_*</code>	Eventos de seguridad/administración (acción/resultado, actor, recurso, IP/ UA, <code>meta_json</code>).

Nuevos cambios esquema → **nueva carpeta en `prisma/migrations/`** + actualización de `schema.prisma`, esta sección y `docs/22-changelog-tecnico.md`.

1. Conexión Prisma ↔ XAMPP

1. **Levantar MySQL** en el Panel de control de XAMPP (módulo MySQL o MariaDB).
2. Confirmar que el puerto **3306** (o el configurado en XAMPP) esté en escucha.
3. **Crear la base de datos** vacía con el nombre usado en `DATABASE_URL` (p. ej. `gestion_documental_gadpr_lm`).
4. Definir `DATABASE_URL` en el `.env` del backend (ver `02-stack-y-convenciones.md`).

Ejemplo (solo desarrollo local; ajustar usuario/clave):

```
DATABASE_URL="mysql://root:@127.0.0.1:3306/gestion_documental_gadpr_lm"
```

2. Validar que la base existe

Opción A — phpMyAdmin

1. Abrir `http://localhost/phpmyadmin`.
2. Iniciar sesión con el usuario de MySQL de XAMPP.

3. Comprobar que la base aparece en la lista izquierda; si no, crearla con **Crear base de datos** (cotejamiento recomendado: `utf8mb4`).

Opción B — línea de comandos

Si `mysql` está en el PATH de XAMPP:

```
mysql -u root -p -e "SHOW DATABASES LIKE 'gestion_documental_gadpr_lm';"
```

3. Migraciones Prisma

Desde el directorio donde viva `schema.prisma` (típicamente `backend/`):

```
npx prisma migrate dev
npx prisma generate
```

- **migrate dev** : aplica migraciones pendientes en desarrollo y mantiene el historial en `prisma/migrations/`.
- **generate** : regenera el cliente Prisma para TypeScript.

Si la base ya existía con tablas creadas fuera de Prisma, usar con cuidado `prisma db pull` solo para **introspección** y alinear el `schema.prisma` con revisión manual (documentar decisiones).

Compatibilidad: no usar tipos ni índices exclusivos de PostgreSQL. Para MySQL/MariaDB usar anotaciones `@db.*` cuando sea necesario.

4. Validar tablas en phpMyAdmin

1. Tras migrar, en phpMyAdmin seleccionar la base del proyecto.
2. Pestaña **Estructura**: deben aparecer las tablas definidas por las migraciones (usuarios, documentos, etc., según el diseño del expediente).
3. Comparar nombres de tablas/columnas con `schema.prisma` y con el diccionario del expediente.

5. Tablas esperadas vs reales

Acción	Responsable
Tras cada migración aplicada	Anotar en <code>docs/22-changelog-tecnico.md</code> y refrescar esta sección §“Inventario ordenado...”
Desviaciones	Si hay diferencia entre diseño y BD, documentar causa (pull manual, hotfix SQL, etc.)

Registro ejemplo (añadir según entorno):

Fecha	Migración aplicada	Observación
2026-05-06	Hasta <code>20260509153000_normalize_documento_estados</code> incl.	Inventario cronológico en §“Inventario ordenado...”; cierre ETAPA 2: <code>docs/31-etapa-2-cierre-y-evidencias.md</code> .

6. Respaldo de desarrollo

- Exportar desde phpMyAdmin (**Exportar**) o `mysqldump` para entregas de tesis o recuperación ante fallos del PC.
- Mantener copias de `storage/` si los archivos son parte de la demo.

7. Problemas frecuentes

Síntoma	Causa probable	Acción
<code>Can't reach database server</code>	MySQL detenido en XAMPP	Iniciar MySQL en el panel
Error de acceso denegado	Usuario/clave incorrectos en <code>DATABASE_URL</code>	Ajustar credenciales de XAMPP
Puerto distinto de 3306	Otro servicio o configuración XAMPP	Cambiar puerto en XAMPP y en <code>DATABASE_URL</code> de forma coherente

05 modulo auth

Módulo — Autenticación y sesión

Objetivo

Gestionar identidad del usuario, emisión de tokens y cierre de sesión de forma segura.

Alcance

Login, logout, refresh, expiración; **recuperación de credenciales (olvidé mi contraseña)**; identificación del usuario actual (`/me`); integración con usuarios/roles y lineamientos de auditoría.

Estado actual

Implementado (prototipo).

- **Backend:**

- JWT de acceso (Bearer) + refresh opaco en cookie HttpOnly (hash SHA-256 en tabla `refresh_tokens`).
- **Rotación de refresh (ASVS V3)**: cada `POST /auth/refresh` invalida el refresh usado y emite uno nuevo (misma `expires_at` en BD que el token anterior); la cookie HttpOnly se renueva desde el servidor.
- **Inactividad (ASVS V3)**: columna `last_used_at` en `refresh_tokens` ; si no hay refresh dentro del umbral `SESSION_INACTIVITY_MINUTES` , la sesión deja de poder renovarse.
- Rate limiting en login y recuperación (ver infra / `@nestjs/throttler`).
- **Lockout por cuenta (R-9 MVP)**: tras N intentos fallidos de contraseña la cuenta queda bloqueada unos minutos (`users.failed_login_attempts` / `users.locked_until`); valores `AUTH_LOCKOUT_MAX_ATTEMPTS` y `AUTH_LOCKOUT_MINUTES` en `.env` (ver `.env.example`). Se limpia en login exitoso y al confirmar/recibir reset de contraseña.
- Argon2id en usuarios.
- Recuperación de credenciales: tokens opacos (hash SHA-256 en BD), un solo uso, expiración; **opcionalmente envío SMTP** (`MailService/nodemailer`) del enlace a `/restablecer?token=` .
- Endpoints:
 - `POST /api/v1/auth/login`

- `POST /api/v1/auth/refresh`
- `POST /api/v1/auth/session/restore` — igual que refresh para cookie válida; **siempre HTTP 200** (`{ restored: true/false }`) para arranque UI sin sesión (evita 401 cosméticos en consola).
- `POST /api/v1/auth/logout`
- `GET /api/v1/auth/me`
- `POST /api/v1/auth/password-reset/request`
- `POST /api/v1/auth/password-reset/confirm`

• Frontend:

- `AuthProvider` (token access en memoria), `axios` con `withCredentials` e interceptor de refresh.
- Pantallas: `/login`, `/recuperar`, `/restablecer`.

Decisiones técnicas

- JWT access + refresh `HttpOnly`; `Argon2id` para contraseñas (módulo usuarios).
- **Access token en memoria** (no `localStorage`) para reducir exposición ante XSS (ASVS V3/V8).
- **Refresh opaco** persistido como hash en BD para permitir revocación (logout y reset de contraseña).

Requisitos de seguridad (normativo → control técnico)

OWASP ASVS (Nivel 2, secciones clave)

- **V2 Autenticación:** credenciales validadas en servidor, mensajes genéricos, no enumeración.
- **V3 Sesión:** expiración de access, refresh en cookie `HttpOnly`, logout revoca.
- **V4 Control de acceso:** `/me` y operaciones protegidas por JWT; mutaciones administrativas por rol (ver 07).
- **V5 Validación:** DTOs + `ValidationPipe` global (`whitelist`, `forbidNonWhitelisted`, `transform`).
- **V10 Logging:** eventos de autenticación registrados en `audit_logs` vía `AuditService` (login/refresh/logout/reset; ver `backend/src/auth/auth.service.ts`). Política de retención y consulta admin: `15-modulo-auditoria.md`.

ISO/IEC 27001:2022 (aplicación práctica)

- **Control de acceso / IAM:** autenticación centralizada; roles en token (vía `/me`).
- **Registro de eventos:** diseño de eventos auditable (login/logout, reset password, denegaciones).

- **Gestión de credenciales:** hash fuerte (Argon2id), restablecimiento seguro, invalidación de sesión.

ISO 15489 (interacción con gestión documental)

- La autenticación/identidad sustenta la **atribución** de acciones (`created_by_id`) en trazabilidad documental (quién hizo qué y cuándo).

Estructura prevista

- Backend: `AuthModule` , `AuthService` , `AuthController` , `strategies/guards`.
- Frontend: pantalla login, almacenamiento de access en memoria o almacén seguro acordado.

Flujos

- Login → tokens; refresh periódico; logout revoca/borra refresh.
- Recuperación:
 - Solicitud (`/password-reset/request`) → **respuesta constante** (no revela si el correo existe) y generación de token (si aplica).
 - Confirmación (`/password-reset/confirm`) → valida token (vigente y no usado), actualiza `password_hash` , marca token como usado e invalida refresh tokens activos.

Diagrama (texto)

1. Login

- UI → `POST /auth/login`
- API → valida credenciales → crea refresh (hash en BD) → set cookie `HttpOnly` → retorna `access` + usuario

1. Uso normal

- UI → requests con `Authorization: Bearer <access>`
- Al montar la app → `POST /auth/session/restore` (cookie) para restaurar sesión sin forzar HTTP 401 si no hay cookie

- Si 401 → UI → POST /auth/refresh (cookie) → nuevo access → reintenta request

1. Logout

- UI → POST /auth/logout (cookie) → API revoca refresh → limpia cookie (en respuesta)

1. Olvidé mi contraseña

- UI → POST /auth/password-reset/request (email) → API responde **siempre** { ok: true }
- UI → POST /auth/password-reset/confirm (token + newPassword) → API actualiza password, marca token usado e invalida sesiones

Endpoints

- POST /api/v1/auth/login — body { email, password }; responde { accessToken, user } y fija cookie de refresh.
- POST /api/v1/auth/refresh — usa cookie; responde { accessToken, user } o 401 si no hay sesión válida.
- POST /api/v1/auth/session/restore — usa cookie; **siempre 200** con { restored: true, accessToken, user } o { restored: false }; limpia cookie si el refresh es inválido.
- POST /api/v1/auth/logout — revoca refresh en BD y borra cookie (204).
- GET /api/v1/auth/me — cabecera Authorization: Bearer <access>; usuario con roles.

Recuperación de credenciales (olvidé mi contraseña)

- POST /api/v1/auth/password-reset/request
 - Body: { email }
 - Respuesta: 202 { ok: true } (y **en dev** opcional debugToken para pruebas controladas)
 - Seguridad: anti-enumeración, revoca tokens previos no usados, expiración.
- POST /api/v1/auth/password-reset/confirm
 - Body: { token, newPassword }
 - Respuesta: 200 { ok: true } o 401 si token inválido/expirado/usado/revocado
 - Efecto: actualiza contraseña (Argon2id) e invalida sesiones (refresh tokens) para forzar re-login.

Pantallas

- /login — inicio de sesión.
- /recuperar — solicitar enlace/token de restablecimiento (siempre muestra mensaje genérico).

- `/restablecer` — ingresar token y nueva contraseña.

Tablas relacionadas

- `users`, `roles`, `user_roles`, etc. (RBAC).
- `refresh_tokens`: hash del refresh opaco, `expires_at`, `revoked_at`, FK a `users`.
- `password_reset_tokens`: hash SHA-256 del token opaco, `expires_at`, `used_at`, `revoked_at`, metadata (`requested_ip`, `user_agent`), FK a `users`.

Cookies y sesión

- **Cookie refresh:**
 - Nombre: `REFRESH_COOKIE_NAME` (default `sgd_refresh`)
 - Flags:
 - `HttpOnly`: `true`
 - `sameSite`: `lax`
 - `secure`: `true` en producción
 - `path`: `/`
 - `maxAge` según `JWT_REFRESH_DAYS`
- **Access token:**
 - Se usa en header `Authorization: Bearer ...`
 - Vida: `JWT_ACCESS_EXPIRES` (default `15m`)
 - Almacenamiento: **memoria** (frontend), nunca en `localStorage` para refresh.

Validaciones

- Política de contraseñas; rate limiting recomendado en login.
- Recuperación: token un solo uso, expiración (por defecto 30 min), no divulgar existencia de usuario.

Permisos

- Público: login; resto según rol.

Reglas de negocio

- **RB-Auth-01:** si el usuario está inactivo (`activo=false`), el login debe fallar con mensaje genérico.

- **RB-Auth-02:** el refresh token debe ser revocable; logout marca `revoked_at`.
- **RB-Auth-03:** el restablecimiento de contraseña invalida sesiones vigentes (revoca refresh tokens activos).
- **RB-Auth-04:** `password-reset/request` no revela si el correo existe (anti-enumeración).
- **RB-Auth-05:** el token de reset es **un solo uso** (`used_at`) y expira (`expires_at`).

Eventos auditable (bitácora `audit_logs`)

Implementados en backend (sin guardar secretos ni tokens en claro):

- `AUTH_LOGIN_OK` / `AUTH_LOGIN_FAIL`
- `AUTH_REFRESH_OK` / `AUTH_REFRESH_FAIL` (el intento sin cookie en `/session/restore` no genera `AUTH_REFRESH_FAIL` para no llenar la bitácora en tráfico anónimo)
- `AUTH_LOGOUT`
- `AUTH_PASSWORD_RESET_REQUEST` (y variantes mail fallido/skip en dev)
- `AUTH_PASSWORD_RESET_CONFIRM_OK` / `AUTH_PASSWORD_RESET_CONFIRM_FAIL`
- `AUTH_RATE_LIMITED` (throttling; ver `throttler-audit.filter.ts`)

Consulta administrativa y retención: `15-modulo-auditoria.md`.

Manejo de errores (lineamientos)

- Respuestas genéricas en auth para evitar filtración (ej. “Credenciales inválidas”).
- No exponer stack traces ni detalles internos al cliente.
- En frontend, ante `401` repetido tras refresh: limpiar sesión y redirigir a `/login`.

Dependencias

- Módulo usuarios; configuración JWT.

Problemas / riesgos

- Ver `20` y `21` globales.

Mejoras futuras

MFA institucional, CAPTCHA en recuperación si la política lo exige, límite adicional combinado por **IP + email** en login.

Estado vigente: el **lockout por cuenta** (además del throttling) ya está aplicado (`AUTH_LOCKOUT_*` ; columnas `failed_login_attempts` , `locked_until` en `users`).

Plan de pruebas (paso a paso)

1. Login OK

- Acción: iniciar sesión en `/login` con `admin@local.test` (contraseña definida por seed, ver `backend/.env.example` → `SEED_ADMIN_PASSWORD`).
- Esperado: respuesta `200` con `accessToken` y cookie `sgd_refresh` ; redirección a `/` .
- Fallos a revisar: `500` (migraciones pendientes), CORS, usuario inactivo.

1. Refresh

- Acción: con sesión activa, forzar `401` (esperar expiración o limpiar access en memoria).
- Esperado: frontend llama `/auth/refresh` , recibe nuevo access y reintenta.
- Fallos a revisar: cookie no enviada (CORS/withCredentials), refresh revocado.

1. Logout

- Acción: cerrar sesión desde menú.
- Esperado: cookie se limpia, refresh revocado en BD, UI vuelve a login.

1. Recuperación (request)

- Acción: `/recuperar` enviar email existente y no existente.
- Esperado: misma respuesta visible (anti-enumeración), backend devuelve `202 { ok: true }` (en dev puede incluir `debugToken`).

1. Recuperación (confirm)

- Acción: `/restablecer` con token válido + contraseña nueva (≥ 8).
- Esperado: `200 { ok: true }` , y sesiones previas invalidadas (relogin requerido).

Pendientes para empezar a desarrollar (backlog accionable)

1) ~~Rate-limiting / lockout~~ (ASVS V2) (MVP aplicado)

Estado: implementado por IP/throttler (`@nestjs/throttler`) sobre login y rutas de reset; logout y consultas fuera del alcance; ver `AUTH_RATE_LIMITED` en `audit_logs` .

Opcional siguiente nivel

- Límite adicional por **email normalizado** en login (combinar IP + email como clave).

2) ~~Control de sesiones (ASVS V3)~~ (MVP+ aplicado)

Estado: rotación en cada refresh + política `SESSION_INACTIVITY_MINUTES` + `last_used_at` en BD.

Institucional (pendiente si se escala):

- tabla `sessions` extendida por dispositivo, revocación administrativa masiva y catálogo de sesiones activas en UI.

3) ~~Correo institucional para recuperación (producción)~~ (implementado sobre SMTP)

Estado:

- Backend envía correo mediante **nodemailer** cuando `SMTP_HOST` (o `SMTP_SERVER`) y `SMTP_FROM_EMAIL` están configurados (`MailService`).
- El cuerpo incluye enlace `PASSWORD_RESET_FRONTEND_URL` + `PASSWORD_RESET_PATH` + `token` (SPA `/restablecer?token=`).
- **Anti-enumeración:** la API sigue respondiendo `202 { ok: true }` aunque el correo no exista; no se envía correo en ese caso.
- **Producción sin SMTP:** se audita `AUTH_PASSWORD_RESET_MAIL_SKIP` (cuenta existente) y **no** se devuelve `debugToken`.
- **Fallo SMTP:** se audita `AUTH_PASSWORD_RESET_MAIL_FAIL`; en **no producción** se puede devolver `debugToken` como respaldo.
- Variables: ver `backend/.env.example`.

Opcional siguiente nivel: plantillas HTML institucional, cola de correo y proveedor institucional (relay).

4) Auditoría transversal (dependencia directa)

Al implementar `audit_logs` (ver `15-modulo-auditoria.md`), integrar:

- login ok/fail,
- logout,
- refresh ok/fail,
- password reset request/confirm.

06 modulo usuarios

Módulo — Usuarios

Objetivo

Administración de cuentas de usuario del sistema (alta, baja lógica, actualización).

Alcance

- **Administración de usuarios (ADMIN):** alta, edición, **activación/desactivación**, asignación de **roles**, asignación de **dependencia** y **cargo**, y restablecimiento de contraseña (temporal) con invalidación de sesiones.
- **Perfil propio (usuario final):** se resuelve vía `GET /api/v1/auth/me` (sin edición en este MVP).

Estado actual

Implementado (prototipo, completo para el alcance MVP).

- **Backend:** módulo `UsuariosModule` con endpoints administrativos bajo JWT + rol `ADMIN`.
 - `GET /api/v1/usuarios` (ADMIN; incluye `ultimoLoginAt` cuando exista en BD)
 - `GET /api/v1/usuarios/matriz-acceso-referencia` (ADMIN) — misma política efectiva que el código NestJS (`access-matrix.reference.ts` ; respaldo en cliente en `frontend/src/constants/roles-access-matrix.ts`).
 - `GET /api/v1/usuarios/:id` (ADMIN)
 - `POST /api/v1/usuarios` (ADMIN)
 - `PATCH /api/v1/usuarios/:id` (ADMIN)
 - `POST /api/v1/usuarios/:id/reset-password` (ADMIN)
- **Frontend:** pantalla `/admin/usuarios` (ADMIN) — «Administración de identidades»: tabla de usuarios (cargo/dependencia/último ingreso desde API), **matriz solo informativa** cargada desde `GET .../matriz-acceso-referencia` (respaldo local si falla la red), enlace para **asignar roles desde la tabla** (sin persistencia ficticia desde la matriz), y mismo flujo de:
 - listado,
 - creación,
 - edición (roles/dependencia/cargo),
 - activar/desactivar,

- restablecer contraseña.

Notas de seguridad (ASVS):

- No se expone `password_hash`.
- Email se normaliza a minúsculas.
- Contraseñas se almacenan con **Argon2id**.
- La gestión de usuarios está restringida a `ADMIN` (mínimo privilegio).
- Restablecer contraseña **revoca refresh tokens** (fuerza re-login).

Decisiones técnicas

- Hash Argon2id; no exponer hash ni datos innecesarios en API.
- `dependencia_id` y `cargo_id` son **opcionales** y usan `ON DELETE SET NULL` para no bloquear el catálogo.

Estructura prevista

- Backend: `UsuariosModule`; DTOs con validación.
- Frontend: listado, formulario, detalle (según permisos).

Endpoints (implementados)

- GET `/api/v1/usuarios` (ADMIN) — lista usuarios (sin hash) con roles y referencias.
- GET `/api/v1/usuarios/:id` (ADMIN) — detalle.
- POST `/api/v1/usuarios` (ADMIN) — crea usuario:
 - body: { `email`, `password`, `nombres?`, `apellidos?`, `activo?`, `dependenciaId?`, `cargoId?`, `roles?`, `invitarPorCorreo?` }
 - regla: si `roles` se omite → asigna `USUARIO`
 - **invitarPorCorreo** (opcional, por defecto efectivo `true` si se omite): genera token en `password_reset_tokens` y envía **correo SMTP** con enlace a la pantalla de `/restablecer` para que el usuario defina su contraseña (misma seguridad que recuperación: un solo uso, expiración). Si SMTP no está configurado o falla el envío, el usuario sigue existiendo con la contraseña temporal del body; respuesta incluye `invitacionCorreo`:
{ `solicitada`, `enviada`, `motivoOmitido?` }.
 - Vigencia del enlace: variable `USER_INVITE_MINUTES` (por defecto `4320 ≈ 72 h`).
- PATCH `/api/v1/usuarios/:id` (ADMIN) — actualiza usuario:
 - permite cambiar `email`, `nombres`, `apellidos`, `activo`, `dependenciaId`, `cargoId`, `roles`
 - si se envía `roles` → reemplaza asignación actual

- `POST /api/v1/usuarios/:id/reset-password` (ADMIN) — restablece contraseña y revoca sesiones.
- Perfil actual: `GET /api/v1/auth/me` (JWT).

Pantallas

- `/admin/usuarios` (ADMIN): lista, crear, editar, activar/desactivar, reset pass.

Tablas relacionadas

- `users` (incluye `dependencia_id`, `cargo_id`), `roles`, `user_roles`.
- Catálogos usados por UI: `dependencias`, `cargos`.

Campos principales (UI/API)

- **Email** (único, normalizado a minúsculas)
- **Nombres / Apellidos**
- **Dependencia** (opcional)
- **Cargo** (opcional)
- **Roles** (`ADMIN`, `USUARIO`, `REVISOR`, `AUDITOR`, `CONSULTA`). **REVISOR**: además del alcance de consulta JWT, puede `POST /documentos/:id/resolver-revision` (junto con **ADMIN**).
AUDITOR / **CONSULTA**: mismo alcance funcional base que **USUARIO** hasta flujos propios.
- **Activo** (habilitado / inhabilitado)

Validaciones

- `email`: formato válido.
- `password` / `newPassword`: mínimo 8 caracteres.
- `dependenciaId`, `cargoId`: UUID (opcional).
- `roles`: lista no vacía cuando se envía; valida contra catálogo de `roles`.

Permisos

- Típicamente solo administradores gestionan terceros; usuario edita perfil limitado.

Eventos auditables (`audit_logs`)

- `USER_CREATED`, `USER_UPDATED`, `USER_PASSWORD_RESET`

- Invitación por correo tras alta: `USER_INVITE_MAIL_SENT` , `USER_INVITE_MAIL_FAIL` , `USER_INVITE_MAIL_SKIP` (p. ej. sin SMTP).

Dependencias

- Auth, roles, dependencias, cargos.

07 modulo roles permisos

Módulo — Roles y permisos (RBAC)

Objetivo

Control de acceso basado en **roles** y permisos granulares sobre recursos y acciones.

Alcance

Definición de roles, matriz permiso ↔ rol, enforcement en backend y UI.

Estado actual

Completado (MVP institucional)

- **Roles** (`@Roles`, `RolesGuard`): sin cambios; menú/UI sigue usando códigos de rol en JWT (`ADMIN`, `USUARIO`, `REVISOR`, `AUDITOR`, `CONSULTA`).
- **Permisos en BD**: `permissions` + `role_permissions` poblados de forma **idempotente** al ejecutar `npx prisma db seed` (desde `backend/`). **ADMIN** recibe todos los códigos; los demás roles reciben un subconjunto alineado con el comportamiento previo (`DOC_READ`, revisión, reportes pendientes para `REVISOR`, etc.).
- **Enforcement técnico**: `@Permissions(...)` + `PermissionsGuard` (AND de códigos requeridos) en rutas de documentos, catálogo (escritura), usuarios, reportes, auditoría, dashboard (admin/backups KPI), backup y política de seguridad. Lista canónica: `backend/src/auth/permission-codes.ts`.
- **API administración**: `GET /api/v1/rbac/permissions`, `GET /api/v1/rbac/roles`, `GET /api/v1/rbac/roles/:codigo/permissions`, `PUT .../permissions` (cuerpo `{ "permissionCodes": ["DOC_READ", ...] }`; reemplazo total), `GET /api/v1/rbac/me/permissions` (opcional UX). Auditoría ante cambios: `ROLE_PERMISSIONS_UPDATED`.
- **UI**: pantalla **Administración** → **Usuarios y roles** → sección **Matriz rol** ↔ **permiso (base de datos)** (casillas por código + guardar).

Prerrequisito operativo: si la BD ya existía **antes** del seed RBAC y no se ejecutó seed (o sólo usuarios sin permisos en `role_permissions`), los usuarios con rol pero sin filas efectivas pueden recibir **403** en rutas con `@Permissions` hasta que `npx prisma db seed` rellene la matriz o un `ADMIN` ajuste `PUT .../permissions`.

Pendiente / evolución

- `CATALOGS_READ` del §2 sigue como opcional (lecturas públicas JWT de catálogos no llevan `@Permissions`).
- `DOC_CHANGE_STATE` y roles institucionales finos (`ADMIN_SEGURIDAD`, etc.) del §3: no implementados; los códigos usados están en `permission-codes.ts` .

Aclaración “permisos por documento” (registro/concreto): sigue en §4 / módulo 12 ; no es sólo completar casillas RBAC globales por rol.

Decisiones técnicas

- Guards en NestJS; decoradores o metadatos por ruta; sincronización de permisos en frontend solo para UX (fuente de verdad en API).
- Evolución recomendada: **RBAC + permisos por acción** (ABAC opcional por dependencia/confidencialidad en documentos).

Estructura prevista / implementada

- Tablas: `roles` , `permissions` , `user_roles` , `role_permissions` ; seed idempotente en `backend/prisma/seed.ts` .

Endpoints RBAC (`/api/v1/rbac/...`)

- Ver § “Estado actual” (implementados).

Pantallas

- **Usuarios y roles** · matriz `rol` ↔ `permiso` (BD).

Dependencias

- Auth, usuarios.
-

Pendientes para empezar a desarrollar (backlog accionable)

1) Permisos granulares — implementado base

Cubiertos: `@Permissions`, `PermissionsGuard`, seed, rutas RBAC administrativas y auditoría `ROLE_PERMISSIONS_UPDATED`. Las **403** por guard siguen usando el filtro `ForbiddenAuditFilter` (`AUTHZ_FORBIDDEN`) ante `ForbiddenException`.

Seguimiento sugerido: tests e2e automáticos; matriz HTML “referencia” vs permisos reales (evitar deriva).

2) Matriz acción → permiso (referencia histórica; códigos reales en `permission-codes.ts`)

Nota: los códigos son sugeridos; se pueden ajustar, pero deben ser **estables**.

Usuarios

- `USERS_READ`, `USERS_CREATE`, `USERS_UPDATE`, `USERS_DISABLE`, `USERS_RESET_PASSWORD`

Catálogos

- `CATALOGS_READ`
- `DEPENDENCIAS_WRITE`, `CARGOS_WRITE`, `TIPOS_DOCUMENTALES_WRITE`, `SERIES_WRITE`, `SUBSERIES_WRITE`

Documentos

- `DOC_READ`, `DOC_CREATE`, `DOC_UPDATE`, `DOC_CHANGE_STATE`

Archivos

- `DOC_FILES_READ`, `DOC_FILES_UPLOAD`, `DOC_FILES_DOWNLOAD`, `DOC_FILES_DELETE`

Reportes

- `REPORTS_EXPORT`

Auditoría

- `AUDIT_READ`, `AUDIT_EXPORT`

3) Roles institucionales mínimos (propuesta)

- **ADMIN_SEGURIDAD**: gestiona usuarios/roles/permisos, ve auditoría y seguridad.
- **ADMIN_CATALOGOS**: gestiona catálogos.
- **OPERADOR**: registra/actualiza documentos (según política) y sube archivos.
- **REVISOR**: revisa y cambia estados (aprobación).
- **AUDITOR**: consulta auditoría/reportes, sin modificar registros.
- **CONSULTA**: solo lectura/descarga según autorización.

4) Integración con control por documento (futuro inmediato)

Para el requisito “control de acceso por documento”:

- añadir políticas por **dependencia** y **confidencialidad** en documentos (ver módulo [12](#)),
- y reforzar con permisos + ABAC (propiedad/área).

08 modulo dependencias

Módulo — Dependencias (organizacionales)

Objetivo

Catálogo de unidades organizativas (dependencias) para clasificar usuarios y documentos.

Alcance

CRUD de dependencias; integridad referencial con usuarios y documentos.

Estado actual

Parcial (prototipo). Tabla `dependencias` en Prisma; API `GET /api/v1/dependencias` (JWT), `POST` y `PATCH /api/v1/dependencias/:id` (JWT + rol `ADMIN`); código único normalizado a mayúsculas. Pantalla en frontend: `/catalogos/dependencias` (listado; alta/edición solo ADMIN).

Snapshot documental: coherentes con `docs/README.md` (2026-05-06); esta dependencia es también **propiedad lógica** de documentos y **ámbito** del JWT en anti-IDOR (12 , 04).

Estructura prevista

- Entidad catálogo; validación de unicidad de código/nombre según reglas de negocio.

Endpoints

- `GET /api/v1/dependencias` — listado; query `incluirInactivos=true|false`.
- `GET /api/v1/dependencias/:id` — detalle.
- `POST /api/v1/dependencias` — alta (ADMIN).
- `PATCH /api/v1/dependencias/:id` — actualización / baja lógica vía `activo` (ADMIN).

Pantallas

- Lista y formulario de dependencia.

Tablas relacionadas

- Definir en `schema.prisma` (pendiente).

09 modulo cargos

Módulo — Cargos

Objetivo

Catálogo de cargos o puestos asociables a usuarios para reportes y permisos contextuales.

Alcance

CRUD de cargos; relación opcional con usuarios.

Estado actual

Parcial (prototipo). Tabla `cargos` con FK opcional a `dependencias`; API `GET /api/v1/cargos` (JWT), `POST` y `PATCH /api/v1/cargos/:id` (ADMIN). Pantalla `/catalogos/cargos` (listado; alta/edición ADMIN). Seed: `DIR-GEN`, `ASIST`.

Snapshot: alineado a `docs/README.md` (2026-05-06).

Endpoints

- `GET /api/v1/cargos` — listado con `dependencia` anidada; query `incluirInactivos`.
- `GET /api/v1/cargos/:id` — detalle.
- `POST` / `PATCH` — mutaciones (ADMIN).

Pantallas

- Lista y formulario de cargo.

Tablas relacionadas

- Pendiente de diseño en Prisma.

10 modulo tipos documentales

Módulo — Tipos documentales

Objetivo

Definir tipologías documentales según política archivística y expediente (metadatos obligatorios por tipo).

Alcance

CRUD; vínculo con series/subseries y reglas de indexación.

Estado actual

Parcial (prototipo). Tabla `tipos_documentales`; API `GET /api/v1/tipos-documentales` (JWT), `POST` y `PATCH /api/v1/tipos-documentales/:id` (ADMIN). Pantalla `/catalogos/tipos-documentales`. Seed: `MEMO`, `OFICIO`.

Snapshot: alineado a `docs/README.md` (2026-05-06) — retención por tipo (R-32–35) sigue backlog.

Decisiones técnicas

- Validación fuerte en creación/edición de documentos según tipo seleccionado.

Pantallas

- Catálogo de tipos; campos dinámicos o esquema según diseño.

Tablas relacionadas

- `tipos_documentales` (catálogo base). Vínculo con series/subseries y documentos se implementará en etapas posteriores.

11 modulo series subseries

Módulo — Series y subseries

Objetivo

Implementar cuadro de clasificación archivística (series documentales y subseries) alineado al expediente.

Alcance

Jerarquía, códigos únicos, relación con tipos documentales y documentos registrados.

Estado actual

Parcial (prototipo). Tablas `series` y `subseries` (jerarquía 1:N). API `GET /api/v1/series` y `GET /api/v1/subseries` (JWT); `POST/PATCH` para ambos (ADMIN). Frontend: `/catalogos/series` y `/catalogos/subseries`. Seed: serie `ADM` y subserie `ADM-CORR`.

Snapshot: alineado a `docs/README.md` (2026-05-06).

Decisiones técnicas

- Integridad: no eliminar series con documentos asociados (o baja lógica controlada).

Pantallas

- Árbol o lista jerárquica; formularios de alta/edición.

Tablas relacionadas

- `series`, `subseries` (FK `subseries.serie_id` → `series.id`). FKs a documentos se implementarán en la etapa de gestión documental.

12 modulo documentos

Módulo — Registro documental (documentos)

Objetivo

Ciclo de vida del expediente digital: registro, metadatos, estados, historial y vínculo con series y tipos.

Alcance

CRUD acotado por permisos; trazabilidad de cambios relevantes.

Estado actual

Completado (ETAPA 6). Evidencias de cierre: `docs/35-etapa-6-cierre-y-evidencias.md`.

- **BD:** `documentos` + tabla de historial `documento_eventos` (trazabilidad de creación/actualización).
- **API:** `GET /api/v1/documentos` y `GET /api/v1/documentos/:id` (JWT), `POST/PATCH` (ADMIN), `GET /api/v1/documentos/:id/eventos` (JWT).
- **Frontend:** `/documentos` (listado + registrar), `/documentos/:id` (detalle + edición + historial).
- **Seed:** `DOC-0001` y eventos asociados al crear/editar.

Decisiones técnicas

- Transacciones al crear documento + metadatos.
- **Estados documentales:** catálogo y transiciones en `backend/src/documentos/documento-estado.util.ts` (NORMALIZACIÓN SQL `20260509153000_normalize_documento_estados`); evento de dominio `ACTUALIZADO` + `DOC_STATE_CHANGED` en `audit_logs`.

Pantallas

- Listado, creación, edición, detalle con historial.

Tablas relacionadas

- `documentos` : registro documental MVP (FKs a catálogos y usuario).
- `documento_eventos` : eventos `CREADO` / `ACTUALIZADO` con `cambios_json` y `created_by_id`.

Dependencias

- Tipos documentales, series/subseries, usuarios, auditoría.
-

Qué falta para empezar a desarrollar pendientes (backlog accionable)

1) Control de acceso por documento (por dependencia/confidencialidad)

Estado: MVP aplicado en backend (listado, detalle, eventos, exportes y archivos usan la misma política de visibilidad).

- **Modelo:** `documentos.dependencia_id` (propietaria) + `documentos.nivel_confidencialidad` (`PUBLICO` / `INTERNO` / `RESERVADO` / `CONFIDENCIAL`), migración `20260507153000_*`.
- **Backend:** filtrado en consulta (no “ocultar en UI”); descarga de adjuntos y reportes alineados; JWT incluye `dependenciaId` del usuario.
- **Pendiente institucional:** reglas más finas (clasificación por serie, excepciones, elevación auditada), y `PermissionsGuard` si se exige matriz por permiso (`07`).

2) Estados formales + transiciones (máquina de estados)

Estado: MVP aplicado en código (transiciones válidas en backend; UI con select de estados; **ADMIN** ejecuta cualquier salto permitido por la tabla de transiciones).

Implementado:

- Alta: **BORRADOR** o **REGISTRADO**.
- Ciclo ejemplo: `BORRADOR` → `REGISTRADO` | `ARCHIVADO` , `REGISTRADO` → `EN_REVISION` | `ARCHIVADO` , `EN_REVISION` → `APROBADO` | `RECHAZADO` , `RECHAZADO` → `EN_REVISION` | `ARCHIVADO` , `APROBADO` → `ARCHIVADO` , **ARCHIVADO** **terminal**.
- **ARCHIVADO** : no permite subir/eliminar adjuntos ni cambiar metadatos salvo campo **activo** en BD.

Pendiente institucional:

- Opcional: prohibir que **ADMIN** cambie `estado` vía **PATCH** y forzar solo workflow.

- Notificaciones y bandeja dedicada (ver §3).

3) Flujo de aprobación (bandeja de trabajo)

Estado: MVP en código (R-28).

- **API**

- `POST /api/v1/documentos/:id/enviar-revision` — **REGISTRADO** → **EN_REVISION**; actor: **creador del documento** o **ADMIN**; requiere visibilidad del documento (misma regla que lectura).
- `POST /api/v1/documentos/:id/resolver-revision` — cuerpo `{ "decision": "APROBADO" | "RECHAZADO", "motivo?": string }`; si **RECHAZADO**, **motivo obligatorio** (3–2000 caracteres, `trim`), almacenado en auditoría como `meta.motivoRechazo`; actor: **ADMIN** o **REVISOR**; solo si **EN_REVISION**.

- **Auditoría:** `DOC_SUBMITTED_FOR_REVIEW`, `DOC_REVIEW_RESOLVED` (además de `DOC_STATE_CHANGED`).

- **UI:** botones en detalle; “bandeja” mínima = filtro de listado **Estado** → **En revisión** (texto guía para rol **REVISOR**).

- **Reportes:** `GET /api/v1/reportes/pendientes-revision.{xlsx,pdf}` (ADMIN/REVISOR) para export rápido de lo que está en **EN_REVISION**.

Pendiente: varias rondas de revisión, cola propia, SLA dedicado, canal in-app.

Notificaciones (R-44, MVP):

- Si el backend tiene **SMTP configurado**, se envía correo (best-effort):
 - a **ADMIN/REVISOR** cuando un documento se envía a revisión;
 - al **creador** cuando la revisión se aprueba o rechaza (incluye motivo si hay).

4) Metadatos avanzados por tipo documental

Objetivo: que el tipo documental determine campos obligatorios/adicionales.

Opciones:

- JSON schema por `tipo_documental` (en BD) + validación server-side
- tabla `tipo_documental_campos` (definición de campos)

5) Integración con retención y conservación (futuro inmediato)

Una vez existan políticas de retención:

- `fecha_archivo`, `fecha_vencimiento`, estado de conservación,
- reportes de próximos a vencer,

- bloqueo de eliminación sin autorización.

13 modulo archivos

Módulo — Archivos (almacenamiento)

Objetivo

Subida, almacenamiento bajo `storage/` , metadatos, versiones y descarga controlada con auditoría.

Alcance

Validación MIME/tamaño/extensión; nombres internos seguros; sin servir disco sin autorización.

Estado actual

Implementado (ETAPA 7). Evidencias de cierre: `docs/36-etapa-7-cierre-y-evidencias.md` .

- **BD:** `documento_archivos` + `documento_archivo_eventos` (tamaño, MIME, sha256, trazabilidad).
- **Storage:** guardado físico bajo `storage/documentos/<documentoId>/...` (ruta no expuesta directamente).
- **Versionado:** versión incremental por documento + nombre (`version`), mantiene historial y permite múltiples cargas del “mismo” archivo.
- **API:**
 - `GET /api/v1/documentos/:id/archivos` (JWT)
 - `POST /api/v1/documentos/:id/archivos` (JWT + `ADMIN` , multipart `file` , máx 10MB, lista blanca MIME)
 - `GET /api/v1/documentos/:id/archivos/:archivoId/download` (JWT, descarga controlada)
 - `GET /api/v1/documentos/:id/archivos/:archivoId/eventos` (JWT)
 - `DELETE /api/v1/documentos/:id/archivos/:archivoId` (JWT + `ADMIN` , borrado lógico)
- **Frontend:** en `/documentos/:id` sección **Archivos** para listar, subir (ADMIN) y descargar.

Visibilidad y anti-IDOR: las rutas anteriores aplican las **mismas reglas de acceso por documento** que el listado/detalle (`dependencia_id` propietaria + `nivel_confidencialidad` en relación al usuario JWT), además del rol (**ADMIN**, **JWT** usuario).

Decisiones técnicas

- Rutas físicas no expuestas; streaming desde NestJS; registrar cada descarga.
- Hash de integridad **SHA-256** calculado sobre el binario almacenado.
- **Borrado lógico** por `activo=false` para conservar evidencia y trazabilidad (ISO 15489).

Requisitos de seguridad y cumplimiento (normativo → control técnico)

OWASP ASVS (Nivel 2, enfoque en subida/descarga)

- **Validación de archivos (V5 + File Upload)**: whitelist de MIME/extensión, límite de tamaño, nombres seguros, bloqueo de path traversal.
- **Control de acceso (V4)**: descarga/listado solo vía API con JWT; subida/borrado restringido a `ADMIN`.
- **Gestión de sesión (V3)**: descarga requiere sesión válida; ante `401` se fuerza re-login.
- **Logging (V10)**: eventos `SUBIDO`, `DESCARGADO`, `ELIMINADO` (sin exponer rutas físicas ni tokens).

ISO/IEC 27001:2022 (aplicación práctica)

- **Protección de activos**: los archivos son activos de información; deben protegerse contra acceso no autorizado.
- **Registro de eventos**: toda descarga debe dejar evidencia (quién/cuándo/qué).
- **Disponibilidad**: definir respaldo de `storage/` y restauración (ver `16 / 21`).

ISO 15489 (gestión documental)

- **Autenticidad**: atribución a usuario (`created_by_id`) y eventos.
- **Integridad**: hash SHA-256 + control de acceso + no sobrescritura de versiones.
- **Fiabilidad y trazabilidad**: versionado + historial de eventos por archivo.
- **Usabilidad/recuperación**: metadatos del archivo (nombre, MIME, tamaño) y vínculos con documento.

Flujo operativo (resumen)

1. Subida (ADMIN)

- UI → `POST /documentos/:id/archivos` (multipart file)

- API:
 - valida permisos (ADMIN),
 - valida tamaño, MIME/extensión y nombre,
 - calcula `sha256`,
 - asigna `version` (incremental) para `documentoId + originalName`,
 - guarda binario bajo `storage/documentos/<documentoId>/...`,
 - registra `documento_archivo_eventos` tipo `SUBIDO`.

1. Listado (JWT)

- UI → `GET /documentos/:id/archivos`
- API → retorna adjuntos activos y metadatos (sin ruta física).

1. Descarga (JWT)

- UI → `GET /documentos/:id/archivos/:archivoId/download`
- API:
 - valida que el archivo pertenezca al documento (anti-IDOR),
 - valida usuario/sesión,
 - hace streaming del binario,
 - registra evento `DESCARGADO` con metadata (por ejemplo IP/UA si se captura).

1. Borrado lógico (ADMIN)

- UI → `DELETE /documentos/:id/archivos/:archivoId`
- API → `activo=false` y evento `ELIMINADO`.

Endpoints (implementados y contrato esperado)

Listar archivos de un documento

- `GET /api/v1/documentos/:id/archivos` (JWT)
- Respuesta (ejemplo conceptual):
 - `[{ id, version, originalName, mimeType, sizeBytes, sha256, activo, createdAt, createdById }]`

Subir archivo (multipart)

- `POST /api/v1/documentos/:id/archivos` (JWT + ADMIN)
- `Content-Type: multipart/form-data`
- Campo: `file`
- Respuesta: registro creado (metadatos + versión).

Descargar archivo (stream)

- GET `/api/v1/documentos/:id/archivos/:archivoId/download` (JWT)
- Respuesta: stream con `Content-Type` del archivo y headers de descarga.

Ver eventos de un archivo

- GET `/api/v1/documentos/:id/archivos/:archivoId/eventos` (JWT)
- Respuesta: historial `SUBIDO/DESCARGADO/ELIMINADO`.

Borrado lógico

- DELETE `/api/v1/documentos/:id/archivos/:archivoId` (JWT + ADMIN)
- Respuesta: `204` o registro actualizado (según implementación).

Reglas de negocio

- **RB-Arch-01 (whitelist)**: solo se admiten tipos MIME/extensiones permitidas (lista blanca).
- **RB-Arch-02 (tamaño)**: máximo **10MB** por archivo (configurable).
- **RB-Arch-03 (anti-IDOR)**: `archivoId` debe pertenecer al `documentoId` de la ruta.
- **RB-Arch-04 (versionado)**: si existe un archivo activo con `originalName`, el siguiente subido crea `version+1`; nunca sobrescribe binarios previos.
- **RB-Arch-05 (borrado lógico)**: eliminar marca `activo=false` y registra evento; no se elimina físicamente por defecto.
- **RB-Arch-06 (auditoría)**: toda descarga registra evento (mínimo: usuario, archivo, timestamp; opcional: IP/UA).

Validaciones (server-side)

- **MIME real**: validar contra la detección/valor admitido; no confiar solo en extensión.
- **Extensión**: coherencia con MIME permitido.
- **Nombre seguro**: normalización/sanitización para evitar path traversal y caracteres peligrosos.
- **Tamaño**: rechazar payloads > límite.
- **Documento existente**: no permitir subir a documentos inexistentes o inactivos (si aplica).

Controles de seguridad aplicados

- Archivos **fuera del directorio público**, no se sirven como estáticos.
- Descarga solo vía API con autorización.

- Streaming controlado (reduce uso de memoria y exposición de rutas).
- Hash SHA-256 almacenado para integridad y trazabilidad.
- Eventos de auditoría por archivo (SUBIDO/DESCARGADO/ELIMINADO).

Manejo de errores (lineamientos)

- 400 : validación (MIME/extensión/tamaño/nombre).
- 401 : sesión inválida/expirada.
- 403 : rol insuficiente (subida/borrado).
- 404 : documento/archivo inexistente o no pertenece (anti-IDOR).
- 500 : error interno (IO/FS/DB) sin exponer rutas físicas.

Eventos auditables (evidencia)

- documento_archivo_eventos :
 - SUBIDO (quién, cuándo, versión, metadatos del archivo)
 - DESCARGADO (quién, cuándo, opcional IP/UA)
 - ELIMINADO (quién, cuándo, borrado lógico)

Dependencias

- Documentos (relación documentoId), auditoría (eventos), seguridad (18).

Mejoras futuras (si se amplía el alcance)

- Antivirus institucional (escaneo en subida y cuarentena).
 - Cuotas por usuario/dependencia (prevención de DoS por almacenamiento).
 - Verificación de hash en descarga (modo estricto).
 - Políticas de retención/disposición (integración con ISO 15489 completa).
-

Pendientes para empezar a desarrollar (backlog accionable)

1) Integración con control de acceso por documento (dependencia/confidencialidad)

Objetivo: que subir/descargar/eliminar archivos respete la política del documento (no solo rol).

- Requiere: módulo 12 (agregar `dependencia_id` y `confidencialidad` al documento, y políticas `canRead/canDownload`).
- Cambios:
 - En `GET /documentos/:id/archivos` : filtrar según permiso por documento.
 - En `download` : validar acceso por documento + registrar denegaciones (`audit_logs`).

2) Antivirus / cuarentena (institucional)

Objetivo: reducir riesgo de malware.

- Flujo sugerido:
 - subir → estado `EN_CUARENTENA`
 - escaneo AV (externo) → `APROBADO` o `RECHAZADO`
 - solo `APROBADO` descargable.

3) Cuotas y límites por usuario/dependencia

Objetivo: prevenir DoS por almacenamiento y mejorar gobernanza.

- Parametrizable desde configuración (17):
 - cuota diaria por usuario,
 - cuota total por dependencia,
 - máximo de adjuntos por documento.

4) Integridad reforzada (opcional)

- Verificación de SHA-256 en descarga (modo estricto) y alertar discrepancias.
- Reporte de integridad (hashes) para evidencia.

5) Respaldo y restauración (dependencia)

- Definir estrategia de backup para `storage/` + BD + logs (ver gaps 36/37 y 21-riesgos-pendientes.md).

Plan de pruebas (paso a paso)

1. Subida válida (ADMIN)

- Acción: en `/documentos/:id` subir un PDF < 10MB.
- Esperado: aparece en listado como `v1` y evento `SUBIDO`.
- Fallos a revisar: `403` (sin ADMIN), `400` (MIME/tamaño), `500` (storage/DB).

1. Versionado

- Acción: subir nuevamente un archivo con el mismo nombre.
- Esperado: aparece `v2` (y no se sobrescribe `v1`).

1. Descarga

- Acción: descargar `v2`.
- Esperado: descarga correcta y evento `DESCARGADO`.

1. Anti-IDOR

- Acción: intentar descargar un `archivoId` de otro documento usando la URL.
- Esperado: `404` o `403` (según decisión), sin filtrar información.

1. Borrado lógico (ADMIN)

- Acción: eliminar un archivo.
- Esperado: deja de mostrarse en listado (si filtra solo activos) y evento `ELIMINADO`.

Dependencias

- Documentos, auditoría, seguridad (18).

14 modulo busqueda

Módulo — Búsqueda y consulta

Objetivo

Búsqueda simple y avanzada por metadatos, filtros y permisos por rol.

Alcance

Listados paginados, ordenamiento, visor de documento/archivo según permisos.

Estado actual

Implementado (ETAPA 8). Evidencias de cierre: docs/37-etapa-8-cierre-y-evidencias.md .

- **API:** GET /api/v1/documentos (JWT) con filtros y paginación.
- **Filtros:** q (código/asunto/descr.), estado, tipoDocumentalId, serieId, subserieId, fechaDesde, fechaHasta, incluirInactivos .
- **Adjuntos (búsqueda):** archivoNombre, archivoMime, archivoSha256 (match sobre adjuntos activos).
- **Ordenamiento:** sortBy (codigo | fechaDocumento | estado) y sortDir (asc | desc).
- **Paginación:** page, pageSize → respuesta { page, pageSize, total, items }.
- **Frontend:** /documentos con barra de búsqueda, filtros y paginación.

Visibilidad: el servidor **filtra resultados** según **dependencia + confidencialidad** del JWT para usuarios que no son **ADMIN** (coincidente con GET /documentos/:id y reportes).

Decisiones técnicas

- Consultas optimizadas en Prisma; índices en columnas de filtro frecuente (definir en migraciones).

Pantallas

- Búsqueda, resultados, detalle desde consulta.

Endpoints

- GET /api/v1/documentos
 - Query:
 - q
 - archivoNombre
 - archivoMime
 - archivoSha256
 - estado
 - tipoDocumentalId
 - serieId
 - subserieId
 - fechaDesde (ISO)
 - fechaHasta (ISO)
 - sortBy , sortDir
 - page , pageSize
 - incluirInactivos

15 modulo auditoria

Módulo — Auditoría y trazabilidad

Objetivo

Registrar eventos relevantes (quién, qué, cuándo, recurso) para cumplimiento y defensa de tesis.

Alcance

Login/logout, CRUD sensibles, descarga de archivos, cambios de estado documental.

Estado actual

Implementado (backend + UI `/admin/auditoria` + exports Excel/PDF vía reportes).

Pendiente institucional: **política de retención** de `audit_logs`, firma/checksum opcional y cobertura ampliada de eventos si el archivo lo exige.

- **Trazabilidad por dominio (implementada):**

- Documento: tabla `documento_eventos` con eventos `CREADO / ACTUALIZADO` y `created_by_id`.
- Archivo: tabla `documento_archivo_eventos` con eventos `SUBIDO / DESCARGADO / ELIMINADO` y `created_by_id`.

- **Bitácora transversal (`audit_logs`):**

- Tabla `audit_logs` + `AuditService`; eventos AUTH (login/refresh/logout/reset/rate-limit), `AUTHZ_FORBIDDEN` ante respuestas **403** autenticadas (`forbidden-audit.filter.ts`), administración/usuarios, documentos/archivos donde se integró; flujo documental `DOC_SUBMITTED_FOR_REVIEW / DOC_REVIEW_RESOLVED` (R-28).
- **Consulta ADMIN (API):** `GET /api/v1/auditoria` con filtros y paginación (`auditoria.controller.ts`). Filtros: `action` (igualdad exacta al código), `actorUserId` (UUID del actor, prioridad sobre `actorEmail`), fechas `from / to` , etc. La respuesta puede incluir `resourceCodigo` : código del expediente resuelto desde `documentos.codigo` cuando el evento apunta a `resourceType=Documento` o el `meta_json` trae `documentoId` (p. ej. eventos de archivo). Misma lógica en exportaciones de reportes. Evidencia de hardening MVP: `docs/39-etapa-10-cierre-y-evidencias.md` .

- **UI ADMIN:** página `/admin/auditoria` (listado paginado + export Excel/PDF vía `GET /api/v1/reportes/auditoria.{xlsx,pdf}` ; columnas de export incluyen código de documento cuando exista).
- **Pendiente institucional:** política de **retención** y archivo; integridad firma/checksum si el alcance lo exige.

Decisiones técnicas

- Servicio de auditoría invocado desde services; no depender solo de logs en consola.
- Mantener la **trazabilidad de negocio** (documento/archivo) separada de la **auditoría de seguridad** (eventos transversales), pero correlacionable por `correlationId` cuando aplique.
- Registrar IP/UA **cuando sea útil** para investigación (sin almacenar datos sensibles innecesarios).

Tablas relacionadas

- **Implementadas:** `documento_eventos` , `documento_archivo_eventos` , **`audit_logs`** (`AuditLog` en Prisma).

Dependencias

- Auth (usuario actual), todos los módulos que generen eventos.

Diseño — `audit_logs` (bitácora central)

Objetivo

Tener una bitácora transversal para eventos de **seguridad** y **administración**:

- accesos,
- intentos fallidos,
- cambios de usuarios/roles/permisos,
- denegaciones de autorización (403),
- exportaciones,
- operaciones críticas (subida/borrado lógico, reset password),
- y correlación para reconstrucción de incidentes.

Tabla sugerida (mínimo viable)

`audit_logs`

- `id` (uuid)
- `created_at` (timestamp)
- **Actor**
 - `actor_user_id` (nullable para eventos anónimos)
 - `actor_email` (opcional, denormalizado para reporte)
- **Acción**
 - `action` (string estable: `AUTH_LOGIN_OK`, `USER_CREATED`, etc.)
 - `result` (`OK` / `FAIL`)
- **Recurso**
 - `resource_type` (ej. `User`, `Documento`, `DocumentoArchivo`)
 - `resource_id` (uuid/string)
- **Contexto**
 - `ip` (varchar)
 - `user_agent` (varchar)
 - `correlation_id` (string)
 - `meta_json` (json/text) sin PII/secretos

Índices sugeridos:

- (`created_at`), (`action`, `created_at`), (`actor_user_id`, `created_at`), (`resource_type`, `resource_id`)

Eventos mínimos recomendados (MVP+)

Autenticación

- `AUTH_LOGIN_OK`, `AUTH_LOGIN_FAIL`
- `AUTH_REFRESH_OK`, `AUTH_REFRESH_FAIL`
- `AUTH_LOGOUT`
- `AUTH_PASSWORD_RESET_REQUEST`, `AUTH_PASSWORD_RESET_CONFIRM_OK`, `AUTH_PASSWORD_RESET_CONFIRM_FAIL`

Autorización

- `AUTHZ_FORBIDDEN` — HTTP **403** con JWT válido (`meta_json`: método y ruta, sin exponer internals)

Usuarios

- `USER_CREATED` , `USER_UPDATED` , `USER_ACTIVATED` , `USER_DEACTIVATED`
- `USER_ROLES_CHANGED`
- `USER_PASSWORD_RESET` (admin)

Documentos y archivos (transversal)

- `DOC_CREATED` , `DOC_UPDATED`
- `DOC_STATE_CHANGED` — transición válida entre estados del documento (`meta_json` : `from` , `to`)
- `DOC_SUBMITTED_FOR_REVIEW` — envío a revisión (`REGISTRADO` → `EN_REVISION`)
- `DOC_REVIEW_RESOLVED` — decisión de revisor (`EN_REVISION` → `APROBADO` / `RECHAZADO` ; `meta_json` incluye `decision`)
- `DOC_FILE_UPLOADED` , `DOC_FILE_DOWNLOADED` , `DOC_FILE_DELETED`

Reportes

- `REPORT_EXPORTED` (tipo, filtro resumido, tamaño)

Cliente (RUM / rendimiento)

- `CLIENT_WEB_VITAL_LCP` — LCP del panel principal informado por el navegador (`POST /api/v1/client-perf/web-vitals`). `meta_json` incluye `valueMs` , `rating` , `pathname` , `navigationType` , `metricId` (sin PII ni elementos DOM).

RespalDOS (registro manual en aplicación)

- `BACKUP_VERIFIED` — un `ADMIN` registra que ejecutó y validó el respaldo institucional (MySQL/storage). Se expone en `GET /api/v1/dashboard/summary` (`lastSignals.lastBackupVerifiedAt`) y se crea con `POST /api/v1/dashboard/admin/backup-verification` .

Integridad y retención

- Retención mínima recomendada (tesis/MVP): 90–180 días (documentar decisión).
- Para instituciones: retención por política, exportación y respaldo de logs.
- Integridad: hashes encadenados o firma (futuro); como mínimo, **acceso restringido** y backups.

Pendientes para empezar a desarrollar (backlog accionable)

1. Crear modelo Prisma `AuditLog` + migración `audit_logs` .
2. Crear `AuditService` con método `log(action, resource, result, meta)` .

3. Integrar `AuditService` en:

- Auth (login/logout/refresh/reset),
- Usuarios (create/update/disable/reset),
- Reportes (export),
- Guards (403) cuando aplique.

4. Endpoints (ADMIN/AUDITOR):

- `GET /api/v1/auditoria` con filtros por actor/acción/fecha/recurso
- `GET /api/v1/auditoria/export` (CSV/Excel) si se requiere evidencia.

16 modulo reportes

Módulo — Reportes

Objetivo

Generación de exportaciones **Excel** (ExcelJS) y **PDF** (pdfkit) con filtros y respeto de permisos.

Alcance

Reportes de documentos, usuarios, auditoría según prioridad del MVP.

Estado actual

Implementado (ETAPA 9 + extensiones post-cierre — 2026-05-06). Evidencia de hito ETAPA 9: docs/38-etapa-9-cierre-y-evidencias.md .

- **Backend:** generación en servidor con **ExcelJS** y **pdfkit**; límite **5000** filas en exportes basados en listado de documentos (`ReportesService`).
- **Permisos:**
 - `ReportesController` declara rol base **ADMIN** (`@Roles('ADMIN')` a nivel de clase).
 - **Excepción explícita:** `GET .../pendientes-revision.{xlsx,pdf}` permiten **ADMIN** y **REVISOR** (`@Roles('ADMIN', 'REVISOR')` en el método), con las **mismas reglas de visibilidad** que `GET /documentos` (dependencia + confidencialidad).
- **Filtros (documentos genéricos):** mismos query params que búsqueda/listado (ETAPA 8): `q`, `estado`, catálogos, fechas, adjuntos, orden, `incluirInactivos` (sin paginación en el export: tope del servicio).
- **Auditoría:** `GET /api/v1/reportes/auditoria.xlsx` y `.pdf` (**ADMIN**), alineados a filtros de `GET /api/v1/auditoria`.
- **Trazabilidad:** cada export registra **REPORT_EXPORTED** en `audit_logs` con `meta` que incluye `format` y `kind` (`documentos` | `auditoria` | `pendientes-revision`).
- **Frontend:** `/documentos` — export Excel/PDF genérico (ADMIN); botones “**Pendientes revisión**” (REVISOR); `/admin/auditoria` — export (ADMIN).
- **Backlog:** reporte dedicado de **usuarios** (no implementado).

Decisiones técnicas

- Generación en servidor; no exponer rutas de plantillas sensibles; límites de filas/tamaño.

Endpoints (activos)

GET con query de filtros → stream de archivo (Content-Disposition: attachment).

Exportar documentos

- GET /api/v1/reportes/documentos.xlsx
- GET /api/v1/reportes/documentos.pdf

Query alineado a docs/14-modulo-busqueda.md (sin page / pageSize : el reporte trae hasta el tope del servicio).

Exportar auditoría (bitácora audit_logs)

- GET /api/v1/reportes/auditoria.xlsx
- GET /api/v1/reportes/auditoria.pdf

Query alineado al listado GET /api/v1/auditoria (action , result , actorEmail , resourceType , resourceId , from , to). **Solo ADMIN**. Cada export registra **REPORT_EXPORTED** (kind=auditoria).

Exportar pendientes de revisión (solo EN_REVISION)

- GET /api/v1/reportes/pendientes-revision.xlsx
- GET /api/v1/reportes/pendientes-revision.pdf

Sin filtros adicionales: lista documentos en estado **EN_REVISION** visibles para el usuario. **ADMIN** y **REVISOR**. **REPORT_EXPORTED** con kind=pendientes_revision .

Dependencias

- Módulos de dominio correspondientes; auditoría para trazabilidad de exportación.

17 modulo configuracion

Módulo — Configuración general

Objetivo

Parámetros del sistema (plazos, tamaños máximos, listas auxiliares) gestionables según rol administrativo.

Alcance

Persistencia en BD o fuente controlada; sin secretos en tablas de configuración UI.

Estado actual

Implementado parcialmente (MVP orientado a seguridad y respaldos).

Este repositorio implementa configuración **administrativa** en dos frentes:

- **Configuración de seguridad (ADMIN):** pantalla `/admin/configuracion`.
- **Respaldos y seguridad (ADMIN):** pantalla `/admin/respaldos` (ejecución manual de `mysqldump` + registro de verificación auditable).

Distinción clave: la pantalla de configuración de seguridad separa (1) el **estado efectivo** (lo que el backend aplica hoy con `.env`, guards y validaciones) y (2) la **política institucional** persistida como **registro** en BD (ISO 15489), que no necesariamente altera el runtime automáticamente.

Decisiones técnicas

- Secretos solo en variables de entorno (`18` , `02`).
 - Ejemplos: `JWT_ACCESS_SECRET` , `DATABASE_URL` , SMTP, rutas a `mysqldump` .
- Parámetros “no secretos” sí pueden persistirse como **registros** auditables (ISO 15489), con trazabilidad `updatedAt` y `timestamp`.

Pantallas

- Panel de configuración (alcance acordado con director de tesis).

Pantallas implementadas (ADMIN)

- **/admin/configuracion** : “Parámetros de seguridad”.
 - Lee:
 - `GET /api/v1/auth/admin/security-summary` (estado efectivo).
 - `GET /api/v1/auth/admin/security-policy` (política institucional guardada).
 - Guarda:
 - `POST /api/v1/auth/admin/security-policy` (actualiza `security_policy` y audita `SECURITY_POLICY_UPDATED`).
- **/admin/respalDOS** : “RespalDOS de información”.
 - Lee:
 - `GET /api/v1/dashboard/admin/backup-overview` (KPI + historial desde `audit_logs`).
 - Acciones:
 - `POST /api/v1/backup/admin/run-now` (ejecuta `mysqldump` “como el cron”; puede tardar varios minutos).
 - `POST /api/v1/dashboard/admin/backup-verification` (registra evidencia `BACKUP_VERIFIED` OK/FAIL).

Guía operativa de respaldo/restauración (local/XAMPP): `scripts/README-backups-mysql-xampp.md` .

Qué falta para empezar a desarrollar (backlog accionable)

1) Completar configuración general (parámetros NO secretos)

Parámetros recomendados para un SGD institucional:

Archivos

- `MAX_UPLOAD_MB` (ej. 10)
- `ALLOWED_MIME_TYPES` (lista blanca)
- `ALLOWED_EXTENSIONS` (lista blanca)

Sesión y autenticación

- `JWT_ACCESS_EXPIRES` (ya existe como env)
- `JWT_REFRESH_DAYS` (ya existe como env)
- `PASSWORD_RESET_MINUTES` (ya existe como env o definir)

- Throttling (**implementado:** `ThrottlerModule` + `@Throttle` en `/auth`; ver `18-seguridad-y-hardening.md`). Umbrales “institucionales” parametrizados en BD serían una evolución de este módulo.

Auditoría

- `AUDIT_RETENTION_DAYS`
- `AUDIT_EXPORT_ENABLED`

Documentos (ISO 15489)

- catálogo de `ESTADOS_DOCUMENTO` (si se formaliza)
- `RETENTION_POLICIES` (si se implementa conservación/retención)

2) Modelo de persistencia (estado actual y recomendado)

Estado actual: existe tabla `security_policy` como registro institucional (singleton `id="default"`) y se actualiza desde UI con auditoría.

Evolución recomendada: crear tabla `system_settings`:

- `key` (string unique)
- `value_json` (json/text)
- `updated_by_id`
- `updated_at`

Reglas:

- No guardar secretos (tokens, passwords, llaves) aquí.
- Cambios deben generar evento en auditoría transversal (`SETTINGS_UPDATED`).

3) Endpoints (ADMIN)

Implementados (seguridad / respaldos):

- `GET /api/v1/auth/admin/security-summary` (ADMIN)
- `GET /api/v1/auth/admin/security-policy` (ADMIN)
- `POST /api/v1/auth/admin/security-policy` (ADMIN)
- `GET /api/v1/dashboard/admin/backup-overview` (ADMIN)
- `POST /api/v1/dashboard/admin/backup-verification` (ADMIN)
- `POST /api/v1/backup/admin/run-now` (ADMIN)

Futuro (configuración general):

- `GET /api/v1/configuracion` (ADMIN) — lista de settings (no secretos)

- PATCH `/api/v1/configuracion` (ADMIN) — actualizar settings permitidos (validación estricta por `key`)

4) UI (ADMIN)

Ruta sugerida: `/admin/configuracion`

- Sección Archivos (límite, MIME, extensiones)
- Sección Sesión (expiraciones informativas)
- Sección Auditoría (retención/export)

5) Validaciones y seguridad

- Validación server-side estricta por `key` (no aceptar claves arbitrarias).
- Registrar cambios con actor + IP/UA si aplica.

18 seguridad y hardening

Seguridad y hardening — SGD-GADPR-LM

Objetivo

Definir la línea base de **controles técnicos** alineados como referencia con ISO/IEC 27001:2022 (gestión de seguridad de la información), ISO 15489 (gestión documental) y OWASP ASVS, **sin** pretender certificación formal en el alcance de tesis.

Alcance

Autenticación, autorización, datos, archivos, comunicaciones en desarrollo local y pruebas; exposición temporal con ngrok.

Estado actual

Implementación: aplicada en el MVP. Este documento se mantiene como **referencia** y registro de controles implementados.

Cierre roadmap: evidencias formales de hardening dentro del MVP en `docs/39-etapa-10-cierre-y-evidencias.md` (ETAPA 10).

Decisiones técnicas

Área	Decisión
Autenticación	JWT access token (vida corta); refresh en cookie HttpOnly
Contraseñas	Argon2id (costes acordados en código)
API	Validación servidor (class-validator / DTOs); no confiar solo en el cliente
Errores	Mensajes genéricos al cliente; no filtrar stack ni detalles internos
Archivos	Lista blanca MIME/extensión, tamaño máximo, nombres seguros; servir vía API con permiso
Auditoría	Eventos críticos (login, cambios sensibles, descarga) en modelo dedicado
Headers	Helmet para headers de seguridad; deshabilitar <code>x-powered-by</code>
HTTPS local	Opcional; ngrok aporta HTTPS en demos temporales

Estructura prevista (código)

- Backend: `AuthModule` , guards JWT y de permisos, `Audit` o equivalente.
- Frontend: rutas protegidas, no almacenar refresh en `localStorage` .

Flujos

1. Login → access + Set-Cookie refresh → requests con `Authorization: Bearer` .
2. Refresh → nuevo access; rotación de refresh según diseño.
3. Logout → invalidar refresh en servidor (lista/bloqueo) cuando exista persistencia.

Controles implementados (resumen)

- **Headers seguridad:** Helmet en `backend/src/main.ts` .
- **Rate limiting:** `ThrottlerModule` global (`app.module.ts`); rutas `/auth` con `@Throttle` más estricto (`auth.controller.ts`); excesos registrados como `AUTH_RATE_LIMITED` (`throttler-audit.filter.ts`).
- **Lockout por cuenta:** contador e intervalo en `users` (`AUTH_LOCKOUT_MAX_ATTEMPTS` , `AUTH_LOCKOUT_MINUTES`); complementa el throttling por IP.
- **403 auditado:** intentos contra endpoints con rol insuficiente generan `AUTHZ_FORBIDDEN` (`forbidden-audit.filter.ts`).
- **Cookies refresh:** `HttpOnly` , `secure` en producción, `sameSite=lax` , `path=/` ; `clearCookie` con mismos flags.
- **Validación API:** `ValidationPipe` global (`whitelist` , `forbidNonWhitelisted` , `transform`).
- **RBAC por rol:** `RolesGuard` + `@Roles(...)` ; mutaciones y reportes típicamente **ADMIN**; excepción documentada: export **pendientes de revisión** permite **ADMIN** o **REVISOR** (`reportes.controller.ts`).
- **Archivos:** lista blanca MIME, tamaño máximo, nombres seguros, descarga controlada vía API.
- **Trazabilidad:**
 - `documento_eventos` (CREADO/ACTUALIZADO)
 - `documento_archivo_eventos` (SUBIDO/DESCARGADO/ELIMINADO)

Controles OWASP ASVS (resumen)

- Validación y sanitización de entradas.
- Sesiones y tokens con expiración.
- Protección de rutas y datos por rol.
- Subida de archivos acotada y trazada.

Directorio backups/automated

- Los volcados **MySQL** (`.sql`) y **ZIP opcional de storage/** pueden generarse desde el proceso Nest (`BACKUP_*` en `backend/.env`).
- **Contienen datos completos:** aplicar controles ISO 27001 (mínimo privilegio en NTFS/Linux, sin exposición web, sin versionar en git — ver `.gitignore` y `backups/automated/README.md`).
- La **restauración** no se ejecuta desde la aplicación web; debe ser procedimiento institucional acotado.

ngrok (temporal)

Detalle operativo, CORS y cookies: `23-entorno-local-xampp-ngrok.md` . Cada sesión debe registrarse en `22-changelog-tecnico.md` .

- **Sesión activa (2026-05-07):** frontend Vite en `:5175` expuesto por ngrok (ver entrada en `22-changelog-tecnico.md`).

cloudflared tunnel (temporal)

Uso alternativo para exponer el **frontend Vite (5173)** de forma temporal. Reglas mínimas:

- Mantener el túnel activo el **menor tiempo posible**.
- Usar **datos de prueba** (evitar PII / información real).
- Si el flujo de auth depende de cookies/JWT, revisar impacto en **CORS** y flags de cookies (`HttpOnly` , `SameSite` , `Secure`).
- Registrar cada sesión en `22-changelog-tecnico.md` .

Manual operativo: `26-cloudflared-tunnel.md` .

Problemas detectados

- Seguimiento activo en `20-problemas-detectados.md` cuando existan hallazgos verificados.

Riesgos pendientes

- Exponer API por ngrok sin restricción de IP o credenciales débiles → mitigar con tokens fuertes, tiempo de sesión corto y cierre del túnel al terminar.

Mejoras futuras

WAF, MFA institucional, HSM, pentest formal — fuera del MVP de tesis.

19 mapeo iso27001 iso15489 owasp asvs

Mapeo de controles — ISO/IEC 27001:2022, ISO 15489 y OWASP ASVS (MVP)

Objetivo de este documento

Explicar **qué es** y **para qué sirve** cada referencia:

- **ISO/IEC 27001:2022** (gestión de seguridad de la información),
- **ISO 15489** (gestión de documentos/records management),
- **OWASP ASVS** (estándar de verificación de seguridad para apps web),

y mostrar **paso a paso**:

1. **qué control** se necesitó en el MVP,
2. **por qué** se aplicó,
3. **dónde** quedó implementado en el código (archivos/rutas/tablas),
4. **qué hace** técnicamente,
5. **cómo comprobarlo** (pasos de prueba).

Importante: en este proyecto se usan ISO/IEC 27001:2022 e ISO 15489 como **referencia** (no certificación), y OWASP ASVS como guía práctica de controles técnicos verificables.

Revisión de coherencia con el código: 2026-05-06 — índice y snapshot `docs/README.md` ; lista de controles instalados vs brechas institucionales `docs/28-listado-lo-que-deberia-tener-el-sistema.md` .

1) ¿Qué es cada estándar? (explicación corta y clara)

1.1 ISO/IEC 27001:2022 (visión de “gestión”)

Qué es: un estándar internacional para establecer y operar un **SGSI** (Sistema de Gestión de Seguridad de la Información).

Qué aporta al proyecto: una forma “de arriba hacia abajo” de pensar seguridad: políticas, roles, riesgos, controles, evidencias.

Cómo lo usamos aquí: como marco para justificar decisiones como:

- autenticación robusta,
- control de acceso,
- trazabilidad,
- manejo seguro de archivos,
- hardening de API.

1.2 ISO 15489 (visión de “gestión documental”)

Qué es: un estándar internacional para la **gestión de documentos/records**: creación, clasificación, retención, integridad, trazabilidad y acceso.

Cómo lo usamos aquí: como guía para que un SGD no sea solo CRUD:

- **clasificación** (Series/Subseries),
- **metadatos** (Tipo documental, asunto, fecha),
- **trazabilidad** (historial de cambios),
- **control de acceso** (roles),
- **gestión de adjuntos** (almacenamiento controlado).

1.3 OWASP ASVS (visión “técnica/verificable”)

Qué es: un estándar de OWASP para **verificar** seguridad de aplicaciones web por requisitos (autenticación, sesión, acceso, validación, errores, etc.).

Cómo lo usamos aquí: para implementar controles técnicos concretos que se puedan **probar**:

- JWT + refresh seguro,
 - cookies HttpOnly,
 - validación server-side (DTO/ValidationPipe),
 - RBAC por rol,
 - subida/descarga de archivos con whitelist y límites,
 - headers de seguridad con Helmet,
 - no filtrar errores sensibles.
-

2) Mapeo “control → implementación” (paso a paso)

2.1 Autenticación y sesión (ISO 27001 + ASVS)

Paso 1 — Decisión: JWT access + refresh HttpOnly

- **Por qué:** reduce riesgo de robo de sesión por XSS (no guardamos refresh en `localStorage`) y permite sesiones “mantenidas” con refresh.
- **Qué hace:**
 - el **access token** se usa en `Authorization: Bearer ...` (vida corta)
 - el **refresh** va en cookie **HttpOnly** (renueva access sin exponer el refresh a JS)

Dónde está implementado:

- `backend/src/auth/auth.controller.ts`
 - `POST /api/v1/auth/login` → set cookie refresh
 - `POST /api/v1/auth/refresh`
 - `POST /api/v1/auth/logout` → clear cookie
- `backend/src/auth/auth.service.ts` (hash SHA-256 de refresh + persistencia)
- `backend/prisma/schema.prisma` → tabla `refresh_tokens`
- Frontend:
 - `frontend/src/api/client.ts` → interceptor: Bearer + reintento con refresh
 - `frontend/src/auth/*` → token access en memoria + manejo sesión perdida

Cómo comprobarlo (prueba):

1. Inicia sesión en `/login`.
 2. En DevTools → Application → Cookies, verifica cookie `sgd_refresh` (o la configurada).
 3. Expira el access (o fuerza 401) y observa que el frontend llama `/auth/refresh`.
 4. Logout → cookie se limpia y se pierde sesión.
-

2.2 Autorización (RBAC por rol) (ISO 27001 + ASVS)

Paso 2 — Decisión: control por rol `ADMIN` en mutaciones y reportes

- **Por qué:** principio de mínimo privilegio (evita que cualquier usuario modifique catálogos/documentos/experte).
- **Qué hace:** limita `POST/PATCH/DELETE` a rol `ADMIN`.

Dónde está implementado:

- Backend:
 - `backend/src/auth/decorators/roles.decorator.ts` (`@Roles(...)`)
 - `backend/src/auth/guards/roles.guard.ts`
 - Controladores (ej. documentos/catálogos/reportes) con `@Roles('ADMIN')`
- Frontend:
 - `frontend/src/routes/RoleRoute.tsx` (protege rutas de catálogos)
 - `frontend/src/layouts/MainLayout.tsx` (menú Catálogos solo ADMIN)

Cómo comprobarlo (prueba):

1. Inicia sesión con un usuario no ADMIN.
 2. Intenta entrar a `/catalogos/dependencias` → debe ir a 403.
 3. Intenta exportar reportes (botones no aparecen si no ADMIN).
-

2.3 Validación server-side (ASVS)

Paso 3 — Validación global con `ValidationPipe`

- **Por qué:** no confiar en el cliente; evita inyección de campos, tipos inválidos y datos basura.
- **Qué hace:**
 - elimina campos extra (`whitelist`)
 - falla si llegan campos no permitidos (`forbidNonWhitelisted`)
 - transforma tipos (`transform`)

Dónde está implementado:

- `backend/src/main.ts` (`ValidationPipe` global)
- DTOs en módulos (`backend/src/**/*.dto/*.dto.ts`)

Cómo comprobarlo (prueba):

1. Envía un `POST` con un campo extra (por Postman/DevTools).
 2. Debe devolver error por campo no permitido.
-

2.4 Seguridad de archivos (ISO 27001 + ISO 15489 + ASVS)

Paso 4 — Subida/descarga controlada + storage no público

- **Por qué (seguridad):**
 - evitar servir archivos desde disco sin autorización,

- evitar subir ejecutables/formatos peligrosos,
- prevenir DoS por archivos enormes.

- **Por qué (gestión documental):**

- mantener evidencia y trazabilidad,
- versiones,
- metadatos del archivo (tipo/tamaño/hash).

Qué hace técnicamente:

- Guarda archivos en `storage/documentos/<documentoId>/...` (no se expone como carpeta pública).
- Limita a **10MB** y MIME permitido.
- Calcula **SHA-256**.
- Maneja **versionado** por `documentoId + originalName`.
- Permite **borrado lógico** (no elimina físicamente por defecto).
- Registra eventos de archivo: `SUBIDO / DESCARGADO / ELIMINADO`.

Dónde está implementado:

- BD:
 - `documento_archivos`, `documento_archivo_eventos` en `backend/prisma/schema.prisma`
 - migraciones `20260421193000_add_documento_archivos`,
`20260421194500_documento_archivos_versionado`
- API (Documentos):
 - `GET /api/v1/documentos/:id/archivos`
 - `POST /api/v1/documentos/:id/archivos` (ADMIN)
 - `GET /api/v1/documentos/:id/archivos/:archivoId/download` (JWT)
 - `GET /api/v1/documentos/:id/archivos/:archivoId/eventos`
 - `DELETE /api/v1/documentos/:id/archivos/:archivoId` (ADMIN, lógico)
- Código:
 - `backend/src/documentos/documentos.controller.ts`
 - `backend/src/documentos/documentos.service.ts`
- UI:
 - `frontend/src/pages/documentos/DocumentoDetallePage.tsx`

Cómo comprobarlo (prueba):

1. Entra a `/documentos/:id`.
2. Sube un PDF (<10MB) → aparece v1.
3. Sube de nuevo mismo nombre → aparece v2.
4. Descarga → revisa historial del archivo.

5. Elimina (ADMIN) → desaparece del listado; historial registra `ELIMINADO`.

2.5 Trazabilidad (ISO 15489 + ISO 27001)

Paso 5 — Historial de documento y archivo

- **Por qué:** integridad, auditoría, y reconstrucción de cambios.
- **Qué hace:**
 - Documento: `CREADO/ACTUALIZADO` con snapshot/diff.
 - Archivo: `SUBIDO/DESCARGADO/ELIMINADO` con `metaJson` (incluye IP en descargas).

Dónde está implementado:

- `documento_eventos`, `documento_archivo_eventos` (Prisma + migraciones)
 - `backend/src/documentos/documentos.service.ts` (creación automática de eventos)
 - UI:
 - Historial documento: `/documentos/:id`
 - Historial archivo: diálogo en sección Archivos
-

2.6 Hardening de API (ASVS)

Paso 6 — Security headers con Helmet y reducción de fingerprinting

- **Por qué:** baseline de seguridad web (headers) y menor exposición de información del servidor.
- **Qué hace:**
 - agrega headers típicos de seguridad (Helmet),
 - deshabilita `x-powered-by`.

Dónde está implementado:

- `backend/src/main.ts`

Cómo comprobarlo (prueba):

1. Abre Network → request a `/api/v1/health`.
 2. Verifica que no exista `x-powered-by` y que existan headers de Helmet.
-

3) Qué NO se implementa “al 100%” por ser fuera del MVP

Esto es importante para tu tesis: no significa “falta”, significa **fuera del alcance**.

- **Certificación** ISO/IEC 27001 o auditoría formal del SGSI (requiere procesos institucionales).
 - **Retención y disposición documental** completa (ISO 15489) con reglas de archivo central, tiempos, expurgo, etc.
 - **Permisos granulares** (más allá de roles) usando `Permission/role_permissions` como enforcement completo.
 - **WAF/MFA/pentest formal**.
-

4) Checklist final de evidencia (para anexos)

- Capturas:
 - Login + cookie refresh HttpOnly
 - 403 en rutas sin permiso (no ADMIN)
 - Historial de documento (CREADO/ACTUALIZADO)
 - Historial de archivo (SUBIDO/DESCARGADO/ELIMINADO)
 - Exportación Excel/PDF
 - Headers de seguridad (Helmet) en respuesta de `/health`

19 pruebas y validaciones

Pruebas y validaciones — SGD-GADPR-LM

Objetivo

Establecer **criterios repetibles** de calidad para frontend y backend antes de considerar cerrada cada iteración.

Alcance

Comandos locales, tipos de prueba previstos y evidencias mínimas para tesis.

Estado actual

- **Backend:** Jest (`npm run test`), e2e Supertest (`npm run test:e2e`), ESLint, Prettier.
- **Frontend:** ESLint (`npm run lint`), build `tsc -b && vite build` (`npm run build`). Sin tests de UI aún (opcional añadir Vitest en iteración futura).

Arranque para prueba manual integral: iniciar **MySQL (XAMPP)** → `npm run start:dev` en `backend/` (puerto **3000**) → `npm run dev` en `frontend/` (**5173**). Si solo corre Vite, el proxy mostrará `ECONNREFUSED` contra `:3000`.

Decisiones técnicas

Paquete	Comando (cuando exista)	Notas
Backend	<code>npm run format</code> , <code>npm run lint</code> , <code>npm run build</code> , <code>npm run test</code> , <code>npx tsc --noEmit</code>	Ejecutar desde <code>backend/</code>
Frontend	<code>npm run format</code> , <code>npm run lint</code> , <code>npm run build</code> , <code>npm run test</code> , <code>npx tsc --noEmit</code>	Ejecutar desde <code>frontend/</code> cuando exista

Estructura

- Unitarias: servicios NestJS, utilidades, hooks (frontend).

- Integración: API + Prisma (con BD de prueba o contenedor local si se acordara; por defecto XAMPP).
- E2E: flujos críticos (login, crear documento, subir archivo) — planificar en ETAPA 3+.

Problemas detectados

- Sin pipeline CI en el repositorio; validación manual por ahora.

Riesgos pendientes

- Regresiones si no se ejecutan scripts antes de merge.

Mejoras futuras

GitLab/GitHub Actions con los mismos comandos.

20 problemas detectados

Problemas detectados — SGD-GADPR-LM

Objetivo

Registrar incidencias técnicas con **identificador**, estado y acción, sin perder el hilo entre iteraciones.

Alcance

Código, entorno, documentación y herramientas del repositorio.

Estado actual

Última revisión documental conjunta con el código: **2026-05-06** (alineación de módulos, README snapshot, backlog 00 ; cierre ETAPA 0 conserva evidencia en docs/29-etapa-0-cierre-y-evidencias.md).

Registro

ID	Descripción	Módulo / área	Causa probable	Impacto	Estado	Solución / siguiente paso
P-0001	No existía carpeta frontend/ ni SPA	ETAPA 1	—	Bloqueaba UI	Cerrado	Vite + React 18 + MUI + Router + axios en frontend/
P-0002	Sin Prisma / sin modelo persistido	ETAPA 2	—	Sin persistencia	Cerrado (schema + migración init_rbac en repo; falta aplicar migración en cada entorno)	
P-0	Archivo .env local ausente hasta que el	Entorno	Cada máquina	Sin DB hasta	Cerrado (ámbito repo)	backend/.env.example + README: copiar a .env , definir

ID	Descripción	Módulo / área	Causa probable	Impacto	Estado	Solución / siguiente paso
03	desarrollador lo crea desde la plantilla			configurar		DATABASE_URL ; no es déficit ETAPA 0
P-004	CI/agente sin XAMPP: no puede validar MySQL vivo	Infra	Entorno solo local	No automatizable desde Git	Cerrado (ámbito repo)	Procedimiento en README.md , 04-modelo-base-de-datos.md ; validación manual del desarrollador
P-005	Archivos vacíos/ erróneos eliminados: 17-seguridad... , 21-changelog... duplicado	Docs	Numación previa	Confusión	Cerrado	Sustituídos por 18-seguridad-y-hardening.md y 21-riesgos-pendientes.md ; changelog único en 22
P-006	Sin .gitignore en raíz (añadido en saneamiento 2026-04-19)	Repo	Omisión inicial	Riesgo de commit de secretos	Cerrado	.gitignore en raíz con .env y storage/*
P-007	Backend sin prefijo / api/v1 , sin ConfigModule, sin CORS	Backend	Plantilla NestJS mínima	No alineado a convenciones API	Cerrado	main.ts : ConfigModule , setGlobalPrefix('api/v1') , enableCors , ValidationPipe
P-008	ESLint: promesa flotante en bootstrap()	backend/src/main.ts	Patrón típico Nest	Warning	Cerrado	Uso de void bootstrap();
P-009	Sin README.md en raíz ni carpeta storage/ versionada	Repo	ETAPA 0 incompleta	Onboarding pobre	Cerrado	README.md + storage/.gitkeep ; .gitignore ignora contenido de storage/
P-010	Sin backend/.env.example	Entorno	No documentado	Fricción al configurar Prisma/JWT	Cerrado	Añadido backend/.env.example

Mejoras al proceso

Tras cada cambio sustantivo, actualizar este archivo y `22-changelog-tecnico.md` .

21 riesgos pendientes

Riesgos pendientes — SGD-GADPR-LM

Objetivo

Registrar **riesgos técnicos y operativos** con mitigación y seguimiento.

Alcance

Desarrollo local, demo con ngrok, datos de prueba y extensión futura.

Estado actual

Actualizado **2026-05-06** (coherencia con anti-IDOR en documentos, auditoría UI, logout y reportes extendidos). *ETAPA 0* cerrada como hito (docs/29-etapa-0-cierre-y-evidencias.md).
Detalle técnico: docs/22-changelog-tecnico.md .

Registro

ID	Descripción	Impacto	Probabilidad	Prioridad	Mitigación	Estado	Decisión / notas
R-0001	Retraso por mezclar UI y backend sin orden de fases	Alto	Media	Alta	Seguir 00-roadmap-general.md ; no crear pantallas antes de ETAPA 1–2 acordadas	Abierto	—
R-0002	Documentación desincronizada del código	Medio	Media	Media	Actualizar docs tocados en cada PR/iteración	Abierto	—
R-0	Secretos filtrados por error en Git	Alto	Baja	Alta	.gitignore ; no commitear .env ; revisar	Abierto	—

ID	Descripción	Impacto	Probabilidad	Prioridad	Mitigación	Estado	Decisión / notas
03					historial si hubo commit accidental		
R-004	Exposición ngrok de API sin controles	Alto	Media	Media	Documentar sesión; CORS estricto; cerrar túnel; no usar en datos reales	Abierto	Ver 23-entorno-local-xampp-ngrok.md
R-005	Root MySQL sin contraseña solo en dev	Medio	Alta (en XAMPP default)	Media	Contraseña en MySQL para equipos compartidos; documentar en entorno	Abierto	Solo laboratorio aislado
R-006	Enumeración de cuentas en recuperación de credenciales (revelar si el correo existe)	Alto	Media	Alta	Respuesta constante 202 { ok: true }; no revelar existencia; registrar en audit_logs	Mitigado	API + registro AUTH_PASSWORD_RESET_REQUEST (y variantes) en audit_logs
R-007	Abuso de endpoint de recuperación (fuerza bruta / spam)	Medio	Media	Media	Rate limit (por IP y por email), backoff; CAPTCHA institucional si aplica; monitoreo de picos	Mitigado (parcial)	Implementado @nestjs/throttler global + rutas /auth ; refinar por email como clave adicional si la política lo exige
R-008	Token de restablecimiento expuesto en canales inseguros (debug/dev)	Alto	Media	Alta	En producción no devolver debugToken ; enviar token por correo institucional; rotación/revocación de tokens previos no usados	Abierto	En dev se devuelve debugToken solo para pruebas; documentar como “no productivo”
R-009	Persistencia de sesiones tras restablecer contraseña	Alto	Media	Alta	Revocar refresh_tokens activos del usuario al confirmar reset; forzar re-login	Mitigado	Implementado en transacción del reset
R-0	IDOR (acceso a				Validar autorización por recurso en cada endpoint;	Mitigado	Documentos/adjuntos/reportes: filtros por dependencia +

I D	Descripción	Impacto	Probabilidad	Prioridad	Mitigación	Estado	Decisión / notas
10	recursos por UUID sin validar permisos/ propiedad)	Alto	Media	Alta	no confiar en IDs del cliente; pruebas negativas	do (parcial)	confidencialidad para no-ADMIN; JWT con <code>dependenciaId</code> . Persisten riesgos de política fina / permiso granular no modelado (07).
R-011	Controles incompletos de auditoría transversal (eventos de seguridad/ administración)	Alto	Media	Alta	Completar cobertura por módulo; correlación; retención; exportación ADMIN; integridad básica	Mitigado (parcial)	<code>audit_logs</code> + <code>AuditService</code> ; UI /admin/auditoria + exports; persisten retención institucional y cobertura total opcional de denegaciones.
R-012	Subida de archivos maliciosos (MIME falso / polyglot / DoS por tamaño)	Alto	Media	Alta	Validación MIME real, tamaño, extensión, nombres seguros; antivirus institucional si existe; quotas; streaming controlado	Mitigado (parcial)	Implementada whitelist y tamaño; AV/quota no implementado
R-013	Exposición de archivos por servir storage como carpeta pública	Alto	Baja	Alta	Storage fuera del directorio público; descarga solo vía API con JWT/permiso; registrar descargas	Mitigado	Implementado: storage no público + descarga controlada + evento DESCARGADO
R-014	Pérdida de integridad o no-repudio de archivos (sin hash/ verificación)	Medio	Media	Media	Calcular SHA-256; almacenar en BD; verificar opcional en descarga; registrar versiones	Mitigado (parcial)	SHA-256 almacenado; verificación en descarga es mejora futura
R-015	Falta de retención/ disposición documental (ISO 15489)	Medio	Media	Media	Definir política por tipo/ serie; estados de archivo/ transferencia; plazos; evidencias (reportes)	Abierto	Fuera del MVP “duro”, pero recomendado para tesis si se exige ISO 15489 completa
R-0	Falta de respaldos operativos y	Alto	Media	Alta	Backups BD + storage + logs; pruebas de restore;	Abierto	Documentar y automatizar en ETAPA 10 (hardening y cierre)

ID	Descripción	Impacto	Probabilidad	Prioridad	Mitigación	Estado	Decisión / notas
16	pruebas de restauración				RPO/RTO; registro de ejecuciones		
R-017	CORS/cookies mal configurados en exposición temporal (ngrok/cloudflared)	Alto	Media	Media	CORS_ORIGIN estricto; sameSite; secure en prod; no usar datos reales; cerrar túnel	Abierto	Riesgo recurrente en demos
R-018	Falta de segregación de funciones (ADMIN único con todo)	Medio	Media	Media	Separar roles: Admin seguridad, Admin catálogos, Operador, Auditor; mínimo privilegio	Abierto	Existen REVISOR , AUDITOR , CONSULTA en seed y administración de usuarios; la segregación fuerte sigue pendiente hasta PermissionsGuard y flujos por rol (07).
R-019	Gestión de usuarios incompleta (sin desactivación, sin rotación de roles, sin historial central)	Medio	Media	Media	Endpoint y UI para activar/inactivar; auditoría de cambios; rotación de roles con evidencia	Mitigado (parcial)	Activar/desactivar y asignación de roles en API + /admin/usuarios ; auditoría central de todo el historial administrativo pendiente según alcance institucional.
R-020	Exposición de PII en logs o respuestas	Medio	Media	Media	Sanitizar respuestas; evitar log de cuerpos/headers sensibles; mascar datos; política de logging	Abierto	Aún no existe política central de logs/auditoría
R-021	Dependencias/bibliotecas con vulnerabilidades (supply chain)	Alto	Media	Alta	npm audit periódico; actualización controlada; lockfile; revisión CVEs	Abierto	Recomendado en ETAPA 10
R-0	Controles CSRF en		Baja		sameSite=lax ; endpoints sensibles por	Mitiga	

I D	Descripción	Impacto	Probabilidad	Prioridad	Mitigación	Estado	Decisión / notas
22	presencia de cookies (refresh HttpOnly)	Medio		Media	POST; considerar token anti-CSRF si se amplía el uso de cookies	do (parcial)	Diseño actual reduce superficie, pero no es CSRF "cero" si crece el sistema

Relación con problemas

Los problemas operativos concretos se enlazan desde [20-problemas-detectados.md](#).

22 changelog tecnico

Changelog técnico — SGD-GADPR-LM

Objetivo

Registrar cambios relevantes en **entorno**, **migraciones Prisma**, **exposición ngrok** y decisiones que afecten despliegue local o seguridad.

Alcance

Entradas breves enlazadas a módulos y a `18-seguridad-y-hardening.md` cuando aplique.

Estado actual

- Activo desde baseline 2026-04-19.

Formato por entrada

```
### YYYY-MM-DD – Título corto
- Qué cambió (migración, variable, puerto, etc.).
- Referencia a sección en docs/ si aplica.
```

Registro

2026-05-07 — ngrok — Frontend Vite (5175)

- **Comando:** `ngrok http 5175`
- **URL pública:** `https://05ff-200-112-221-9.ngrok-free.app`
- **Propósito:** acceso remoto temporal fuera de la LAN para revisión/demos.
- **Alcance:** solo UI (SPA) en `frontend/` (no expone directamente la API).
- **Riesgos:** exposición pública temporal (enumeración de rutas, fuerza bruta contra login si el backend también es accesible por otros medios).
- **Medidas:** tiempo mínimo del túnel, usar datos de prueba, no compartir credenciales, cerrar túnel al terminar.

- **Referencia:** 18-seguridad-y-hardening.md → sección “ngrok (temporal)” y 23-entorno-local-xampp-ngrok.md.

2026-05-07 — RBAC granular: PermissionsGuard, API /rbac, seed role_permissions, UI «Matriz rol ↔ permiso»

- **Backend:** permission-codes.ts, @Permissions, PermissionsGuard, módulo rbac/ (listar permisos/roles; GET/PUT .../roles/:codigo/permissions; GET /rbac/me/permissions). Cambios registrados **ROLE_PERMISSIONS_UPDATED**.
- **Seed:** permissions + asignaciones por rol después de crear roles (idempotente).
- **Rutas:** documentos (incl. archivos/revisión), catálogo escrituras, usuarios, reportes, auditoría lista, dashboard admin/backup KPI, ejecutar backup, política seguridad GET/POST auth.
- **Frontend:** pantalla usuarios · sección matriz BD + botón **Permisos por rol (BD)**.
- **Docs:** 07, README snapshot RBAC, 27-manual § 5.1.

2026-05-07 — Seguimiento respaldos: .gitignore, carpeta backups/automated, script PowerShell y hardening doc

- **Repo:** ignorar *.sql / *.zip bajo backups/automated/; README.md de la carpeta con reglas de permisos y no exposición web.
- **Script:** scripts/configure-local-backups.ps1 — añade bloque BACKUP_* a backend/.env si falta BACKUP_MYSQLDUMP_PATH.
- **Docs:** 18-seguridad-y-hardening.md (directorio de respaldos), scripts/README-backups-mysql-xampp.md (checklist), 27-manual-usuario § 11.

2026-05-07 — Respaldos: mysqldump automático (cron), registro FAIL y POST /backup/admin/run-now

- **Backend:** módulo backup/ + ScheduleModule — MysqlDumpBackupService ejecuta mysqldump con .cnf temporal (sin password en línea de comandos), rotación BACKUP_KEEP_COUNT, ZIP opcional de storage/ (BACKUP_INCLUDE_STORAGE_ZIP); auditoría BACKUP_VERIFIED con meta.source=scheduled_mysqldump y resultado OK/FAIL.
- **API:** POST /api/v1/backup/admin/run-now (ADMIN) — mismo flujo sin esperar al cron.
- **Dashboard:** POST .../backup-verification acepta result OK|FAIL; backup-overview v2 añade automatedBackup y historial[].source.
- **Frontend:** radios OK/FAIL, columna Origen, tarjeta y botón mysqldump inmediato.
- **Docs:** scripts/README-backups-mysql-xampp.md, 27-manual-usuario-sgd-gadpr-lm.md § 11, backend/.env.example.

2026-05-07 — Rendimiento: prefetch post-login + LCP en panel (RUM auditado)

- **Frontend:** `PostLoginPerfScheduler` + `perf/postLoginPrefetch.ts` — `requestIdleCallback` precarga chunks de `/`, `/documentos`, `/perfil` y GET alineados (resumen dashboard, perfil, bandeja documentos por defecto, catálogos de bandeja, `health`, `admin/ping` si ADMIN). Dependencia `web-vitals`; hook `useDashboardLcpReporting` en `DashboardPage`.
- **Backend:** `POST /api/v1/client-perf/web-vitals` (JWT, throttle) → `audit_logs` (`CLIENT_WEB_VITAL_LCP`, `resourceType=ClientPerf`).
- **Docs:** `40-rendimiento-post-login-web-vitals.md`, `15-modulo-auditoria.md`, `27-manual-usuario` § 1.5.
- **PR:** rama `perf/post-login-prefetch-web-vitals` → `main`.

2026-05-06 — Respaldos (ADMIN): KPI + historial real desde auditoría

BACKUP_VERIFIED

- **API:** `GET /api/v1/dashboard/admin/backup-overview` — hasta 50 filas recientes de `BACKUP_VERIFIED`, conteos OK/FAIL en 90 días, último OK y texto opcional `BACKUP_EXPECTED_SCHEDULE_HINT` desde entorno (sin cron en la app).
- **API:** `POST .../dashboard/admin/backup-verification` — meta ampliada (`tipoRespaldo`, `tamanoLabel`, `tamanoBytes`, `notes`) persistida en `meta` del log de auditoría.
- **Frontend:** `/admin/respaldos` consume el overview; elimina datos ilustrativos ficticios; formulario de registro con campos opcionales.
- **Docs:** `27-manual-usuario-sgd-gadpr-lm.md` § 11, `backend/.env.example`.

2026-05-06 — Auditoría (ADMIN): expediente por código real y filtros coherentes con BD

- **API/UI:** respuesta `GET /api/v1/auditoria` y exports `reportes/auditoria.{xlsx,pdf}` enriquecidos con `resourceCodigo` (lookup `documentos.codigo` por `Documento.resourceId` o `meta.documentoId`).
- **Filtros:** `action` pasa de `contains` a **igualdad exacta**; nuevo query `actorUserId` (UUID); la UI deja de filtrar solo por correo inferido.
- **Código:** `backend/src/auditoria/audit-list.util.ts` compartido con `ReportesService.findAuditLogs`.
- **Docs:** `15-modulo-auditoria.md`, `27-manual-usuario-sgd-gadpr-lm.md` § 10.

2026-05-06 — Identidades (ADMIN): último ingreso real y matriz desde API

- **Datos:** migración `20260506143000_user_ultimo_login` — columna `users.ultimo_login_at` (actualizada en `AUTH_LOGIN_OK` con credenciales).

- **API:** `GET /api/v1/usuarios/matriz-acceso-referencia` — matriz efectiva alineada a `access-matrix.reference.ts` (evita matriz solo en cliente).
- **Perfil:** `GET .../auth/me/profile` prioriza `ultimoLoginAt` persistido y conserva respaldo por auditoría.
- **UI:** `/admin/usuarios` — dependencia/cargo visibles, estado **Suspendido**, último ingreso formateado, matriz consumida del servidor, acción **Ir a usuarios para asignar roles** (sin botón “guardar” ficticio).
- **Docs:** `04-modelo-base-de-datos.md`, `27-manual-usuario-sgd-gadpr-lm.md` § 5.1.

2026-05-06 — Clasificación documental: ficha y tabla con datos reales (agregados + honestidad sobre retención)

- **API:** `GET /api/v1/documentos/clasificacion-agregados` — por serie/subserie activa del catálogo: cuenta de expedientes visibles (`activo` + misma función de alcance que `GET /documentos`), dependencia y nivel de confidencialidad predominantes entre esos registros (`DocumentosService.getClasificacionAgregados`).
- **Frontend:** `/clasificacion` consume ese endpoint junto al catálogo; ficha muestra métricas reales sin inventar plazos/disposición final; tabla añade **Expedientes visibles** por serie; botón Actualizar coherente con otras pantallas.
- **Docs:** `27-manual-usuario-sgd-gadpr-lm.md` § 7.2.2.

2026-05-07 — Trámites (Kanban): tablero con datos consolidados desde API

- **API:** `GET /api/v1/documentos/tablon-tramites` agrupa cargas por las cuatro columnas + totales borrador/rechazado (`DocumentosService.findTablonTramites`), misma visibilidad que `GET /documentos` .
- **Listados:** `pageSize` máximo en `GET /documentos` pasa a **200** (antes 100) para grandes bandejas cuando se necesite.
- **UI:** `/tramites` consume el tablero en una llamada; tarjetas muestran **tipo documental** + asunto compacto + dependencia; botón actualizar.

2026-05-07 — Vite: mitigación riesgo `allowedHosts` vs LAN (`frontend/vite.config`)

- **`server.allowedHosts`** : política repo documentada sin lista fija en config (valor por defecto Vite permite IPs/LAN + localhost).
- **Túneles:** usar `__VITE_ADDITIONAL_SERVER_ALLOWED_HOSTS` (fusión oficial) según manual Vite — evita repetir errores tipo “sin conexión” con `Host` al acceder por `192.168.*.*` .
- **Refs:** `docs/02-stack-y-convenciones.md` , `.env.example` del frontend.

2026-05-06 — Sincronización de documentación con el estado del código (docs/)

- Actualización transversal del índice (README.md snapshot), roadmap (00), arquitectura/stack (01 , 02 , 03), modelo (04), módulos 12 , 15 , 16 , 17 , 18 , pruebas (19), riesgos/ problemas (20 , 21), listado de brechas (28), manual (27), cierres de etapa 38 / 39 y notas 29 – 37 donde aplica — alineados a revisión documental (**R-28**), reportes (**R-39**), auditoría UI, lockout (**R-9**) y desarrollo estable (tsbuildinfo:clean + start:dev).

2026-05-06 — R-39/R-28: reporte “pendientes de revisión” (ADMIN/ REVISOR)

- **API:** GET /api/v1/reportes/pendientes-revision.{xlsx,pdf} (usa mismas reglas de visibilidad que lectura).
- **Auditoría:** REPORT_EXPORTED con kind=pendientes_revision .
- **Frontend:** botones “Pendientes revisión (Excel/PDF)” en /documentos para rol **REVISOR**.
- **Docs:** 28-listado-lo-que-deberia-tener-el-sistema.md , 12-modulo-documentos.md , 27-manual-usuario-sgd-gadpr-lm.md .

2026-05-06 — R-44 (MVP): notificaciones por correo en revisión documental (best-effort)

- **Backend:** envía correo si SMTP está configurado:
 - envío a revisión → notifica a usuarios **ADMIN/REVISOR** activos;
 - resolución (aprobado/rechazado) → notifica al **creador** (incluye motivo en rechazo).
- **Nota:** sin SMTP, el flujo funciona igual (no bloquea).
- **Docs:** 28-listado-lo-que-deberia-tener-el-sistema.md , 12-modulo-documentos.md .

2026-05-05 — R-28: rechazo con motivo obligatorio y auditoría

- **API:** POST .../resolver-revision acepta motivo requerido si decision: "RECHAZADO" (DTO ResolverRevisionDto ; validación global con trim).
- **Auditoría:** DOC_REVIEW_RESOLVED.meta incluye motivoRechazo en rechazos.
- **Frontend:** diálogo de confirmación antes de rechazar (DocumentoDetallePage).
- **Docs:** 28-listado-lo-que-deberia-tener-el-sistema.md , 12-modulo-documentos.md , 27-manual-usuario-sgd-gadpr-lm.md .

2026-05-10 — R-28 MVP: enviar a revisión y resolver (rol REVISOR)

- **API:** POST /api/v1/documentos/:id/enviar-revision , POST .../resolver-revision + DTO ResolverRevisionDto .

- **Reglas:** envío solo desde **REGISTRADO** (creador o ADMIN); resolución **EN_REVISION** (ADMIN o REVISOR); auditoría `DOC_SUBMITTED_FOR_REVIEW` / `DOC_REVIEW_RESOLVED`.
- **Frontend:** acciones en detalle; aviso a **REVISOR** en listado de documentos.
- **Docs:** 28-listado..., 12-modulo-documentos.md, 06-modulo-usuarios.md, 15-modulo-auditoria.md, 27-manual-usuario-sgd-gadpr-lm.md.

2026-05-09 — R-27 MVP: catálogo y transiciones de estado en documentos

- **Datos:** migración `20260509153000_normalize_documento_estados` (valores huérfanos → `REGISTRADO`).
- **Backend:** `documento-estado.util.ts`; validación en `create / update`; bloqueo de adjuntos si **ARCHIVADO**; `DOC_STATE_CHANGED` en auditoría.
- **Frontend:** `constants/documento-estado.ts`; filtro Estado en listado; estado inicial en alta; select en edición detalle + deshabilitar carga/eliminación de archivos archivados.
- **Docs:** 28-listado-lo-que-deberia-tener-el-sistema.md, 04-modelo-base-de-datos.md, 12-modulo-documentos.md, 15-modulo-auditoria.md, 27-manual-usuario-sgd-gadpr-lm.md.

2026-05-08 — Listado gap 28: auditoría 403 + logout por cuenta en login

- **Datos:** migración `20260508120000_user_login_lockout` (`failed_login_attempts`, `locked_until` en `users`).
- **Backend:** `ForbiddenAuditFilter` (`AUTHZ_FORBIDDEN`); `AuthService.login` con `AUTH_LOCKOUT_*` y auditoría `ACCOUNT_LOCKED` / intentos fallidos en `AUTH_LOGIN_FAIL` (mensaje genérico al cliente).
- **Docs:** 28-listado-lo-que-deberia-tener-el-sistema.md, 04-modelo-base-de-datos.md, 05-modulo-auth.md, 15-modulo-auditoria.md, 18-seguridad-y-hardening.md, 27-manual-usuario-sgd-gadpr-lm.md, `.env.example`.

2026-05-07 — ETAPA 10: cierre formal MVP tesis (documentación y evidencias)

- **Nuevo:** `docs/39-etapa-10-cierre-y-evidencias.md` (hardening: `Helmet`, `ValidationPipe`, `Throttler` global + `@Throttle` `auth`, `ThrottlerAuditFilter`, `GET /auditoria` ADMIN).
- **Actualización:** `00-roadmap-general.md`; `38-etapa-9-cierre-y-evidencias.md`; `18-seguridad-y-hardening.md`; `15-modulo-auditoria.md`; `docs/README.md`; `README.md` raíz; `EJECUTAR.txt`.

2026-05-07 — Listado gap 28: confidencialidad por documento + auditoría en UI + roles extendidos en administración

- **Datos/API:** migración Prisma documento `dependencia_id / nivel_confidencialidad`; filtro anti-IDOR en `documentos` y reportes; JWT con `dependenciaId`.
- **UI:** `/admin/auditoria` (filtros + export Excel/PDF vía reportes); formulario/detalle documento con dependencia y confidencialidad; **Usuarios** : selector de roles `REVISOR / AUDITOR / CONSULTA` además de `ADMIN / USUARIO`.
- **Docs:** `28-listado...`, `04-modelo-base-de-datos.md`, `15-modulo-auditoria.md`, `16-modulo-reportes.md`, `scripts/README-backups-mysql-xampp.md`, `27-manual-usuario-sgd-gadpr-lm.md`.

2026-05-06 — ETAPA 9: cierre formal al 100 % (documentación y evidencias)

- **Nuevo:** `docs/38-etapa-9-cierre-y-evidencias.md` (GET `/reportes/documentos.{xlsx,pdf}`, ExcelJS/pdfkit, filtros ETAPA 8, límite 5000 filas, guards ADMIN).
- **Actualización:** `00-roadmap-general.md`; `16-modulo-reportes.md`; `docs/README.md`; `README.md` raíz; `EJECUTAR.txt`; `27-manual-usuario-sgd-gadpr-lm.md` (exportación ADMIN).

2026-05-06 — ETAPA 8: cierre formal al 100 % (documentación y evidencias)

- **Nuevo:** `docs/37-etapa-8-cierre-y-evidencias.md` (GET `/documentos` con `q`, filtros catálogo/fechas, adjuntos `archivo*`, `sortBy / sortDir`, `page / pageSize`, UI `DocumentosPage`).
- **Actualización:** `00-roadmap-general.md`; `36-etapa-7-cierre-y-evidencias.md`; `14-modulo-busqueda.md`; `docs/README.md`; `README.md` raíz; `EJECUTAR.txt`.

2026-05-06 — ETAPA 7: cierre formal al 100 % (documentación y evidencias)

- **Nuevo:** `docs/36-etapa-7-cierre-y-evidencias.md` (CRUD adjuntos, `storage/`, versiones, eventos `SUBIDO / DESCARGADO / ELIMINADO`, límite 10MB, UI `/documentos/:id`).
- **Actualización:** `00-roadmap-general.md`; `35-etapa-6-cierre-y-evidencias.md` (nota archivos); `13-modulo-archivos.md` (enlace evidencias); `docs/README.md`; `README.md` raíz; `EJECUTAR.txt`.

2026-05-06 — ETAPA 6: cierre formal al 100 % (documentación y evidencias)

- **Nuevo:** `docs/35-etapa-6-cierre-y-evidencias.md` (`documentos/ API`, `documento_eventos`, `/documentos`, `/documentos/:id`; línea respecto ETAPA 7/archivos).

- **Actualización:** 00-roadmap-general.md ; 34-etapa-5-cierre-y-evidencias.md ; 12-modulo-documentos.md (enlace al 35); docs/README.md ; README.md raíz; EJECUTAR.txt .

2026-05-06 — ETAPA 5: cierre formal al 100 % (documentación y evidencias)

- **Nuevo:** docs/34-etapa-5-cierre-y-evidencias.md (cinco catálogos: API | dependencias | cargos | tipos-documentales | series | subseries , páginas /catalogos/* , mutaciones ADMIN).
- **Actualización:** 00-roadmap-general.md ; 33-etapa-4-cierre-y-evidencias.md (siguiente fase); docs/README.md ; README.md raíz; EJECUTAR.txt .

2026-05-06 — ETAPA 4: cierre formal al 100 % (documentación y evidencias)

- **Nuevo:** docs/33-etapa-4-cierre-y-evidencias.md (MainLayout , ProtectedRoute , RoleRoute , /forbidden , 404 , AppNotifications /axios).
- **Actualización:** 00-roadmap-general.md ; 32-etapa-3-cierre-y-evidencias.md (enlace a 33); docs/README.md ; README.md raíz; EJECUTAR.txt .

2026-05-06 — ETAPA 3: cierre formal al 100 % (documentación y evidencias)

- **Nuevo:** docs/32-etapa-3-cierre-y-evidencias.md (JWT, refresh+rotación, Argon2, JwtAuthGuard / RolesGuard , throttling auth, audit_logs para eventos AUTH, session/restore).
- **Actualización:** docs/00-roadmap-general.md ; docs/05-modulo-auth.md (endpoints session/restore , auditoría central, ASVS logging); docs/31-etapa-2-cierre-y-evidencias.md (siguiente fase); docs/README.md ; README.md raíz; EJECUTAR.txt .

2026-05-06 — ETAPA 2: cierre formal al 100 % (documentación y evidencias)

- **Nuevo:** docs/31-etapa-2-cierre-y-evidencias.md (checklist: schema.prisma , 14 migraciones, DATABASE_URL / XAMPP, Prisma 5.22.x).
- **Actualización:** docs/04-modelo-base-de-datos.md (listado ordenado de migraciones, RBAC+sesión+usuarios institucional, tablas seguridad/consulta §5); 00-roadmap-general.md ; docs/README.md ; README.md raíz; docs/30-etapa-1-cierre-y-evidencias.md (siguiente fase); EJECUTAR.txt .

2026-05-06 — ETAPA 1: cierre formal al 100 % (documentación y evidencias)

- **Nuevo:** docs/30-etapa-1-cierre-y-evidencias.md (checklist: frontend Vite/React/MUI/axios/Router + RHF/Zod; Nest ConfigModule, ValidationPipe, /api/v1, CORS, proxy Vite).
- **Actualización:** 00-roadmap-general.md (bloque *Estado actual*); docs/README.md; README.md raíz; 03-estructura-de-carpetas.md (árbol y nota de módulos Nest).

2026-05-06 — ETAPA 0: cierre formal al 100 % (documentación y evidencias)

- **Objetivo:** cumplir entregables del roadmap fila ETAPA 0 (/docs, .gitignore, storage/, plantillas .env.example, README, deuda registrada).
- **Nuevo:** docs/29-etapa-0-cierre-y-evidencias.md (checklist comprobado + distinción informe inicial archivado).
- **Actualización:** bandera de archivo en etapa-0-auditoria-inicial-y-diagnostico.md; 00-roadmap-general.md (bloque *Estado actual*); docs/20-problemas-detectados.md (P-003/P-004 cerrados en ámbito repositorio; revisión 2026-05-06); índice docs/README.md; 21-riesgos-pendientes.md (fecha actual).
- **README raíz:** enlace a evidencias ETAPA 0.
- **EJECUTAR.txt** : referencia rápida a docs/29-etapa-0-cierre-y-evidencias.md.

2026-04-20 — ETAPA 9: reportes (Excel/PDF)

- **Backend:** GET /api/v1/reportes/documentos.xlsx (ExcelJS) y GET /api/v1/reportes/documentos.pdf (pdfkit).
- **Permisos:** solo ADMIN puede exportar.
- **Frontend:** botones “Exportar Excel / Exportar PDF” en /documentos usando filtros actuales.

2026-04-20 — ETAPA 8: búsqueda y paginación de documentos

- **API:** GET /api/v1/documentos con filtros (q, catálogos, estado, fechas) y paginación (page, pageSize).
- **API (mejora):** ordenamiento (sortBy, sortDir) y búsqueda por adjuntos (archivoNombre, archivoMime, archivoSha256).
- **Frontend:** /documentos con filtros, ordenamiento por columnas (click) y navegación Anterior/Siguiente.

2026-04-20 — ETAPA 7: archivos (upload/download) con trazabilidad

- **Prisma:** modelos DocumentoArchivo + DocumentoArchivoEvento; migración 20260421193000_add_documento_archivos.

- **Prisma (mejora):** versionado en `documento_archivos.version` ; migración `20260421194500_documento_archivos_versionado` .
- **Storage:** guardado físico bajo `storage/` (no público), nombres internos seguros.
- **API:** listado, upload (ADMIN) y descarga (JWT) por documento.
- **API (mejora):** eventos por archivo + borrado lógico (ADMIN) y registro de IP en descargas.
- **Frontend:** sección Archivos en `/documentos/:id` (subir/descargar/historial/eliminar).

2026-04-20 — ETAPA 6 (cierre): historial de documentos + detalle/edición

- **Prisma:** modelo `DocumentoEvento` ; migración `20260421190000_add_documento_eventos` .
- **API:** `GET /api/v1/documentos/:id/eventos` y registro automático de eventos `CREADO/ACTUALIZADO` .
- **Frontend:** ruta `/documentos/:id` (detalle + edición + historial) y navegación desde el listado.

2026-04-21 — ETAPA 6 (inicio): registro documental MVP

- **Prisma:** modelo `Documento` ; migración `20260421180000_add_documentos_mvp` .
- **API:** `DocumentosModule` en `/api/v1/documentos` (JWT; mutaciones solo `ADMIN`).
- **Frontend:** `/documentos` (listado + registrar documento).
- **Seed:** `DOC-0001` (tipo `MEMO` , subserie `ADM-CORR`).

2026-04-21 — ETAPA 5: catálogo Series/Subseries

- **Prisma:** modelos `Serie` y `Subserie` ; migración `20260421170000_add_series_subseries` .
- **API:** `SeriesModule` (`/api/v1/series`) y `SubseriesModule` (`/api/v1/subseries`) con JWT; mutaciones solo `ADMIN` .
- **Frontend:** `/catalogos/series` y `/catalogos/subseries` , menú bajo Catálogos.
- **Seed:** `ADM` y `ADM-CORR` .

2026-04-21 — ETAPA 5: catálogo Tipos documentales

- **Prisma:** modelo `TipoDocumental` ; migración `20260421160000_add_tipos_documentales` .
- **API:** `TiposDocumentalesModule` en `/api/v1/tipos-documentales` (JWT; mutaciones solo `ADMIN`).
- **Frontend:** `/catalogos/tipos-documentales` , menú bajo Catálogos.
- **Seed:** `MEMO` , `OFICIO` .

2026-04-21 — ETAPA 5: catálogo Cargos

- **Prisma:** modelo `Cargo` + FK opcional a `Dependencia` ; migración `20260421140000_add_cargos` .
- **API:** `CargosModule` en `/api/v1/cargos` (mismo patrón JWT / `ADMIN` que dependencias).

- **Util:** `src/common/prisma-util.ts` (`isPrismaCode`) usado por dependencias y cargos.
- **Frontend:** `/catalogos/cargos` , menú bajo Catálogos.
- **Seed:** cargos `DIR-GEN` (con GADPR-LM) y `ASIST` (sin dependencia).

2026-04-21 — ETAPA 5 (inicio): catálogo Dependencias

- **Prisma:** modelo `Dependencia` , migración `20260421120000_add_dependencias` .
- **API:** `DependenciasModule` , `GET/POST/PATCH` bajo `/api/v1/dependencias` (JWT; mutaciones solo `ADMIN`).
- **Seed:** dos dependencias de ejemplo (`GADPR-LM` , `SGD`) tras migración.
- **Frontend:** ruta `/catalogos/dependencias` , entrada de menú **Catálogos** → **Dependencias**.
- Tras pull: `npx prisma migrate deploy` y `npx prisma generate` (O `npm run prisma:generate:clean` en Windows si EPERM).

2026-04-20 — Documentación: comandos Prisma CLI

- Nuevo `docs/24-prisma-comandos-cli.md` (tablas de referencia + scripts `backend/package.json` + nota EPERM Windows); entrada en `docs/README.md` .

2026-04-20 — ETAPA 4: shell UI + rutas protegidas + RBAC en API

- **Frontend:** `MainLayout` (`AppBar`, drawer de navegación, salida de sesión), `ProtectedRoute` (redirección a `/login`), `DashboardPage` (salud API + verificación `GET /admin/ping` para `ADMIN`), `ForbiddenPage` (`/forbidden`), login con redirección si ya hay sesión; eliminada `HomePage` pública en favor del panel autenticado.
- **Frontend (refinamiento):** menú y rutas condicionados por rol (`ADMIN`) + notificaciones globales (API caída / sesión expirada).
- **Backend:** `@Roles()` + `RolesGuard` , `GET /api/v1/admin/ping` (JWT + rol `ADMIN`).
- **Docs:** `00-roadmap-general.md` , `03-estructura-de-carpetas.md` , `07-modulo-roles-permisos.md` .

2026-04-20 — ETAPA 3: auth JWT + refresh HttpOnly + login frontend

- **Migración:** `20260420103000_add_refresh_tokens` — tabla `refresh_tokens` (hash SHA-256 del refresh opaco).
- **Backend:** `AuthModule` (`login` , `refresh` , `logout` , `me`); cookie `HttpOnly` para refresh; `JWT_ACCESS_EXPIRES` , `JWT_REFRESH_DAYS` , `REFRESH_COOKIE_NAME` ; tipos `JwtSignOptions` para `signAsync` ; `JwtStrategy` devuelve usuario con roles para `GET /api/v1/auth/me` .
- **Seed:** `SEED_ADMIN_EMAIL` / `SEED_ADMIN_PASSWORD` en `backend/.env.example` ; `npx prisma db seed` .

- **Frontend:** `AuthProvider`, `useAuth`, token de acceso en memoria, interceptores axios (Bearer + reintento con `/auth/refresh`), ruta `/login`, `HomePage` con sesión y cierre de sesión.
- **Validado:** `npm run build` + `npm run lint` (backend y frontend), `npm test` y `npm run test:e2e` en backend.

2026-04-20 — Script `prisma:generate:clean` (EPERM Windows)

- `backend/scripts/clean-prisma-client.js` + `npm run prisma:generate:clean`: borra `node_modules/.prisma` y ejecuta `prisma generate` para evitar bloqueo del motor en Windows.

2026-04-20 — ETAPA 2: Prisma 5 + MySQL, RBAC inicial

- **ORM:** `prisma` y `@prisma/client` **5.22.0** (evita cambios de configuración de Prisma 7 sobre `datasource url`).
- **Esquema:** `User`, `Role`, `Permission`, `UserRole`, `RolePermission`; tablas en inglés con `@@map` a nombres SQL coherentes.
- **NestJS:** `PrismaModule` global + `PrismaService`; `GET /api/v1/health` incluye `database: 'up' | 'down'` según `SELECT 1` (API puede arrancar sin MySQL).
- **Migración:** `prisma/migrations/20260420001500_init_rbac/migration.sql` — aplicar con `npx prisma migrate dev` desde `backend/` con XAMPP y BD creada.
- **Frontend:** `HomePage` muestra estado de la base de datos según el health.
- **Scripts:** `prisma:generate`, `prisma:migrate`, `prisma:studio` en `backend/package.json`.

2026-04-19 — Script `free:3000` (puerto ocupado)

- `npm run free:3000` en raíz o en `backend/`: libera el puerto 3000 (`npx kill-port`) antes de `start:dev` cuando aparece `EADDRINUSE`.

2026-04-19 — `package.json` en raíz del monorepo

- Scripts de conveniencia: `npm run install:all` (instala `backend` + `frontend`), `npm run start:dev`, `npm run dev`, `build`, `lint`, `test` desde la raíz sin `cd`.
- Motivo: evitar error `ENOENT` al ejecutar `npm` en la raíz sin `package.json`.

2026-04-19 — ETAPA 1: frontend Vite + React 18 y API shell NestJS

- **Frontend:** proyecto en `frontend/` (Vite, React 18, TS, MUI, React Router, axios, RHF y Zod instalados; shell con `HomePage` que llama a `GET /health`, `NotFoundPage`, tema MUI).
- **Backend:** `@nestjs/config`, `class-validator` / `class-transformer`; prefijo global `api/v1`; CORS desde `CORS_ORIGIN`; `ValidationPipe` global; endpoint `GET /api/v1/health`; eliminado `AppService` boilerplate.

- **Pruebas:** `npm run test` y `npm run test:e2e` en backend actualizados; frontend `npm run build` y `npm run lint` OK.
- **Entorno:** `frontend/.env.example` con `VITE_API_URL`. React fijado a **18.x** (stack oficial).
- **Siguiente:** ETAPA 2 — Prisma + MySQL (XAMPP).

2026-04-19 — Toma de control técnico: auditoría, docs 00 – 23 , saneamiento mínimo

- Auditoría de estructura: solo `backend/` (Nest sin Prisma); sin `frontend/`; sin `schema.prisma`.
- Documentación: creados 00 , 05 – 17 , 18 – 21 , 23 , `docs/README.md`; eliminados archivos vacíos/erróneos (17-seguridad duplicado, 21-changelog duplicado); referencias 17 → 18 en 01 y 02 .
- Raíz: `README.md` , `.gitignore` , `storage/.gitkeep` , `backend/.env.example` .
- Código: `void bootstrap()` en `main.ts` para cumplir ESLint (`no-floating-promises`).
- Validado en backend: `npm run build` , `npm run lint` (0 errores), `npm run test` (pass).
- Próximo hito planificado: **ETAPA 1** — scaffolding `frontend/` , ConfigModule NestJS, prefijo `/api/v1` , CORS (sin pantallas de negocio hasta ordenar base).

2026-04-19 — ETAPA 0: auditoría inicial y baseline documental

- Repositorio sin código de aplicación previo; existían borradores parciales en `docs/` con numeración distinta.
- Unificación de documentación bajo esquema 00 – 23 ; referencias cruzadas actualizadas.
- Inicio de **ETAPA 1** (base técnica): scaffolding planificado de `frontend/` (Vite + React + TS) y `backend/` (NestJS + TS), más `storage/` y `.env.example` .

2026-04-19 — Documentación inicial de infraestructura local (histórico)

- Línea base conceptual: XAMPP (MySQL/MariaDB), Prisma, NestJS, Vite; ngrok solo para exposición temporal documentada.

Plantilla — Sesión ngrok (copiar y rellenar)

```
### YYYY-MM-DD – ngrok – [API | Frontend | ambos]
- Comando: `ngrok http PUERTO`
- URL pública: https://...
- Propósito: (demo, callback, prueba móvil, ...)
- Endpoints / alcance: ...
- Cierre: (hora / túnel detenido sí/no)
```

Plantilla — Sesión cloudflared (copiar y rellenar)

YYYY-MM-DD – cloudflared – Frontend (5173)

- Comando: ``cloudflared tunnel --url http://localhost:5173``
- URL pública: `https://...`
- Propósito: (demo, prueba móvil, revisión externa, ...)
- Duración: (inicio-fin)
- Alcance: (solo frontend / rutas específicas)
- Notas seguridad: (CORS, cookies, datos de prueba, etc.)
- Cierre: túnel detenido (sí/no)

23 entorno local xampp ngrok

Entorno local (XAMPP) y ngrok — SGD-GADPR-LM

Objetivo

Documentar el **entorno real de desarrollo** en Windows con XAMPP y el uso **opcional y temporal** de ngrok.

Alcance

MySQL/MariaDB, phpMyAdmin, puertos, variables de entorno y riesgos de túnel HTTPS.

Estado actual

- **MySQL/MariaDB:** esperado en `127.0.0.1:3306` (verificar en panel XAMPP).
- **phpMyAdmin:** `http://localhost/phpmyadmin` (puerto 80 del Apache de XAMPP).
- **Backend:** `http://localhost:3000` (NestJS).
- **Frontend:** `http://localhost:5173` (Vite) cuando exista `frontend/`.

Orden práctico: **mysql (XAMPP)** → **Nest :3000** → **Vite :5173**. Si aparece `http proxy error / ECONNREFUSED 127.0.0.1:3000` en la consola de Vite, el backend no está en marcha.

Decisiones técnicas

1. **Base de datos:** crear manualmente la base (p. ej. `gestion_documental_gadpr_lm`) antes de `prisma migrate`, cotejamiento `utf8mb4`.
2. **DATABASE_URL:** ver `backend/.env.example` y `02-stack-y-convenciones.md`.
3. **ngrok:** solo para demo, prueba en otro dispositivo o revisión puntual; **no** es entorno de producción.

Flujo ngrok (referencia)

```
ngrok http 3000
# o, cuando exista el frontend:
ngrok http 5173
```

Obligatorio al usar ngrok:

1. Anotar en `22-changelog-tecnico.md` : comando, URL pública, propósito, fecha de cierre del túnel.
2. Ajustar **CORS** en NestJS para incluir el origen `https://...ngrok-free.app` (o dominio que entregue ngrok en esa sesión).
3. Si se usan cookies HttpOnly para refresh, validar `SameSite` y compatibilidad cross-site según el escenario.

Flujo cloudflared (referencia)

Exposición temporal alternativa del **frontend** con HTTPS público (útil para pruebas rápidas en móvil o revisión remota).

```
cloudflared tunnel --url http://localhost:5173
```

Obligatorio al usar cloudflared:

1. Anotar en `22-changelog-tecnico.md` : comando, URL pública, propósito, duración y cierre del túnel.
2. Usar **datos de prueba**; evitar exponer información real.
3. Si hay login/refresh con cookies/JWT, revisar compatibilidad de `SameSite/Secure` y CORS del backend.

Manual: `26-cloudflared-tunnel.md` .

Riesgos

- Filtración de endpoints o datos de prueba por URL pública.
- Abuso de túnel abierto: limitar tiempo y usar credenciales fuertes.

Problemas frecuentes

Síntoma	Acción
CORS bloqueado desde URL ngrok	Añadir origen exacto en backend y reiniciar API
Cookie no enviada	Revisar dominio, SameSite, HTTPS
MySQL no conecta	Servicio detenido en XAMPP o puerto distinto en <code>DATABASE_URL</code>

Referencias

- Reglas Cursor: `.cursor/rules/prisma-xampp-mysql.mdc` , `.cursor/rules/ngrok-temporal-documentacion.mdc`
- Seguridad general: `18-seguridad-y-hardening.md`

24 prisma comandos cli

Prisma CLI — comandos de referencia (SGD-GADPR-LM)

Contexto

- **ORM:** Prisma 5.x con **MySQL/MariaDB** (XAMPP).
- **Esquema:** backend/prisma/schema.prisma .
- **Migraciones:** backend/prisma/migrations/ (22 carpetas versionadas al 2026-05-08; inventario en docs/04-modelo-base-de-datos.md).
- Ejecutar los comandos desde la carpeta **backend/** (donde está el schema.prisma), usando:

```
npx prisma <comando>
```

o los scripts npm definidos en backend/package.json (ver sección final).

Comandos esenciales

Comando	Uso
prisma generate	Regenera el cliente Prisma (node_modules/.prisma/client) según schema.prisma . Necesario tras cambiar modelos para que TypeScript y el runtime reflejen el esquema.
prisma migrate dev	Desarrollo: detecta cambios en el esquema, crea un archivo de migración SQL, lo aplica a la BD y suele ejecutar generate . Solicita un nombre descriptivo para la migración.
prisma migrate deploy	Producción / CI / otro equipo: solo aplica migraciones pendientes ya versionadas en prisma/migrations/ . No crea migraciones nuevas.
prisma db seed	Ejecuta el script de seed configurado en package.json → prisma.seed (en este proyecto: prisma/seed.ts). Datos iniciales (roles, usuario admin, etc.).
prisma studio	Abre una interfaz web para inspeccionar y editar filas en las tablas.

Base de datos y esquema

Comando	Uso
<code>prisma db push</code>	Sincroniza el esquema con la BD sin generar archivos de migración. Útil en prototipos; para historial versionado preferir migrate dev .
<code>prisma db pull</code>	Introspección: actualiza <code>schema.prisma</code> a partir de una base de datos ya existente.
<code>prisma migrate reset</code>	Destructivo en desarrollo: recrea/aplica migraciones desde cero y ejecuta seed . Borra datos; usar con cuidado.
<code>prisma migrate resolve</code>	Marca migraciones como aplicadas o revertidas cuando hubo intervención manual en conflictos (casos excepcionales).
<code>prisma migrate diff</code>	Compara dos fuentes (esquema, BD, carpeta de migraciones) y muestra SQL de diferencias sin aplicarlas.

Validación y formato

Comando	Uso
<code>prisma validate</code>	Comprueba que <code>schema.prisma</code> sea sintácticamente válido.
<code>prisma format</code>	Formatea <code>schema.prisma</code> .

Proyecto e información

Comando	Uso
<code>prisma init</code>	Inicializa Prisma en un repo nuevo (<code>schema.prisma</code> , <code>.env</code>). Este proyecto ya está inicializado.
<code>prisma version / prisma -v</code>	Muestra versiones del CLI y del motor.

Flujo habitual en este monorepo

1. Cambias `schema.prisma` → `npx prisma migrate dev` (recomendado) o, solo en pruebas rápidas, `npx prisma db push`.
2. Traes cambios del repositorio con migraciones nuevas → `npx prisma migrate deploy` y `npx prisma generate`.
3. Actualizas datos de seed (p. ej. `SEED_ADMIN_*` en `.env`) → `npx prisma db seed`.
4. Inspeccionas datos → `npx prisma studio`.

Nota (Windows): si `prisma generate` falla con **EPERM** al renombrar el motor, usar en `backend/` :

```
npm run prisma:generate:clean
```

Scripts en `backend/package.json`

Script	Comando real
<code>npm run prisma:generate</code>	<code>prisma generate</code>
<code>npm run prisma:generate:clean</code>	Limpia <code>node_modules/.prisma</code> y ejecuta <code>generate</code>
<code>npm run prisma:migrate</code>	<code>prisma migrate dev</code>
<code>npm run prisma:studio</code>	<code>prisma studio</code>

Referencias

- Documentación oficial: [Prisma CLI reference](#).
- Entorno local (XAMPP, `DATABASE_URL`): `docs/04-modelo-base-de-datos.md` , `docs/23-entorno-local-xampp-ngrok.md` .

25 ui ux diseno sistema institucional

Diseño UI/UX — Sistema web institucional de gestión documental (SGD-GADPR-LM)

Versión: 1.0 (coherencia con implementación revisada: 2026-05-06; detalle funcional en 27, 28, snapshot docs/README.md)

Ámbito: Interfaz y experiencia de usuario alineadas con ISO/IEC 27001:2022, ISO 15489 y OWASP ASVS.

Uso: Referencia para implementación en frontend (MUI + React), pruebas con usuarios y sustento de tesis.

1. Enfoque integral de diseño

Cómo debe verse

- Estética **sobria y corporativa**: fondos claros, rejilla ordenada, sombras suaves, sin exceso de gradientes o estilo “consumer”.
- **Densidad legible** en escritorio: tablas y formularios escaneables; etiquetas claras y agrupación lógica de campos.
- **Patrones repetibles**: misma posición para acciones primarias, mismos iconos para la misma acción en todo el sistema.

Cómo debe sentirse

- **Confianza**: mensajes claros, estados del sistema explícitos (guardado, solo lectura, pendiente).
 - **Control**: ubicación clara (breadcrumbs, título), permisos comprensibles (acción deshabilitada + motivo).
 - **Eficiencia**: atajos para usuarios frecuentes sin perjudicar a usuarios ocasionales.
 - **Seguridad percibida**: sesión visible, confirmaciones en acciones críticas, mensajes de error no reveladores.
-

2. Propuesta visual general

Estilo

Shell tipo aplicación profesional: **barra superior + navegación lateral** (colapsable en vista reducida). Acento de color institucional en CTAs y navegación activa.

Paleta recomendada (tokens de referencia)

Rol	Hex (referencia)	Uso
Primario	#1E3A5F	Botón principal, app bar, foco
Primario hover	#2A5082	Hover
Fondo app	#F5F7FA	Fondo detrás del contenido
Superficie	#FFFFFF	Tarjetas, drawer
Borde	#E2E8F0	Divisores, bordes de card
Texto principal	#0F172A	Títulos y cuerpo
Texto secundario	#475569	Subtítulos, hints
Éxito	#0F766E	Estados positivos
Advertencia	#B45309	Revisión, caducidad próxima
Error	#B91C1C	Fallos, bloqueos
Info	#1D4ED8	Ayuda contextual

Sustituir el primario por **color de marca** si la institución lo define; mantener la **semántica** de éxito/advertencia/error.

Tipografía

- Familia sugerida: **Inter** (o Source Sans 3 / IBM Plex Sans).
- Base **16px**; títulos de página **20–24px**; peso 600–700 en encabezados.
- En tablas con cifras, preferir cifras tabulares si está disponible en CSS.

Iconografía

- Estilo **outline**, tamaños coherentes (24px navegación, 20px acciones).
- Una acción = un icono estable en todo el producto.

Espaciado (escala 4px)

8, 12, 16, 24, 32, 48. Padding horizontal de página en escritorio: **24–32px**.

Jerarquía

1. Título de página + acción primaria a la derecha.
2. Filtros en franja secundaria.
3. Contenido principal (tabla, detalle, asistente).
4. Metadatos / ayuda en lateral o pestañas.

Responsivo (prioridad escritorio)

- **Desktop:** sidebar fijo, tablas amplias, detalle en dos columnas si aplica.
 - **Tablet:** drawer overlay; tablas con scroll horizontal con indicación visual.
 - **Móvil:** flujos por pasos; evitar tablas densas sin alternativa.
-

3. Arquitectura de información

Menú principal (lateral)

1. **Inicio** (dashboard)
2. **Documentos** (listado y registro según permisos)
3. **Catálogos** (solo roles autorizados)
 - Dependencias, Cargos, Tipos documentales, Series, Subseries
4. (*Futuro*) Búsqueda avanzada, Reportes, Auditoría, Configuración — según roadmap del backend

Navegación superior

Logo / nombre del sistema, **usuario** y **cerrar sesión** (o menú de cuenta). Opcional: búsqueda global cuando exista endpoint.

Breadcrumbs

En rutas profundas: Inicio > Documentos > Detalle . Deben reflejar la jerarquía real del dominio documental (series, expedientes) cuando el modelo de datos lo incorpore.

Plantillas de pantalla

- Listado + filtros + tabla.

- Detalle con pestañas (General, Archivos, Historial, Permisos).
 - Formulario / asistente (registro + carga).
 - Reportes: parámetros → vista previa → exportación.
-

4–5. Módulos principales (objetivo, componentes, estados)

Login

- **Objetivo:** autenticación clara y mensajes no enumeradores.
- **Componentes:** marca, campos correo/contraseña, mostrar/ocultar contraseña, enlace recuperación, aviso de uso autorizado breve.
- **Validación:** inline; error de credenciales genérico.
- **Errores red:** mensaje genérico sin detalles técnicos al usuario final.

Recuperación / restablecimiento de contraseña

- **Objetivo:** expectativa clara; **mismo mensaje de éxito** haya o no cuenta (anti enumeración).
- **Estados:** éxito, error de red, token inválido con CTA a nueva solicitud.

Dashboard

- **Objetivo:** situación operativa y accesos rápidos por rol.
- **Componentes:** tarjetas KPI (cuando haya datos), estado de servicios, accesos a “Documentos” y catálogos.
- **Vacío:** mensaje de bienvenida y enlaces a primeros pasos.

Gestión de usuarios y roles (*cuando exista en UI*)

- Tabla + filtros; edición en modal/drawer; **confirmación** en desactivación y cambios sensibles; campo de **motivo** si la auditoría lo exige.

Registro documental y archivos

- Formulario por secciones (identificación, clasificación, vigencias); carga con estados (pendiente, completado, error); **versión** explícita al reemplazar.

Búsqueda avanzada (*cuando exista*)

- Constructor de filtros; resultados tabulares; exportación acotada por permiso.

Visualización de documento

- Visor según tipo; panel de metadatos; historial de versiones; mensaje claro si no hay permiso de descarga.

Auditoría e historial

- Tabla inmutable con quién/qué/cuándo; filtros; sin exponer tokens ni datos personales innecesarios.

Reportes y configuración

- Parámetros explícitos; confirmación en cambios de retención o políticas críticas.

6. Criterios UX

Criterio	Aplicación
Claridad	Lenguaje institucional simple; ayudas contextuales
Rapidez	Filtros persistentes, skeleton loaders, paginación clara
Facilidad	Valores por defecto; asistentes en flujos complejos
Accesibilidad	Contraste AA, foco visible, teclado, ARIA en modales
Menos errores	Confirmación en destructivos; validación antes de enviar
Consistencia	Orden único de botones (definido en design system)
Confianza	Trazabilidad visible en acciones sensibles

7. Cumplimiento normativo vía UI/UX

ISO/IEC 27001:2022

- Control de acceso **visible** (rol, solo lectura).
- **Sesión** gestionada con avisos cuando se implemente caducidad.
- **Alertas** sin datos sensibles en notificaciones.
- **Auditoría** legible para roles autorizados.

ISO 15489

- **Clasificación** visible en cabeceras (serie/subserie/tipo).

- **Versiones e historial** accesibles según permiso.
- **Búsqueda** alineada a metadatos de gestión documental.

OWASP ASVS

- Formularios con validación; errores **genéricos** al usuario.
- Acciones sensibles con confirmación o reautenticación según nivel objetivo.
- No exponer stack traces ni rutas internas en la UI.

8. Recomendaciones UX de seguridad

1. Login con mensaje único ante fallo de credenciales.
2. Recuperación de contraseña sin revelar existencia de cuenta.
3. Modales de confirmación para borrado y cambios de permisos amplios.
4. Indicador de sesión (y aviso previo a expiración cuando se implemente).
5. Feedback en operaciones largas ("Validando permisos...") sin filtrar internals.
6. Descargas: acuse cuando la política lo requiera.

9. Wireframes textuales

Login

```
| [Marca] Sistema de gestión documental |
|
| |
| | Iniciar sesión |
| | Correo [ ] |
| | Contraseña [ ] |
| | [ Ingresar ] ¿Olvidó contraseña? |
| | Aviso uso autorizado (breve) |
| |
| |
```

Shell aplicación

```
| TopBar: [Menú] Título sistema      [Usuario ▼] _____|
| |Nav_____ | Breadcrumb: Inicio > Documentos _____|
| | Inicio | | Título página          [Acción principal]    |
```

	Docs			Filtros / contenido	_____		
	Cat.*			Tabla o detalle			

10. Accesibilidad y UCD

- Contraste mínimo **WCAG 2.1 AA** para texto y componentes UI.
- Orden de foco lógico; modales con **trap** y cierre con Esc.
- Errores de formulario asociados a campos (`aria-describedby`).
- No usar solo color para transmitir estado (incluir icono o texto).
- Validación con usuarios por **rol** (administrativo, consulta, archivo).

11. Design system (componentes)

Botones

- **Primario:** relleno color primario; **Secundario:** borde; **Texto:** acciones terciarias; **Peligro:** destructivos.
- `textTransform: none` para legibilidad en español.

Inputs

- Label encima; altura mínima táctil ~40px; estados: default, focus, error, disabled, read-only.

Tablas

- Cabecera clara; paginación; acciones en columna final o menú contextual.

Modales

- Título + cuerpo + pie; foco inicial en acción segura o primer campo.

Badges

- Estados documentales: borrador, registrado, vigente, en revisión (colores semánticos + texto).

Tarjetas

- Sombra ligera; título + métrica o descripción + CTA opcional.

Alertas

- Info / éxito / advertencia / error con icono y, si aplica, acción (p. ej. “Reintentar”).
-

12. Implementación en el repositorio

- **Tema MUI:** `frontend/src/theme/appTheme.ts` (palette, tipografía Inter, shape).
- **Layout autenticación:** `frontend/src/layouts/AuthLayout.tsx` (card centrada, fondo institucional).
- **Shell logueado:** `frontend/src/layouts/MainLayout.tsx` (drawer responsivo, breadcrumbs, iconos de navegación).
- **Utilidad de migas:** `frontend/src/nav/breadcrumbs.ts` (opción `documentDetailLabel` para detalle de documento).
- **Contexto de miga dinámica:** `breadcrumbDetailContext.ts`, `BreadcrumbDetailProvider.tsx` y `useBreadcrumbDetail.ts` (`useRegisterBreadcrumbDetail` en detalle de documento).
- **Cabecera de página:** `frontend/src/components/PageHeader.tsx` (título, descripción, acciones, enlace “volver”).
- **Estados vacíos:** `frontend/src/components/EmptyState.tsx` (tablas `dense`, paneles con icono).
- **403 / 404:** mismas tarjeta y fondo que login vía `AuthLayout.tsx`.

Las pantallas de módulos futuros deben **reutilizar** el shell, el tema y los patrones de esta guía para mantener coherencia y trazabilidad de seguridad en la experiencia.

Referencias cruzadas

- [18-seguridad-y-hardening.md](#)
- [19-mapeo-iso27001-iso15489-owasp-asvs.md](#)
- [05-modulo-auth.md](#)

26 cloudflared tunnel

Cloudflared Tunnel (Quick Tunnel) — Frontend Vite (5173)

Objetivo

Dejar un **manual operativo** para exponer de forma **temporal** el frontend local (Vite, `http://localhost:5173`) usando Cloudflare Tunnel vía `cloudflared`, incluyendo:

- instalación en Windows,
- ejecución del túnel,
- verificación y troubleshooting,
- **registro de sesión** (trazabilidad) y riesgos.

Este uso es **solo para demo / pruebas**. No se considera despliegue ni entorno de producción.

Alcance

- Windows 10/11 (PowerShell).
- Frontend Vite en puerto `5173`.
- Comando principal: `cloudflared tunnel --url http://localhost:5173`.

Requisitos previos

1. El frontend debe estar levantado y accesible localmente (y, para flujos reales de login/datos, el **backend Nest en :3000** + **MySQL** según `docs/23-entorno-local-xampp-ngrok.md`).

```
http://localhost:5173
```

1. Tener permisos para instalar software en el equipo (o usar método portable).

Instalación de `cloudflared` (Windows)

Opción A — `winget` (recomendada)

En PowerShell:

```
winget install --id Cloudflare.cloudflared -e
```

Cerrar y reabrir la terminal. Validar:

```
cloudflared --version
```

Opción B — Chocolatey

```
choco install cloudflared -y  
cloudflared --version
```

Opción C — Scoop

```
scoop install cloudflared  
cloudflared --version
```

Opción D — Manual (portable)

1. Descargar el binario de Windows (`cloudflared-windows-amd64.exe`) desde releases oficiales de Cloudflare.
2. Renombrar a `cloudflared.exe` .
3. Mover a una ruta estable, por ejemplo: `C:\Tools\cloudflared\cloudflared.exe` .
4. Agregar `C:\Tools\cloudflared\` al **PATH** del sistema/usuario.
5. Cerrar y reabrir PowerShell y validar con:

```
cloudflared --version
```

Uso: levantar túnel hacia Vite (5173)

Con Vite ejecutándose en local:

```
cloudflared tunnel --url http://localhost:5173
```

Resultado esperado

- La consola mostrará una **URL pública HTTPS** generada por Cloudflare.
- Esa URL debe abrir el frontend desde otro dispositivo/red (mientras el túnel esté activo).

Verificación rápida

1. En la máquina local, abrir `http://localhost:5173` y confirmar que carga.
2. Ejecutar el túnel y copiar la URL pública.
3. Abrir la URL pública en:
 - un navegador en modo incógnito, o
 - un teléfono (en otra red si aplica).

Troubleshooting (errores comunes)

```
cloudflared: The term 'cloudflared' is not recognized...
```

Causa probable

- `cloudflared` no está instalado o no está en el `PATH`.

Acciones

- Instalar con `winget/choco/scoop`, cerrar y reabrir la terminal.
- Validar con `cloudflared --version`.
- Si es instalación manual, confirmar que el `PATH` contiene la carpeta del `.exe`.

La URL pública abre, pero no carga recursos / pantalla en blanco

Causas probables

- Vite no está levantado o está en otro puerto.
- La app requiere variables (`VITE_*`) no configuradas en el entorno.

Acciones

- Confirmar `http://localhost:5173` en local.
- Revisar consola del navegador (Network/Console) para errores de runtime.

Problemas de autenticación (cookies/JWT) al usar dominio público

Causas probables

- Cookies con `SameSite / Secure` incompatibles con el escenario.
- CORS / configuración de API no permite el origen del túnel.

Acciones

- Revisar configuración del backend: CORS con el origen exacto de la URL pública.
- Revisar flags de cookies (`HttpOnly` , `SameSite` , `Secure`) y escenarios cross-site.
- Si se usa refresh en cookie, verificar que el flujo sigue funcionando bajo HTTPS público.

Seguridad y riesgos (resumen)

- **Exposición pública:** cualquier persona con la URL podría intentar acceder. Minimizar tiempo activo.
- **Datos:** usar datos de prueba; evitar exponer PII o información real.
- **Auth:** revisar CORS/cookies; evitar tokens en URLs y evitar logging con secretos.
- **Cierre:** detener el comando al terminar y registrar el cierre.

Registro obligatorio (para trazabilidad)

Cada vez que se use un túnel, registrar una entrada en `docs/22-changelog-tecnico.md` y, si afecta seguridad/cookies/CORS, referenciar `docs/18-seguridad-y-hardening.md` .

Plantilla — Sesión `cloudflared` (copiar y rellenar)

```
### YYYY-MM-DD – cloudflared – Frontend (5173)
- Comando: `cloudflared tunnel --url http://localhost:5173`
- URL pública: https://...
- Propósito: (demo, prueba móvil, revisión externa, etc.)
- Duración: (inicio-fin)
- Alcance: (solo frontend / rutas específicas)
- Notas seguridad: (CORS, cookies, datos de prueba, etc.)
- Cierre: túnel detenido (sí/no)
```

Referencias internas

- `18-seguridad-y-hardening.md`

- `22-changelog-tecnico.md`
- `23-entorno-local-xampp-ngrok.md` (entorno local y exposición temporal)

27 manual usuario sgd gadpr lm

Manual de Usuario — SGD-GADPR-LM (uso de principio a fin)

Versión del manual: 2026-05-08 (snapshot docs/README.md ; carga diferida + precarga tras login + LCP auditado para ADMIN)

Audiencia: personal institucional (usuario final), administradores (**ADMIN**), revisores (**REVISOR**) y evaluadores (pruebas).

0. Propósito del manual

Este manual describe **paso a paso y con detalle** cómo usar el sistema SGD-GADPR-LM desde el primer ingreso hasta el registro, consulta, adjuntos y trazabilidad de documentos.

Importante: varias acciones están restringidas por rol. Los flujos administrativos y de catálogo recaen sobre **ADMIN**. La **revisión/aprobación** documental (**R-28**) la ejecutan **ADMIN** o **REVISOR**.

1. Requisitos previos (antes de usar)

1.1 Acceso

- Tener un usuario activo en el sistema.
- Tener credenciales válidas (correo y contraseña).

1.2 Navegador recomendado

- Chrome / Edge actualizado (modo normal, sin extensiones que bloqueen cookies).

1.3 URL del sistema

- En local (frontend Vite): `http://localhost:5173/` (si el puerto cambia, revisa la consola donde se levantó el frontend).
- El backend debe estar disponible en `http://localhost:3000/api/v1`

1.4 Carga inicial por módulo

- La **primera vez** que abres una ruta después de iniciar sesión puede mostrarse brevemente **Cargando pantalla** mientras el navegador descarga el bloque correspondiente del frontend. Las visitas siguientes al mismo módulo suelen ser más rápidas si el caché conserva esos archivos.

1.5 Precarga en segundo plano y métrica LCP (panel principal)

- Con sesión iniciada el sistema puede, cuando el navegador está menos ocupado, **precargar** en segundo plano el código y datos más usados (panel `/`, lista `/documentos` por defecto, `/perfil`). Es normal observar peticiones paralelas sin haber pulsado esos menús todavía; no cambia permisos ni datos visibles hasta que abras cada pantalla.
- Al cargar el **panel principal**, el cliente puede registrar una métrica de rendimiento (**LCP**) en auditoría (`CLIENT_WEB_VITAL_LCP`), visible para **ADMIN** en **Auditoría** junto al resto de acciones del sistema.

2. Ingreso al sistema (Inicio de sesión)

2.1 Abrir la pantalla de login

1. Abre el navegador.
2. Ingresa a `http://localhost:5173/login` (o al puerto que indique el frontend).

2.2 Iniciar sesión

1. En **Correo o usuario**, escribe tu correo institucional.
2. En **Contraseña**, escribe tu contraseña.
3. (Opcional) Marca **Mantener sesión en este equipo** si estás en un equipo confiable.
4. Presiona **Ingresar al sistema**.

Resultado esperado

- El sistema te redirige al **Panel principal**.
- En la barra superior verás tu correo y la indicación de **sesión activa**.

Posibles fallos

- **“Credenciales inválidas...”**: correo/contraseña incorrectos, usuario inactivo o **cuenta temporalmente bloqueada** tras repetidos errores de contraseña (el mismo mensaje se usa a propósito; el administrador puede revisar `AUTH_LOGIN_FAIL` / `ACCOUNT_LOCKED` en Auditoría). Tras restablecer contraseña el bloqueo se limpia.

- **Límite de intentos por red:** demasiadas peticiones en poco tiempo (mensaje tipo “Demasiados intentos”); espera unos minutos.
- **“No se pudo conectar con la API...”:** suele indicar backend apagado, proxy incompleto o **URL incorrecta**. Si la interfaz está en `http://IP-LAN:5173`, mantén `VITE_API_URL` **sin definir** (recomendado) para usar el mismo origen y el proxy de Vite hacia `127.0.0.1:3000`; no configures `localhost` en `VITE_API_URL` cuando entres desde **otro equipo** (ese `localhost` sería el equipo del navegador, no el servidor). Si el mensaje aparecía aun cargando bien la página en LAN, tras actualización del cliente esa alerta ya **no debe mostrarse** por cancelaciones internas benignas de peticiones.

Siguiente paso

- Verifica tu rol y navega a Documentos.

2.3 Perfil de usuario (datos y actividad)

1. Tras iniciar sesión, en la barra superior presiona tu **correo** para abrir el menú de cuenta.
2. Elige **Mi perfil**. También puedes abrir directamente la ruta `/perfil`.
3. Revisa **Información personal** (correo, rol principal, área/dependencia si está asignada, estado y **último ingreso** preferentemente desde el campo `ultimoLoginAt`, con respaldo por último `AUTH_LOGIN_OK` en auditoría cuando el campo sea nulo).
4. En **Actividad reciente** verás las últimas acciones auditadas asociadas a tu cuenta (por ejemplo inicio de sesión, cargas o consultas documentales cuando existan registros).
5. Para iniciar el **cambio de contraseña** vía recuperación, presiona **Cambiar contraseña** (lleva a `/recuperar`; es el mismo flujo que “olvidé mi contraseña”).
6. Para salir, usa **Cerrar sesión de forma segura** o la opción **Cerrar sesión** del mismo menú superior.

Resultado esperado

- Se muestran tus datos de cuenta y una línea de tiempo breve de actividad (puede estar vacía si aún no hay eventos auditados recientes).
- **Último ingreso** muestra fecha si hay `ultimoLoginAt` o, en su defecto, el último `AUTH_LOGIN_OK` en auditoría; si ninguno existe aún para tu cuenta se verá como no disponible.

Posibles fallos

- Mensaje de error al cargar el perfil: el backend no está disponible o hubo un fallo puntual; revisa la consola de red y que la API responda en `/api/v1/auth/profile`.
- Actividad incompleta frente a todo lo que hizo en pantalla: solo se listan acciones que generan filas en `audit_logs` y se filtran eventos de sistema ruidosos (p. ej. renovación de sesión).

Siguiente paso

- Si necesitas nueva contraseña, completa el flujo en § 3 (recuperación).
-

3. Recuperación de credenciales (si olvidaste tu contraseña)

3.1 Solicitar restablecimiento

1. En `/login`, presiona **¿Olvidaste tu contraseña?**
2. En la pantalla **Recuperación de credenciales**, ingresa tu correo.
3. Presiona **Solicitar restablecimiento**.

Resultado esperado

- El sistema muestra un mensaje genérico: “Si el correo está registrado...”.

3.2 Restablecer contraseña

Cuando el administrador tiene configurado el **servidor SMTP** en el backend, suele llegar un **correo** con un enlace tipo

`/restablecer?token=...`. Al hacer clic, el navegador abre esa pantalla y el campo **token** puede venir ya relleno.

Sin correo institucional (entorno de desarrollo típico), el sistema puede mostrar después de solicitar recuperación un **token de desarrollo** en pantalla únicamente para pruebas; en producción con SMTP eso **no debe aparecer**.

1. Si no usaste el enlace del correo, abre la pantalla `/restablecer` desde el mismo sitio donde usas la aplicación.
2. Ingresa el **token** (si la URL ya lo incluye, verifica que el campo coincida) y la **nueva contraseña** (mínimo 8 caracteres).
3. Presiona **Restablecer**.

Resultado esperado

- Mensaje de éxito y posibilidad de volver a iniciar sesión.
-

4. Panel principal (Inicio)

4.1 Qué verás

- **Indicadores:** totales **en tiempo real** desde la API (`GET /dashboard/summary` para todos los roles). La verificación `GET /health` y su sondeo automático solo se ejecutan cuando el usuario es `ADMIN` (coincide con las secciones de salud y alertas que solo ellos ven). **Documentos** y **Pendientes** ven todos los roles; tarjetas **Usuarios** y **Alertas** solo `ADMIN`; hay **actualización automática** y etiqueta «**Actualizado: ...**».
- Use **Actualizar ahora** en la cabecera del panel si quiere traer datos de nuevo al instante (sin esperar al intervalo automático); el botón se desactiva brevemente mientras termina la petición.
- **Alertas (tarjeta roja, solo `ADMIN`):** el número es la cantidad de **señales activas** que el sistema detecta; debajo de la tarjeta se listan en texto claro. Pueden combinarse, por ejemplo: documentos en **En revisión**, accesos **403** recientes en auditoría, **intentos fallidos de login** (30 días), **falta de registro de respaldo verificado** (hasta que se use Respaldos → registrar), o problemas de **salud del API/base de datos** detectados en el navegador.
- **Cumplimiento de seguridad (solo `ADMIN`):** barras calculadas con métricas de los últimos 30 días (no son valores ficticios), más el bloque de **último respaldo verificado** y última línea auditada en el mismo panel.
- **Estado del servicio (solo `ADMIN`):** confirmación de API y base de datos; el enlace rápido **Ir a documentos** aparece dentro de ese bloque. Los usuarios sin rol administrador pueden ir a documentos desde el menú o desde **Ver documentos** en la tabla de expedientes recientes.
- **Comprobación de rol administrador** (si aplica): indicador de acceso ADMIN.

4.2 Menú lateral (navegación)

- Inicio
 - Documentos
 - Administración → **Usuarios y roles** (solo `ADMIN`)
 - **Catálogos** (solo `ADMIN`):
 - Dependencias
 - Cargos
 - Tipos documentales
 - Series
 - Subseries
-

5. Administración (solo ADMIN)

5.1 Gestión de usuarios (crear/editar/desactivar/reset)

La pantalla **Administración de identidades** muestra, en orden vertical y a **ancho completo**, primero el **directorio de usuarios institucionales** y, más abajo, la **matriz RBAC de referencia** (así la tabla no queda tan estrecha como en diseños de dos columnas). Los detalles técnicos (endpoints API, último ingreso `ultimoLoginAt`, alcance efectivo `@Roles`) y las referencias ISO/ASVS están en el apartado **Evidencia técnica y normativa (API, último ingreso)** (panel colapsable bajo la cabecera).

La tabla reproduce `GET /usuarios` y la **matriz de referencia** `GET /usuarios/matriz-acceso-referencia` (lectura útil por rol vs módulos; no persiste cambios).

La **capacidad técnica** del API combina rol JWT (`ADMIN`, `USUARIO`, etc.) + **permisos en base de datos**: por **rol** (`role_permissions`) y **opcionalmente por persona** (`user_permissions`, llamados «permisos directos» en la pantalla), aplicados por el servidor (`@Permissions`). La sección **Matriz rol ↔ permiso (base de datos)** permite **marcar/desmarcar códigos** por cada rol institucional y **Guardar** (API `PUT /rbac/roles/:codigo/permissions`; queda evidencia `ROLE_PERMISSIONS_UPDATED` en auditoría para administradores).

Los usuarios se administran con **roles** y, si hace falta, con **permisos directos** en **Crear usuario / Editar usuario** (campo **Permisos directos (solo esta cuenta)**): se **suman** a lo que otorguen los roles (p. ej. asignar solo `DOC_FILES_UPLOAD` sin crear un rol nuevo). Quedan registrados cambios fuertes en auditoría (`USER_DIRECT_PERMISSIONS_UPDATED`). Quien cambie de combinación debe **volver a iniciar sesión** (o esperar renovación del token) para ver el efecto completo.

Los roles siguen siendo obligatorios (al menos uno): si un rol no tiene permisos en BD, la API puede responder `403` aun con el mismo código de rol en la cuenta.

1. En el menú lateral, entra a **Administración** → **Usuarios y roles**.
2. En el directorio, revisa chips **Activos / Total** y la tabla de usuario (nombre preferente o correo), **cargo y dependencia** cuando están en el catálogo, rol(es), estado (**Activo / Suspendido**) y **Último ingreso** según `ultimoLoginAt` (tras login **exitoso con credenciales**; no sólo renovación silenciosa). Cuentas antiguas pueden mostrar «sin acceso» hasta el próximo login tras el despliegue del campo. Bajo los botones hay enlaces rápidos: **Ver matriz RBAC** (baja a la matriz) y, en la matriz, **Volver al directorio de usuarios**.
3. Para crear un usuario:
 - Presiona **Crear usuario**
 - Completa **Correo**, **Contraseña temporal** (respaldo hasta que el usuario defina la suya), (opcional) **Nombres/Apellidos**, (opcional) **Dependencia/Cargo**, **Roles** (lista ejemplar: `ADMIN`, `USUARIO`, `EDITOR_DOC`, `REVISOR`, `AUDITOR`, `CONSULTA`) y, opcionalmente,

Permisos directos (lista de códigos del catálogo; vacío = solo hereda del rol). El **alcance en API** es la **unión** de permisos por **todos los roles** del usuario + **permisos directos**. El rol **EDITOR_DOC** (cuando existe en el seed o migración) complementa a **USUARIO** con edición de metadatos y gestión de adjuntos según **role_permissions**.

- Deja marcada la opción recomendada **“Enviar al correo un enlace...”** para que llegue un mensaje con el enlace a **definir contraseña** (página de restablecer). Si no marcas la casilla, el usuario solo puede entrar con la contraseña temporal.
- Presiona **Crear**
- Si aparece un aviso de que no se envió el correo, el administrador debe revisar la configuración SMTP del servidor o repetir más tarde el flujo de recuperación de contraseña para ese usuario.

4. Para editar:

- En la fila del usuario, pulsa el botón **⋮ / Acciones** (icono junto al final de la fila).
- Elige **Editar usuario** (roles, dependencia, cargo, permisos directos).
- Ajusta y presiona **Guardar** (si cambió permisos directos, revise auditoría y pida al usuario que cierre sesión si hace falta).

5. Para activar/desactivar:

- En **Acciones**, elija **Activar cuenta** o **Desactivar cuenta**

6. Para restablecer contraseña:

- En **Acciones**, elija **Restablecer contraseña**
- Ingresa nueva contraseña y confirma

7. Permisos por rol (BD) (matriz efectiva ante el API):

- Usa **Permisos por rol (BD)** o desplázate a **Matriz rol ↔ permiso (base de datos)**.
- En **Rol a editar**, elige el código (**USUARIO**, **REVISOR**, etc.).
- Marca o quita los códigos de permiso necesarios (**Guardar permisos del rol**).
- Tras un cambio, los usuarios con ese rol heredan el nuevo conjunto; si ya tenían sesión abierta puede bastar esperar caducidad/refresh según configuración JWT o volver a iniciar sesión.

Resultado esperado

- El listado de usuarios refleja altas/edición; la matriz de referencia muestra vista comparativa por rol.
- Si guardaste la matriz en BD: mensaje de éxito y registro **ROLE_PERMISSIONS_UPDATED** en **Auditoría** (filtro opcional por acción).

Fallos a revisar

- **403**: su cuenta no tiene rol **ADMIN** o el rol **ADMIN** **perdió permisos** en BD (recover: DB o ejecutar **npm prisma db seed** en **backend/** con precaución en producción).
- Catálogo de permisos vacío en pantalla: no se ejecutó seed RBAC después de migrar código.

- Error de validación: correo duplicado o contraseña corta.
-

6. Catálogos (solo ADMIN)

Los catálogos son requisitos para registrar documentos correctamente.

6.1 Dependencias

1. Menú → **Catálogos** → **Dependencias**
2. Crea/edita una dependencia (código único y nombre).

6.2 Cargos

1. Menú → **Catálogos** → **Cargos**
2. Crea/edita un cargo y (opcionalmente) asígnalo a una dependencia.

6.3 Tipos documentales

1. Menú → **Catálogos** → **Tipos documentales**
2. Crea/edita tipos (ej. MEMO, OFICIO).

6.4 Series y Subseries

1. Menú → **Catálogos** → **Series**
2. Crea series.
3. Menú → **Catálogos** → **Subseries**
4. Crea subseries y vincúlalas a una serie.

Resultado esperado

- Los catálogos quedan disponibles para el registro documental.
-

7. Registro documental (Documentos)

Confidencialidad y dependencia: cada documento tiene **nivel** (Público, Interno, Reservado, Confidencial) y **dependencia propietaria**. Quien no es **ADMIN** solo ve lo que corresponda a su dependencia (y niveles permitidos). **Confidencial** queda reservado a **ADMIN**.

7.1 Abrir el módulo Documentos

1. Menú → **Documentos**.

7.2 Buscar documentos (simple y avanzada)

Los filtros se organizan en **tarjeta** y se **adaptan al ancho de pantalla** (en móviles los campos se apilan; en escritorio pueden mostrarse en varias columnas). La **tabla** puede mostrar **scroll horizontal** en pantallas estrechas: desplázate lateralmente para ver todas las columnas.

En la barra de filtros puedes usar:

- Texto libre (): coincide con **código**, **asunto**, **descripción**, **dependencia** del documento (nombre o código), **usuario que registró** (correo, nombres o apellidos), **tipo documental** y **clasificación** (subserie o serie).
- **Estado** (lista desplegable con catálogo formal: Borrador, Registrado, En revisión, etc.; «(Todos)» para no filtrar)
- Tipo documental
- Serie/Subserie
- Rango de fechas
- Filtros por adjuntos (nombre, MIME, sha256)

Acción

1. Ajusta filtros.
2. Presiona **Aplicar filtros**.

Resultado esperado

- Lista **paginada** con registros **reales** del servidor (según tus permisos y filtros). Abajo del listado verás **número de página**, el **intervalo de registros** visibles respecto del total y botones **Anterior** / **Siguiente**.
- En la tabla, **Clasificación** muestra serie y subserie; **Responsable** prioriza la **dependencia aplicada al documento** y, si no hay, muestra nombre o correo de quien lo registró (pasa el ratón sobre la celda para ver detalle cuando aplique).

7.2.1 Trámites — tablero de flujo (Kanban)

1. Menú → **Trámites** (ruta `/tramites`).
2. Revisa cuatro columnas: **Registrado**, **En revisión**, **Aprobado** y **Archivado** — los ítems son **documentos vivos del servidor**, filtrados por tu **permiso de lectura**, no datos de demostración.
3. Cada tarjeta muestra **código**, **tipo documental** (nombre del catálogo), línea compacta del **asunto** y **dependencia aplicada al expediente** (o aviso si no hay dependencia).

Interactividad

- **Actualizar** (icono de recarga junto al título) vuelve a pedir todo el tablero al servidor en una sola operación; la cabecera indica fecha/hora de la última carga donde aplique.
- Pulsa una tarjeta (o también el contenido dentro de ella): abre el **detalle** del documento. Las **transiciones de estado** siguen aplicándose solo desde el detalle según tus permisos; el tablero es **solo lectura** (no hay arrastrar y soltar).
- Cada expediente aparece solo en una columna: corresponde a su **único estado actual** en la base de datos (no pueden repetirse el mismo ID en dos columnas).
- Si hay muchos registros por columna (más del tope cargado por el servidor, hoy hasta ciento cincuenta por columna en esta vista), el tablero avisa revisar la **bandeja Documentos** filtrando por estado.
- Estados **Borrador** y **Rechazado** no están en las cuatro columnas principales; si existen registros visibles para tu usuario, la pantalla puede mostrar un aviso con enlaces a la bandeja.

Resultado esperado

- Visión rápida del pipeline documental coherente con tus permisos de visibilidad y con los mismos registros que la bandeja de documentos.

7.2.2 Clasificación — cuadro documental (solo lectura)

1. Menú → **Clasificación** (ruta `/clasificacion`).
2. **Actualizar** (icono de recarga junto al título): vuelve a cargar catálogo y agregados del servidor (`GET .../clasificacion-agregados` junto con series/subseries activas).
3. **Izquierda — Estructura documental**: árbol con el fondo institucional y, debajo, cada **serie** y sus **subseries** (**solo catálogo activo** — mismos datos que en **Catálogos**).
4. Pulsa una **serie** o **subserie**. La **Ficha de clasificación** muestra **código** y **nombre** del catálogo; **descripción** si existe; además (**datos derivados de expedientes**):
 - **Expedientes visibles**: cuántos documentos vigentes (**activo**) coinciden con tu **misma visibilidad** que en la bandeja **Documentos**, agregados a la serie o subserie elegida (por subserie asignada al expediente; en serie se suman todas las subseries bajo ese padre que aplica al recuento del servidor).
 - **Área responsable predominante**: dependencia más frecuente entre esos expedientes visibles en esa clasificación; si **cero** expedientes encajan, texto claro tipo “sin expedientes...”; puede no coincidir con un campo “único” si tu organización distribuye cargas entre varias dependencias.
 - **Nivel de acceso predominante**: confidencialidad más frecuente entre expedientes visibles (p. ej. interno/reservado), en etiqueta legible según valores del modelo.
 - **Conservación (plazo / destino)** el sistema declara honestamente si **no** hay campos de retención o disposición final en base de datos: no muestra años inventados; cuando el proyecto modele esa política en catálogo, la pantalla podrá enlazarlos.

5. **Tabla de retención** (abajo derecha): una fila por **serie activa** con código y nombre del catálogo; columna **Expedientes visibles** (**recuento real** igual criterio que arriba). Columnas **Retención** y **Destino final** muestran **marcador de pendiente**, no valores ficticios, hasta que existan datos modelados.

ADMIN: enlaces a mantenimiento **Series / Subseries**. Otros roles: solo lectura.

Resultado esperado

- Vista alineada al catálogo real y métricas de expedientes con las mismas reglas de privacidad/visibilidad que el resto del módulo documental.

Posibles fallos

- Lista vacía: no hay series/subseries activas (un **ADMIN** las crea en **Catálogos**).
- Ficha con expedientes **0**: normal si no hay documentos clasificados bajo ese nodo para tu cuenta o filtros implícitos de visibilidad; la bandeja **Documentos** debe reflejar el mismo comportamiento por rol.

7.3 Exportar a Excel o PDF (solo ADMIN)

Los reportes usan los **mismos filtros** aplicados arriba (no exportan solo la página visible: el servidor arma el conjunto filtrado completo dentro de un tope configurado).

Acción

1. Ajusta filtros y pulsa **Aplicar filtros** (recomendado para acotar el resultado).
2. En el bloque de filtros, pulsa **Excel** o **PDF**.
3. Acepta la descarga en el navegador.

Resultado esperado

- Se obtiene un archivo `.xlsx` o `.pdf` con el listado filtrado.
- Rol distinto de **ADMIN**: la API responderá sin autorización si se intentara exportar desde herramientas externas.

Posibles fallos

- Sesión caducada: vuelve a iniciar sesión.
- Mensaje tipo “No se pudo exportar”: revisa que el backend esté en marcha y que tu usuario sea **ADMIN**.
- Lista muy grande: el servidor puede **limitar la cantidad de filas** exportadas por rendimiento.

7.3.1 Exportar “Pendientes de revisión” (REVISOR o ADMIN)

Este reporte descarga exclusivamente documentos en estado **En revisión** (cola operativa) y se expone también a rol **REVISOR**.

Acción

1. En **Documentos**, en el bloque de filtros, pulsa **Pendientes revisión (Excel)** o **Pendientes revisión (PDF)**.
2. Acepta la descarga en el navegador.

Resultado esperado

- Se obtiene un archivo `.xlsx` o `.pdf` con la lista de documentos **En revisión**.

Posibles fallos

- No aparecen botones: tu usuario no tiene rol **REVISOR** ni **ADMIN**.
- “No se pudo exportar...”: backend apagado o sesión caducada.

7.4 Crear documento (solo ADMIN)

1. Menú → **Nuevo documento** (ruta `/documentos/nuevo`) o, desde **Documentos**, botón **Nuevo documento** si está visible.
2. Los desplegables (**tipo**, **serie**, **clasificación**, **dependencia**) muestran el **catálogo real del servidor**. El sistema puede **prellenar su dependencia** si su usuario tiene dependencia en perfil y ésta existe en catálogo. Si hay un solo tipo documental o una sola serie o una sola subserie aplicable en el árbol, puede seleccionarse automáticamente al cargarse el catálogo.
3. Completa:
 - **Código (único)**: el servidor **asigna automáticamente** el siguiente correlativo si no lo modifica. La pantalla puede mostrar una **vista previa** (también con **Correlativo servidor**). La convención depende de lo ya registrado: si existen códigos en forma **simple** (`PREFIJO-0001`, `PREFIJO-0002` ...), se continúa esa serie; si no, puede usarse el formato **anual** (`PREFIJO-AÑO-00001` ...). Solo **ADMIN** puede fijar un código distinto escribiéndolo en el formulario. El prefijo se configura con `DOCUMENTO_CODIGO_PREFIX` en el backend (`DOC` por defecto).

Desde **Documentos**, el cuadro **Registrar documento** se comporta igual: vista previa al abrir y asignación en el servidor si no tocó el campo **Código**.

- Asunto
- Descripción (opcional)
- Fecha

- Tipo documental
 - Serie y clasificación (subserie)
 - **Estado inicial (Registrado o Borrador)**
 - **Dependencia propietaria** (opcional; puede venir desde su perfil)
 - **Confidencialidad** (por defecto Interno)
4. Selecciona un **archivo** permitido (PDF, imagen JPG/PNG/WEBP u Office DOCX/XLSX) (máx 50 MB).
 5. Verifica que el panel **Validaciones automáticas** marque “Correcto” para extensión/nombre/metadatos/clasificación (las reglas siguen vigentes hasta que selecciones archivo y completes campos válidos).
 6. Presiona **Guardar documento**.

Resultado esperado

- El documento aparece en el listado y se puede abrir el detalle.

Nota sobre el ciclo de vida: en el **detalle**, un ADMIN puede avanzar el **estado** solo por **transiciones válidas** (por ejemplo **Registrado** → **En revisión** → **Aprobado/Rechazado** → **Archivado**). Si eliges una transición incorrecta, el sistema mostrará un error. En estado **Archivado** no se pueden subir ni eliminar archivos adjuntos.

8. Detalle del documento (donde se adjuntan archivos)

8.1 Abrir el detalle

1. En el listado de Documentos, haz clic sobre un registro (o usa **Ver**).
2. El sistema navega a `/documentos/:id`.

La pantalla se organiza en dos columnas (en escritorio):

- **Izquierda — Vista previa:** muestra el **contenido real** del archivo activo de **mayor versión** cuando es **PDF** o **imagen** (JPG, PNG o WebP), descargado de forma segura con tu sesión. Si el archivo pesa más de **20 MB**, el sistema solo muestra un aviso informativo (para no saturar la memoria del navegador) y debe usarse **Descargar** para verlo completo (la descarga permite hasta ~50 MiB, coherente con el límite de subida). Para **DOCX**, **XLSX** u otros tipos debe usarse **Descargar** (el navegador no integra vista previa de Office aquí). Si no hay adjuntos o falla la carga, verá mensajes aclaratorios en pantalla; debajo, **fecha** y **descripción** del registro. Más abajo, **Archivos digitales**: **Subir archivo** aparece si tienes `DOC_FILES_UPLOAD`; **Eliminar** una versión, si tienes `DOC_FILES_DELETE`; listar, descargar e historial según permisos de lectura/descarga. Un **ADMIN** sigue viendo las acciones administrativas habituales en UI.

- **Derecha — Metadatos:** tipo, serie, subserie y códigos del **catálogo**; confidencialidad; dependencia; **Conservación** si no está parametrizada en datos (valor «—») y texto explicativo. Botones **Descargar** (última **versión** numérica disponible entre activos), **Editar** (si tienes permiso **DOC_UPDATE** en el servidor —p. ej. **ADMIN** o rol con ese permiso asignado en la matriz, como **EDITOR_DOC**) y **Ver historial** (desplaza a la tarjeta inferior).
- **Derecha — Historial y trazabilidad:** línea de tiempo con los eventos del documento (fechas y usuario).

Si tu usuario es **ADMIN**, dentro de la tarjeta **Vista previa** verás además el bloque **Acceso al documento (ACL)**:

- **INHERIT:** usa las reglas habituales del sistema (dependencia + confidencialidad + propiedad) para determinar visibilidad.
- **RESTRICTED:** el documento queda visible solo para **ADMIN** y para los **usuarios/roles** que selecciones en la lista. Útil para evitar exposición accidental (prevención de **IDOR**) cuando un expediente debe compartirse con un grupo reducido.
- **Guardar acceso:** aplica el cambio de inmediato; si eliges **RESTRICTED** y no seleccionas nadie, el documento deja de aparecer para usuarios no administradores.
- **Aclaración (roles):** los **roles** del ACL solo cruzan con los roles que cada usuario **ya tiene** en su cuenta en el servidor. Aquí **no** se otorga el rol global **Administrador**. Para hacer administrador del sistema a alguien, use **Administración** → **Usuarios y roles**, **Editar** y cambie roles (solo un usuario que ya sea **ADMIN**).

En el mismo detalle puedes revisar **dependencia propietaria** y **nivel de confidencialidad**. Si tu cuenta tiene permiso **DOC_UPDATE** , presiona **Editar** en **Metadatos**, ajusta los campos y **Guardar** en el diálogo cuando la pantalla lo muestre.

8.1.1 Envío y resolución de revisión (flujo MVP)

Cuando el documento está en estado **Registrado**:

1. Quien lo **registró** en el sistema o un **ADMIN** puede pulsar **Enviar a revisión**. El estado pasa a **En revisión**.

Cuando está **En revisión**:

1. Un usuario con rol **REVISOR** o **ADMIN** puede pulsar **Aprobar** o **Rechazar**.
2. Si pulsas **Rechazar**, se abre un diálogo donde debes escribir el **motivo del rechazo** (obligatorio, mínimo 3 caracteres, máximo 2000); el texto queda registrado en **Auditoría** junto con la decisión.

Consulta rápida de pendientes

- En **Documentos**, filtra **Estado** → **En revisión**. Si tienes rol **REVISOR**, el listado muestra una nota de ayuda con este mismo consejo.

Resultado esperado

- Estados y trazas coherentes en el **Historial** del documento y en **Auditoría** (acciones como envío/resolución de revisión cuando el administrador revise la bitácora).

Fallos típicos

- **403** al resolver: tu usuario no es **REVISOR** ni **ADMIN**.
- **403** al enviar: solo el usuario que creó el registro documental (o **ADMIN**) puede enviar ese documento a revisión.
- Estado incorrecto (p. ej. ya archivado o no está en «Registrado»): el backend rechaza la operación con un mensaje de validación.
- Rechazo **sin motivo** o motivo demasiado corto: validación del servidor (**400**) o mensaje en el propio diálogo antes de confirmar.

8.2 Sección “Archivos digitales” (adjuntos)

Esta sección está en la tarjeta **Vista previa** del detalle del documento. No aparece en Inicio.

8.2.1 Subir archivo (solo ADMIN)

1. Dentro del detalle del documento, en **Vista previa**, ubica **Archivos digitales**.
2. Presiona **Subir archivo**.
3. Selecciona un archivo permitido (máx 50MB).

Resultado esperado

- El archivo aparece como **v1** (o **v2**, **v3** si ya existía el mismo nombre).

8.2.2 Descargar archivo (JWT)

1. En el archivo listado, presiona **Descargar**.

Resultado esperado

- Se descarga el binario y se registra un evento **DESCARGADO**.

8.2.3 Ver historial del archivo (JWT)

1. Presiona **Historial**.

Resultado esperado

- Se muestran eventos **SUBIDO/DESCARGADO/ELIMINADO** con fecha y usuario.

8.2.4 Eliminar archivo (borrado lógico, solo ADMIN)

1. Presiona **Eliminar**.
2. Confirma.

Resultado esperado

- El archivo se marca inactivo (no se borra físicamente por defecto) y aparece un evento `ELIMINADO`.

9. Historial del documento (trazabilidad)

En el detalle del documento existe la tarjeta **Historial y trazabilidad** (también alcanzable con **Ver historial** desde **Metadatos**):

- Muestra eventos de creación y actualización del documento.
- Sirve como evidencia de trazabilidad (ISO 15489).

10. Auditoría del sistema (solo ADMIN)

1. Menú lateral → **Administración** → **Auditoría** (ruta `/admin/auditoria`).
2. En **Criterios de consulta** elija **Usuario** (**Todos** o un usuario del listado — el servidor filtra por `actor_user_id`), **Acción** (**Todas** o una acción concreta, coincidencia exacta con el código en base de datos) y las fechas **Desde / Hasta**.
3. Pulse **Consultar** para aplicar filtros y cargar la tabla (antes de consultar, los cambios en los campos no actualizan el listado). Opcional: icono **Actualizar** en la cabecera para repetir la consulta con los mismos filtros y página actual.
4. Opcional: **Exportar Excel** o **Exportar PDF** descargan hasta **5000** registros recientes que cumplan **los filtros ya aplicados**.

Resultado esperado

- Lista paginada de eventos (`audit_logs`).
- Columna **Usuario** muestra nombre preferente cuando el actor está enlazado a un usuario del sistema (si no, el correo registrado en el evento o guion).
- **Documento / recurso** muestra el **código institucional del expediente** (p. ej. `SIS-2026-...`) cuando el backend puede resolverlo desde el documento o desde `documentoId` en metadatos; si no aplica, puede mostrarse “—” o una referencia técnica abreviada al UUID.
- Cada exportación deja constancia en auditoría (`REPORT_EXPORTED`).

Posibles fallos

- **403 / vacío:** el usuario no es ADMIN o el token expiró (vuelve a iniciar sesión).
-

11. RespalDOS y seguridad (solo ADMIN)

1. Menú lateral → **Administración** → **RespalDOS** (ruta `/admin/respaldos`).
2. El **servidor puede programar mysqldump** (cron dentro del proceso API) usando variables en `backend/.env` (`BACKUP_AUTOMATED_*`, `BACKUP_MYSQLDUMP_PATH`, etc. — véase `backend/.env.example`, checklist en `scripts/README-backups-mysql-xampp.md` y, para añadir el bloque automáticamente en una copia nueva del repo, `scripts/configure-local-backups.ps1`). Tras cambiar `.env`, **reinicie el proceso del backend** para que el cron quede registrado.
3. **Copia desde la UI:** puede pulsar **Ejecutar mysqldump ahora (manual)**; llama `POST /api/v1/backup/admin/run-now` y escribe artefactos en disco (`BACKUP_OUTPUT_DIR`). Opcionalmente el job incluye un **ZIP de storage/** si `BACKUP_INCLUDE_STORAGE_ZIP=true`.
4. **Restauración** no se ejecuta desde el navegador: sigue siendo procedimiento institucional (MySQL CLI + recuperación de `storage/`).
5. **Datos en pantalla:** `GET /api/v1/dashboard/admin/backup-overview` (solo ADMIN): historial hasta 50 filas de `BACKUP_VERIFIED` (OK o FAIL), columna **Origen** (Manual vs Automático según `meta.source`), KPIs 90 días y señal de cron activo.
6. **Registrar verificación manual:** elija **Resultado** OK o **FAIL**; si elige **FAIL**, **Notas** es obligatorio (motivo). Opcional: tipo, tamaño. Genera el mismo tipo de evento de auditoría que el job automático.
7. **“Próximo respaldo / programación”:** combina `BACKUP_EXPECTED_SCHEDULE_HINT` (texto) y, si el cron automático está activo, la expresión cron configurada.
8. Diálogos **Restaurar copia** y **Probar respaldo** siguen siendo solo orientación.

Resultado esperado

- El administrador distingue eventos automáticos y manuales, puede documentar fallos (FAIL) y conoce dónde quedan los `.sql` / `.zip` en el servidor.

Posibles fallos

- **403:** usuario no ADMIN o sesión caducada.
 - **Ejecutar mysqldump ahora falla:** comprobar `BACKUP_MYSQLDUMP_PATH`, `DATABASE_URL`, permisos de carpeta de salida y logs del proceso Node.
 - **Tabla vacía:** aún no hubo registros OK/FAIL ni en automático ni en manual.
-

12. Reportes institucionales (solo ADMIN)

1. Menú lateral → **Administración** → **Reportes** (ruta `/admin/reportes`).
2. Elija **Periodo** (mes), **Área** (dependencia, opcional), **Tipo documental** (opcional) y el **formato preferido** para limitar botones PDF/XLSX.
3. Pulse **Generar** para aplicar los filtros al gráfico **Documentos por tipo** (máx. 6 tipos con más volumen en el mes) y para las exportaciones de inventario.
4. En **Reportes disponibles** puede:
 - Descargar inventario en **PDF / XLSX** (respeta filtros aplicados; el XLSX permite acotar también por **Área** mediante `dependenciaId` en servidor).
 - Descargar **Actividad por usuario** como PDF de **auditoría** (solo rango de fechas del periodo, sin filtro de tipo/área).
 - **Trazabilidad por documento**: use el detalle del expediente (**Cómo consultar** explica la ruta dentro del sistema).
 - **Cumplimiento de respaldos**: botón **Abrir** lleva a la pantalla de respaldos (procedimiento documentado fuera del SGD).

Posibles fallos

- **403**: el usuario no es ADMIN para indicadores o exports administrativos.
- Gráfico vacío: no hay documentos activos en el periodo para el ámbito del administrador.

13. Configuración de seguridad (solo ADMIN)

1. Menú lateral → **Administración** → **Configuración** (ruta `/admin/configuracion`).
2. La pantalla muestra:
 - **Estado efectivo** (lo que el backend aplica hoy) leído desde `GET /auth/admin/security-summary`.
 - **Política institucional** (valores deseados) persistida como registro en base de datos con `GET /auth/admin/security-policy`.
3. Ajuste los valores deseados (p. ej. longitud mínima, bloqueo por intentos, caducidad JWT deseada) y presione **Guardar política**.
4. Al guardar, el sistema registra auditoría `SECURITY_POLICY_UPDATED` y conserva el contexto (actor, fecha/hora, IP si aplica).

Importante

- Guardar la política institucional **no cambia automáticamente** el runtime si el control no está implementado (ej. historial de contraseñas o step-up ADMIN). La pantalla muestra **Efectivo vs Deseado** para evitar falsas expectativas.

- El mínimo de contraseña efectivo hoy está alineado a **8 caracteres** (DTO servidor), aunque la política deseada pueda definirse distinta.
-

14. Cierre de sesión

1. En la barra superior, abre el menú del usuario.
2. Presiona **Cerrar sesión**.

Resultado esperado

- Se limpia la sesión y vuelves a `/login`.
-

15. Checklist de uso “de principio a fin” (resumen rápido)

1. Login
2. (ADMIN) Crear catálogos: dependencias/cargos/tipos/series/subseries
3. (ADMIN) Crear documento (dependencia y confidencialidad si aplica)
4. Opcional: **Trámites** (Kanban) o **Clasificación** (cuadro ISO)
5. Abrir detalle del documento
6. (ADMIN) Subir archivo y generar versión
7. Descargar y revisar historial
8. (ADMIN) Revisar o exportar **Auditoría** si necesitas evidencia sistémica
9. (ADMIN) Opcional: **RespalDOS** para recordatorio de procedimiento (copias reales fuera del SGD web)
10. (ADMIN) Opcional: **Reportes** (gráficos e inventario/auditoría exportables)
11. (ADMIN) Opcional: **Configuración** (transparencia de políticas técnicas)
12. Logout

28 listado lo que deberia tener el sistema

Listado de lo que debería tener el sistema (Gap vs implementación actual)

Proyecto: SGD-GADPR-LM
Fecha de última revisión: 2026-05-08
Propósito: comparar los requisitos (1–45) propuestos vs el sistema implementado y listar lo que falta para un cierre institucional alineado con **ISO/IEC 27001**, **ISO 15489** y **OWASP ASVS**.

- Leyenda de estado:
- **Implementado:** existe en backend y/o frontend y es usable.
 - **Parcial:** existe parcialmente (MVP) o falta robustecer (p. ej. auditoría transversal, rate limit, retención).
 - **Pendiente:** no existe o no se evidencia en el sistema actual.

0) Avance (código vs gobierno institucional)

Constatación explícita: **no** se puede “cerrar” el listado 1–45 solo con software de tesis; varios ítems son **política**, **infraestructura** o **proceso**. El repositorio incorpora (entre otras iteraciones):

Brecha (doc)	Qué se hizo en MVP
R-6 / R-38	Columnas <code>dependencia_id</code> y <code>nivel_confidencialidad</code> en <code>documentos</code> ; filtro de visibilidad en listado/detalle/descarga/export (no-ADMIN).
R-30 / R-31 / R-40 (base)	UI ADMIN <code>/admin/auditoria</code> + export <code>GET /api/v1/reportes/auditoria.{xlsx,pdf}</code> ; bitácora <code>audit_logs</code> con eventos de auth; AUTHZ_FORBIDDEN al responder 403 con usuario JWT.
R-9 (base ASVS)	Throttling global y por ruta <code>auth</code> + AUTH_LOCKOUT_* : bloqueo por cuenta tras N contraseñas incorrectas (<code>users.failed_login_attempts</code> / <code>locked_until</code>); se limpia en login OK o restablecimiento de contraseña.

Brecha (doc)	Qué se hizo en MVP
R-4 (parcial)	Roles REVISOR , AUDITOR , CONSULTA en seed y UI; REVISOR ejecuta resolver revisión (<code>POST .../resolver-revision</code>); AUDITOR/CONSULTA siguen como USUARIO en alcance hasta flujos propios.
R-36 / R-37	Procedimiento documentado: <code>scripts/README-backups-mysql-xampp.md</code> (backup/restauración manual).
R-27 / R-34 (MVP)	Catálogo BORRADOR ... ARCHIVADO , transiciones controladas en servidor, migración SQL de normalización; ARCHIVADO bloquea subir/eliminar adjuntos y cambios de metadatos (salvo <code>activo</code>); <code>DOC_STATE_CHANGED</code> en <code>audit_logs</code> .
R-28 / R-29 (MVP)	<code>POST /api/v1/documentos/:id/enviar-revision</code> (REGISTRADO → <code>EN_REVISION</code> , creador o <code>ADMIN</code>); <code>POST .../resolver-revision</code> (<code>EN_REVISION</code> → <code>APROBADO/RECHAZADO</code> , <code>ADMIN</code> o REVISOR); rechazo con motivo obligatorio (3–2000 caracteres) registrado en <code>audit_logs.meta.motivoRechazo</code> ; eventos <code>DOC_SUBMITTED_FOR_REVIEW</code> y <code>DOC_REVIEW_RESOLVED</code> ; bandeja mínima = filtro listado estado En revisión .

Queda **pendiente de gobierno / producto** (entre otros): bandeja dedicada / SLA, **notificaciones por vencimiento** (depende de retención R-32–35), retención/legal hold operativos (R-32–35), HTTPS productivo (R-19), MFA/WAF (backlog), permisos granulares `Permission` (R-5), políticas jurídicas firmadas (R-43). **R-44 (correo)** para revisión ya está en MVP best-effort vía SMTP.

1) Matriz de requisitos (1–45) — estado y brecha

1. Seguridad, identidades y acceso

1. Inicio de sesión seguro — Implementado

- **Evidencia:** `JWT access + refresh HttpOnly`, `Argon2id`, `/auth/login|refresh|logout|me` .
- **Docs:** `05-modulo-auth.md` , `18-seguridad-y-hardening.md` .

2. Gestión de usuarios (crear/editar/activar/desactivar) — Implementado

- **Evidencia:** `/admin/usuarios` + endpoints `/usuarios` (`ADMIN`).
- **Docs:** `06-modulo-usuarios.md` .

3. Gestión de identidades (cuenta única) — Implementado

- **Evidencia:** `users.email` único.

4. Roles y perfiles (admin, usuario, revisor, auditor, consulta) — Parcial

- **Hoy:** ADMIN , USUARIO , REVISOR, AUDITOR, CONSULTA; REVISOR resuelve revisión documental vía API/UI (R-28 MVP).
- **Falta:** flujos para AUDITOR / CONSULTA y matriz de permisos fina.

5. Permisos por rol (ver/subir/editar/eliminar/descargar) — Parcial (mejorado MVP)

- **Hoy:** mutaciones sensibles con ADMIN ; lectura con JWT; **filtrado por dependencia + confidencialidad** en consulta/descarga/export documentos (no-ADMIN); **permissions / role_permissions** con @Permissions + PermissionsGuard en rutas clave + UI matriz BD + /rbac/... ; seed RBAC (prisma db seed).
- **Falta:** permisos ABAC por registro/documento más allá de dependencia/confidencialidad ya modelados; segregación institucional avanzada (§3 en 07).
- **Docs:** 07-modulo-roles-permisos.md .

6. Control de acceso por documento (área/tipo/confidencialidad) — Parcial (MVP código)

- **Hoy:** documentos.dependencia_id , nivel_confidencialidad y reglas en servicio (listado/detalle/eventos/archivos/export).
- **Falta:** reglas de negocio institucionales más finas (ej. mezcla de roles no-ADMIN, clasificación por serie, elevación controlada).

7. Contraseñas cifradas (hash) — Implementado

- **Evidencia:** Argon2id (password_hash).

8. Recuperación segura de contraseña (token temporal) — Implementado (MVP)

- **Evidencia:** password_reset_tokens + endpoints request/confirm + invalidación de sesiones.
- **Falta:** envío de token por correo institucional (en MVP puede existir debugToken en dev).

9. Bloqueo por intentos fallidos — Parcial (MVP+)

- **Hoy:** @Throttle en login/refresh/restore/reset + throttler global + AUTH_RATE_LIMITED ; logout por **cuenta** (AUTH_LOCKOUT_MAX_ATTEMPTS / AUTH_LOCKOUT_MINUTES , ver .env.example) con auditoría BAD_PASSWORD / ACCOUNT_LOCKED .
- **Falta:** backoff/ajuste fino institucional, aviso explícito al usuario (se mantiene mensaje genérico), integración con mesa de ayuda / desbloqueo ADMIN en UI si se requiere.

10. Control de sesiones (inactividad/expiración/cierre) — Parcial

- **Hoy:** expiración de access + refresh; logout revoca refresh.

- **Falta:** control explícito por inactividad (server-side), lista de sesiones, cierre global.

1. Validación de entradas (formularios) — Implementado (base)

- **Evidencia:** DTOs + `ValidationPipe` global.
- **Falta:** reglas de negocio extra (p. ej. políticas fuertes de contraseña, normalizaciones, límites específicos por campo en todos los módulos).

1. Validación de archivos (formatos autorizados) — Implementado (base)

- **Evidencia:** whitelist MIME, nombres seguros, no servir storage público.
- **Docs:** `13-modulo-archivos.md`, `18-seguridad-y-hardening.md`.

1. Límite de tamaño de archivos — Implementado

- **Evidencia:** 10MB en interceptor Multer.

1. Protección contra inyección SQL (ORM/parametrización) — Implementado

- **Evidencia:** Prisma ORM (query parametrizada).

1. Protección contra XSS — Parcial

- **Hoy:** React reduce XSS reflejado por default; no almacenar refresh en localStorage.
- **Falta:** política explícita de sanitización/escape para campos con HTML, CSP (Helmet avanzado), revisión de renderizado de textos.

1. Protección CSRF — Parcial

- **Hoy:** `sameSite=lax` en cookie refresh reduce superficie.
- **Falta:** anti-CSRF token si aumentan endpoints sensibles basados en cookie; evaluación ASVS.

1. Manejo seguro de errores — Implementado (base)

- **Evidencia:** mensajes genéricos; no stack al cliente.
- **Falta:** estrategia consistente de códigos/errores y logging estructurado con correlación.

1. CORS controlado — Implementado

- **Evidencia:** `CORS_ORIGIN` configurable, `credentials: true`.

1. HTTPS obligatorio — Parcial

- **Hoy:** en demos se usa túnel (HTTPS externo), local puede ser HTTP.
- **Falta:** despliegue institucional con TLS terminación (reverse proxy) y política “HTTPS only”.

2. Gestión documental (ISO 15489)

1. Registro de documentos — Implementado

- **Evidencia:** CRUD documento (ADMIN) + consulta (JWT).

1. Código único de documento — Implementado

- **Evidencia:** `documentos.codigo` único.

1. Metadatos documentales (título/tipo/área/autor/estado/versión/clasificación) — Parcial

- **Hoy:** tipo, subserie/serie (clasificación), fechas, estado, creador, dependencia propietaria (`dependencia_id`), nivel de confidencialidad.
- **Falta:** metadatos adicionales por tipo formalizados y “versión” del documento como entidad (diferente a versión de archivo).

1. Clasificación documental (serie/subserie) — Implementado

- **Evidencia:** catálogos series/subseries y FK en documento.

1. Organización por carpetas o estructura lógica — Parcial

- **Hoy:** clasificación por series/subseries; storage físico por `documentoId`.
- **Falta:** “repositorio” lógico por dependencia/proceso/año visible en UI si se requiere.

1. Búsqueda de documentos — Implementado (MVP)

- **Evidencia:** filtros por metadatos y por adjuntos (nombre/mime/sha256).

1. Control de versiones — Parcial

- **Hoy:** versionado de archivos + historial de documento (eventos).
- **Falta:** versión del “documento” como estado formal (p. ej. v1/v2 con snapshot) si la institución lo exige.

1. Estados del documento (borrador/enviado/revisado/aprobado/.../archivado) — Parcial (MVP código)

- **Hoy:** catálogo fijo y transiciones validadas en `DocumentosService` (`documento-estado.util.ts`); alta **BORRADOR/REGISTRADO**; **ADMIN** puede seguir ajustando estado por **PATCH**; acciones de flujo **enviar / resolver revisión** con reglas por actor.

- **Falta:** catálogo parametrizable institucional; transiciones **solo** vía workflow (sin bypass ADMIN) si la política lo exige.

1. Flujo de aprobación — Parcial (MVP código)

- **Hoy:** envío a revisión (**REGISTRADO** → **EN_REVISION**) por **creador o ADMIN**; resolución (**APROBADO/RECHAZADO**) por **ADMIN** o **REVISOR**; **rechazo con motivo obligatorio** persistido en auditoría (`motivoRechazo`); filtro de listado para “En revisión”.
- **Falta:** bandeja propia, notificaciones, SLA, múltiples niveles de aprobación, firma electrónica institucional.

1. Trazabilidad documental (quién creó/modificó/revisó/aprobó/descargó/eliminó) — Parcial

- **Hoy:** eventos de documento/archivo; `DOC_STATE_CHANGED`, `DOC_SUBMITTED_FOR_REVIEW`, `DOC_REVIEW_RESOLVED` en `audit_logs` cuando aplica el flujo.
- **Falta:** informes de cohorte institucional, cobertura exhaustiva por operación y retención de bitácora acordada.

1. Bitácora de auditoría (acciones del sistema con IP) — Implementado (MVP+)

- **Hoy:** tabla `audit_logs` + API `GET /api/v1/auditoria` (ADMIN) + UI `/admin/auditoria` + export Excel/PDF desde reportes; `AUTHZ_FORBIDDEN` ante **403** autenticado.
- **Falta:** más eventos denegados (p. ej. 404 táctico si se audita sin filtración), retención institucional y firma/checksum de bitácora.

1. Historial de accesos (quién ingresó y cuándo) — Parcial

- **Hoy:** eventos `AUTH_LOGIN_OK` / `AUTH_LOGIN_FAIL` (y relacionados) en `audit_logs`; consulta y export desde módulo auditoría.
- **Falta:** dashboard operativo y KPIs de seguridad para mesa de ayuda.

1. Conservación documental (tiempo por tipo) — Pendiente

2. Políticas de retención — Pendiente

3. Archivo digital (estado archivado sin perder) — Parcial (MVP)

- **Hoy:** estado **ARCHIVADO** con bloqueo de carga/eliminación de adjuntos y de edición de metadatos (solo `activo` en catálogo).
- **Falta:** política de conservación, ubicación lógica “fondo archivístico” y disposición institucional.

1. Eliminación controlada (sin autorización/registro) — Parcial

- **Hoy:** documentos/archivos se restringen por ADMIN y los archivos usan borrado lógico.
- **Falta:** reglas de eliminación por política/estado + bitácora central y aprobación (si aplica).

3. Continuidad, reportes y cumplimiento

1. Copias de seguridad automáticas (BD y archivos) — Parcial (procedimiento)

- **Guía manual:** `scripts/README-backups-mysql-xampp.md`.
- **Falta:** automatización institucional (cron, destino certificado, pruebas de restauración registradas).

1. Restauración de información — Parcial (procedimiento)

- Ver `scripts/README-backups-mysql-xampp.md` (`import mysql + storage/`).

1. Protección de documentos sensibles (público/interno/reservado/confidencial) — Parcial (MVP código)

- **Hoy:** niveles en metadato + enforcement en API (ver R-6).
- **Falta:** gobierno institucional del catálogo de niveles y excepciones auditadas.

1. Reportes administrativos — Implementado (parcial)

- **Hoy:** reportes de documentos a Excel/PDF con filtros; plantilla dedicada **pendientes de revisión** (`/reportes/pendientes-revision.{xlsx,pdf}`) para **ADMIN/REVISOR**; filtro por **estado** incluye revisión/aprobación vía datos.
- **Falta:** export combinado de eventos `DOC_SUBMITTED_FOR_REVIEW` y `DOC_REVIEW_RESOLVED` si lo exige archivo.

1. Reportes de seguridad (accesos, intentos fallidos, acciones) — Parcial (MVP)

- **Hoy:** export filtrable de `audit_logs` (Excel/PDF) + consulta en pantalla ADMIN.
- **Falta:** plantillas institucionales, envío programado, segregación de datos en reportes.

1. Panel de administración (usuarios/roles/permisos/documentos/auditoría) — Parcial

- **Hoy:** usuarios + catálogos + documentos + auditoría + exportes (ADMIN).
- **Falta:** pantalla de permisos granulares y parámetros generales (17).

1. Manual de usuario — Implementado

- **Evidencia:** `27-manual-usuario-sgd-gadpr-lm.md` + regla de actualización.

1. Políticas internas del sistema — Parcial

- **Hoy:** lineamientos en docs + reglas `.cursor/rules`.

- **Falta:** documento formal de políticas institucionales (acceso/retención/seguridad) y su aterrizaje en configuración.

1. Notificaciones (pendiente/aprobado/rechazado/vencimiento) — Parcial (MVP)

- **Hoy:** notificación por **email** (best-effort, depende de SMTP):
 - al **enviar a revisión:** se notifica a usuarios **ADMIN/REVISOR** activos;
 - al **resolver revisión:** se notifica al **creador** del documento (incluye motivo si fue rechazado).
- **Falta:** notificaciones por vencimiento (retención), bandeja/cola dedicada con SLA, plantillas institucionales, canal alternativo (in-app) y configuración de destinatarios por política.

1. Integridad del documento (evitar alteraciones y registrar cambios) — Parcial

- **Hoy:** trazabilidad de cambios (eventos) + hash de archivos + RBAC.
- **Falta:** controles avanzados (firma digital, WORM, sellado de tiempo) si el alcance lo exige.

2) Módulos mínimos recomendados — estado actual

1. Autenticación — Implementado (MVP+)

- Login, logout, refresh, recuperación, `/me` ; logout por cuenta (env) + throttling.
- Falta: MFA; sesión por inactividad avanzada más allá del refresh.

2. Usuarios — Implementado (MVP)

- Crear/editar/activar/desactivar/reset pass; roles **ADMIN, USUARIO, REVISOR, AUDITOR, CONSULTA**.
- **REVISOR:** resolución de revisión documental (además del alcance de lectura JWT como **USUARIO**).
- Falta: permisos granulares (`Permission`) y flujos para **AUDITOR/CONSULTA**.

3. Documentos — Implementado (MVP+)

- Registro, metadatos base, clasificación, búsqueda, detalle; **estados, workflow enviar/ resolver revisión** en UI y API.

4. Trazabilidad — Parcial

- Eventos por documento/archivo; `audit_logs` (estado + envío/resolución de revisión) + UI/ export seguridad.
- Falta: retención legal e integridad avanzada de bitácora.

5. Conservación — Pendiente (gobierno)

- Retención, archivo formal, disposición/eliminación por política; evidencia restauración fuera del código.

6. Seguridad — Parcial

- Validación, headers, CORS, ORM, subida acotada, **throttling**, **filtro por documento**, **lockout por cuenta**, **403 auditados**.
- Falta: MFA, CSP/CSRF según alcance ampliado, TLS productivo y monitoreo centralizado.

7. Reportes — Parcial

- Documentos + **auditoría** Excel/PDF (ADMIN).
- Falta: reportes de cumplimiento documental (retención/aprobación) y envío programado.

3) Lista priorizada de “lo que falta” (recomendación)

Prioridad Alta (cierra brechas de seguridad y evidencia)

- **R-30/R-31/R-40**: profundizar cobertura (denegaciones 404 tácticas si aplica, exportaciones ya auditadas); dashboard operativo.
- **R-9**: MFA y políticas de backoff; lockout por cuenta **iniciado** (env `AUTH_LOCKOUT_*`).
- **R-6/R-38**: endurecer reglas de negocio (excepciones, elevación auditada).
- **R-36/R-37**: automatizar backups y **pruebas de restauración** con bitácora.

Prioridad Media (mejora ISO 15489 “completo”)

- **R-27/R-28**: profundizar (bandeja, notificaciones, transiciones solo por workflow, aprobaciones multinivel).
- **R-32/R-33**: retención y conservación.
- **R-44**: notificaciones (pendientes/vencimientos).

Prioridad Baja / Futuro (institucionalización avanzada)

- Firma digital, sellado de tiempo, WORM, SIEM/WAF/MFA corporativo.

29 etapa 0 cierre y evidencias

ETAPA 0 — Cierre al 100% (evidencias en repositorio)

Proyecto: SGD-GADPR-LM

Referencia roadmap: docs/00-roadmap-general.md (fila ETAPA 0 — Auditoría y saneamiento)

Expediente: GADPR-LM-ETI-SGD-2026-001

Fecha de cierre formal: 2026-05-06

Actualización documental (2026-05-06): este documento conserva la evidencia de cierre del hito. Para el **estado vivo** del código y brechas institucionales: docs/README.md (snapshot), docs/22-changelog-tecnico.md , docs/28-listado-lo-que-deberia-tener-el-sistema.md .

Objetivo

Declarar **cerrada la ETAPA 0** cuando los entregables del roadmap están **presentes en el monorepo** y la **deuda** queda registrada en los documentos oficiales de seguimiento, sin obligar a que cada máquina de desarrollo tenga MySQL configurado (eso es onboarding local, ETAPA 2 / operación).

Checklist vs roadmap (00-roadmap-general.md)

Entregable roadmap	Evidencia en repo	Estado
/docs completo (índice + módulos + seguridad + entorno + manual + brechas)	docs/README.md enlaza 00 – 28 , 27-manual-usuario... , etapa-0-auditoria... , 29 (este archivo)	Cumple
.gitignore (secretos y artefactos)	Raíz: .gitignore (.env* , node_modules , dist , storage/* con !storage/.gitkeep)	Cumple
storage/ reservado	storage/.gitkeep ; reglas documentadas en README y 13-modulo-archivos.md	Cumple

Entregable roadmap	Evidencia en repo	Estado
<code>.env.example</code> (sin secretos)	<code>backend/.env.example</code> ; <code>frontend/.env.example</code>	Cumple
<code>README.md</code> (onboarding + enlaces docs/)	<code>README.md</code> en raíz	Cumple
Deuda registrada	<code>docs/20-problemas-detectados.md</code> , <code>docs/21-riesgos-pendientes.md</code> , <code>docs/28-listado-lo-que-deberia-tener-el-sistema.md</code>	Cumple

Relación con el informe inicial de auditoría

El archivo `etapa-0-auditoria-inicial-y-diagnostico.md` es un **informe histórico** (snapshot **2026-04-19**). Las conclusiones de estado del repositorio en ese documento **no** describen el código actual.

- **Artefacto de diagnóstico:** se conserva sin reescribir el análisis original (trazabilidad académica).
- **Estado vigente del saneamiento:** este `29-etapa-0-cierre-y-evidencias.md` + `00-roadmap-general.md` (sección *Estado actual*).

Validaciones mínimas recomendadas (no bloquean el cierre de ETAPA 0)

Verificación	Responsable	Nota
Copiar <code>backend/.env.example</code> → <code>backend/.env</code> y crear BD MySQL	Cada desarrollador	Ya documentado en <code>README.md</code> y <code>04-modelo-base-de-datos.md</code>
<code>npx prisma migrate deploy</code> + <code>prisma generate</code>	Cada entorno	Fuera del “cierre documental”; ver reglas <code>.cursor/rules/prisma-xampp-mysql.mdc</code>

Próximo foco oficial

Según `docs/00-roadmap-general.md` , el trabajo de producto sigue en **ETAPA 10 — Hardening y cierre** y en el backlog de prioridades (`00` , sección inferior).

Fin del documento de cierre ETAPA 0.

30 etapa 1 cierre y evidencias

ETAPA 1 — Base técnica: cierre al 100 % (evidencias)

Proyecto: SGD-GADPR-LM
Referencia roadmap: docs/00-roadmap-general.md (fila ETAPA 1 — Base técnica)
Fecha de cierre formal: 2026-05-06

Actualización documental (2026-05-06): este documento conserva la evidencia de cierre del hito. Para el **estado vivo** del código y brechas institucionales: docs/README.md (snapshot), docs/22-changelog-tecnico.md , docs/28-listado-lo-que-deberia-tener-el-sistema.md .

Objetivo

Acreditar que la **capa técnica transversal** acordada en el roadmap está implantada antes de adjudicar trabajo solo a ETAPAs de dominio (catálogos, documentos, etc.).

Checklist vs roadmap (00-roadmap-general.md)

Frontend (frontend/)

Entregable	Evidencia	Estado
Vite + React + TypeScript	frontend/package.json , frontend/tsconfig*.json , frontend/vite.config.ts	Cumple
MUI	@mui/material , @emotion/*	Cumple
axios	frontend/src/api/client.ts , dependencia axios	Cumple
Enrutamiento	react-router-dom , frontend/src/app/App.tsx	Cumple
Stack de formulario (referencia expediente / ETAPA 0 plan)	react-hook-form , zod , @hookform/resolvers	Cumple (dependencias; uso gradual por pantalla)
		Cumple

Entregable	Evidencia	Estado
Dev: mismo origen con API (/api/v1)	Proxy <code>server.proxy['/api']</code> → backend en <code>vite.config.ts</code>	

Backend (NestJS)

Entregable	Evidencia	Estado
<code>ConfigModule</code> global	<code>backend/src/app.module.ts</code> (<code>ConfigModule.forRoot</code> , <code>envFilePath</code>)	Cumple
Validación global de entrada	<code>ValidationPipe</code> en <code>backend/src/main.ts</code> (<code>whitelist</code> , <code>forbidNonWhitelisted</code> , <code>transform</code>)	Cumple
Prefijo de API <code>/api/v1</code>	<code>app.setGlobalPrefix('/api/v1')</code> en <code>main.ts</code>	Cumple
CORS configurable + credenciales	<code>enableCors</code> con <code>CORS_ORIGIN</code> ; <code>credentials: true</code>	Cumple
Hardening base HTTP	<code>helmet</code> , <code>cookie-parser</code> ; reducción fingerprint Express	Cumple

Monorepo

Entregable	Evidencia	Estado
Scripts de conveniencia	<code>package.json</code> en raíz: <code>install:all</code> , <code>dev:all</code> , <code>start:dev</code> , <code>build</code> , ...	Cumple
Documentación de arranque	<code>README.md</code> , <code>EJECUTAR.txt</code> , <code>iniciar-desarrollo.cmd</code>	Cumple

Alcance fuera de ETAPA 1

- **Prisma / MySQL, JWT / usuarios, pantallas de negocio** corresponden a **ETAPA 2+** según roadmap; aquí solo se lista que reposan sobre esta base (**módulos bajo** `backend/src/*/` , **SPA bajo** `frontend/src/`).

Siguiente fase oficial

Según `docs/00-roadmap-general.md` , tras la base técnica sigue la **ETAPA 2:** cierre formal en `docs/31-etapa-2-cierre-y-evidencias.md` y modelo en `docs/04-modelo-base-de-datos.md` .

Fin del documento de cierre ETAPA 1.

31 etapa 2 cierre y evidencias

ETAPA 2 — BD + Prisma + XAMPP: cierre al 100 % (evidencias)

Proyecto: SGD-GADPR-LM

Referencia roadmap: docs/00-roadmap-general.md (fila ETAPA 2 — BD + Prisma + XAMPP)

Referencia modelo: docs/04-modelo-base-de-datos.md

Fecha de cierre formal: 2026-05-06

Actualización documental (2026-05-06): este documento conserva la evidencia de cierre del hito. Para el **estado vivo** del código y brechas institucionales: docs/README.md (snapshot), docs/22-changelog-tecnico.md , docs/28-listado-lo-que-deberia-tener-el-sistema.md .

Objetivo

Acreditar que la **capa de datos** declarada para el proyecto (MySQL/MariaDB vía **XAMPP**, **Prisma** como ORM único, migraciones versionadas) está **definida en el repositorio** y documentada para aplicación local.

Ámbito: el cierre ETAPA 2 cubre **artefactos en Git** (schema.prisma , migrations/ , .env.example , procedimiento 04). Crear la BD vacía, definir .env y ejecutar migrate deploy / generate en cada PC es **onboarding por entorno** (no déficit del cierre ETAPA 2).

Checklist vs roadmap (00-roadmap-general.md)

Entregable	Evidencia	Estado
schema.prisma alineado a MySQL (provider = "mysql")	backend/prisma/schema.prisma	Cumplido
Migraciones versionadas en prisma/migrations/	Carpeta presente — 22 migraciones ordenadas cronológicamente (ver tabla en docs/04-modelo-base-de-datos.md)	Cumplido

Entregable	Evidencia	Estado
BD esperada para desarrollo (DATABASE_URL) documentada sin secretos	<code>backend/.env.example</code> + §1–3 de <code>04-modelo-base-de-datos.md</code>	Cumple
Validación en phpMyAdmin / SQL	Pasos §2 y §4 de <code>04-modelo-base-de-datos.md</code>	Cumple
Versión Prisma fijada (proyecto)	<code>@prisma/client</code> y <code>prisma 5.22.0</code> en <code>backend/package.json</code>	Cumple

Comandos mínimos (desde `backend/`)

```
npx prisma migrate deploy
npx prisma generate
```

En desarrollo con iteración local: equivalente habitual `npm run prisma:migrate` (alias de `migrate dev`). Ver también `docs/24-prisma-comandos-cli.md`.

Nota sobre etapas posteriores

Tablas nuevas ligadas a **auth avanzado**, **usuarios institucionales** o **auditoría** pueden añadirse en migraciones sucesivas tras ETAPA 2; el modelo consolidado debe reflejarse siempre en `04-modelo-base-de-datos.md` y en este archivo si se redefine el “cierre” de la etapa.

Próximo hito oficial (roadmap)

ETAPA 3 — Seguridad y auth: cierre formal en `docs/32-etapa-3-cierre-y-evidencias.md`; detalle en `docs/05-modulo-auth.md`.

Fin del documento de cierre ETAPA 2.

32 etapa 3 cierre y evidencias

ETAPA 3 — Seguridad y auth: cierre al 100 % (evidencias MVP)

Proyecto: SGD-GADPR-LM

Referencia roadmap: docs/00-roadmap-general.md (fila ETAPA 3 — Seguridad y auth)

Documentación funcional: docs/05-modulo-auth.md , docs/06-modulo-usuarios.md , docs/07-modulo-roles-permisos.md

Fecha de cierre formal: 2026-05-06

Actualización documental (2026-05-06): este documento conserva la evidencia de cierre del hito. Para el **estado vivo** del código y brechas institucionales: docs/README.md (snapshot), docs/22-changelog-tecnico.md , docs/28-listado-lo-que-deberia-tener-el-sistema.md .

Objetivo

Acreditar controles mínimos de **identidad, sesión y autorización por rol (RBAC)** alineados al stack del expediente, sobre la base de datos y API de etapas previas.

Alcance MVP: autorización **por rol codificado** (ADMIN , USUARIO) con JwtAuthGuard + RolesGuard y tablas permissions / role_permissions **preparadas pero no usadas como fuente única de verdad** — backlog en docs/07-modulo-roles-permisos.md (PermissionsGuard). Esto **no bloquea** el cierre ETAPA 3 como fase de prototipo descrita en el roadmap.

Checklist vs roadmap (00-roadmap-general.md)

Entregable	Evidencia	Estado
Usuarios (cuentas, hash, activación)	backend/src/usuarios/*, modelo User en schema.prisma	Cumple
Roles / permisos (base RBAC)	Tablas roles , permissions , user_roles , role_permissions ; seed roles; Roles + RolesGuard	Cumple base
JWT (access)	JwtModule , JwtStrategy , JwtAuthGuard ; claims en token; JWT_ACCESS_SECRET / expiración configurables	Cumple

Entregable	Evidencia	Estado
Refresh HttpOnly	Cookie en <code>auth.controller</code> (<code>httpOnly</code> , <code>sameSite</code> , <code>secure</code> en prod); tabla <code>refresh_tokens</code> con rotación e inactividad (<code>auth.service</code>)	Cumple
Argon2id	<code>argon2.verify</code> / hash en login y flujos usuario (<code>auth.service</code> , <code>usuarios.service</code>)	Cumple
Guards	<code>JwtAuthGuard</code> , <code>RolesGuard</code> importados en controladores que requieren rol	Cumple
Auditoría de eventos de login/sesión	<code>AuditService</code> en <code>auth.service</code> (<code>AUTH_LOGIN_*</code> , <code>AUTH_REFRESH_*</code> , <code>AUTH_LOGOUT</code> , <code>reset</code>); tabla <code>audit_logs</code>	Cumple (MVP+)
Rate limiting auth	<code>@Throttle</code> en login y reset; <code>ThrottlerGuard</code> global + filtro <code>AUTH_RATE_LIMITED</code>	Cumple base

Endpoints de autenticación (referencia rápida)

Método	Ruta	Rol
POST	<code>/api/v1/auth/login</code>	Público
POST	<code>/api/v1/auth/refresh</code>	Cookie refresh
POST	<code>/api/v1/auth/session/restore</code>	Cookie refresh (respuesta 200 sin fallo HTTP en ausencia de sesión)
POST	<code>/api/v1/auth/logout</code>	Cookie refresh
GET	<code>/api/v1/auth/me</code>	JWT

Recuperación de contraseña: `POST .../password-reset/request`, `POST .../password-reset/confirm`.

Frontend (evidencia complementaria)

Elemento	Ubicación típica
Token access en memoria + <code>withCredentials</code>	<code>frontend/src/api/client.ts</code> , <code>frontend/src/auth/*</code>
Bootstrap sin 401 ruidoso	<code>POST /auth/session/restore</code> en <code>AuthProvider</code>
Rutas protegidas / rol ADMIN	<code>ProtectedRoute</code> , <code>RoleRoute</code> , <code>App.tsx</code>

Fuera de alcance de ETAPA 3 (siguientes iteraciones)

- `PermissionsGuard` por códigos en BD (07).

- **MFA, lockout por cuenta** tras N fallos consecutivos (throttle actual es principalmente por IP/ventana).
 - **Políticas por documento / dependencia** (12 , 28).
-

Próximo hito oficial (roadmap)

ETAPA 4 — navegación y shell UI: cierre formal en `docs/33-etapa-4-cierre-y-evidencias.md` .

Fin del documento de cierre ETAPA 3.

33 etapa 4 cierre y evidencias

ETAPA 4 — Navegación y shell UI: cierre al 100 % (evidencias MVP)

Proyecto: SGD-GADPR-LM

Referencia roadmap: docs/00-roadmap-general.md (fila ETAPA 4 — Navegación y shell UI)

Frontend: SPA bajo frontend/src/

Fecha de cierre formal: 2026-05-06

Actualización documental (2026-05-06): este documento conserva la evidencia de cierre del hito. Para el **estado vivo** del código y brechas institucionales: docs/README.md (snapshot), docs/22-changelog-tecnico.md , docs/28-listado-lo-que-deberia-tener-el-sistema.md .

Objetivo

Acreditar una **envoltura de aplicación coherente** (layout, rutas, estados HTTP accesibles, feedback de red/sesión) sobre la que se montan los módulos de negocio (catálogos, documentos, etc.).

Checklist vs roadmap (00-roadmap-general.md)

Entrega ble	Evidencia	Esta do
Layout / dashbo ard	MainLayout (AppBar, drawer temporal/permanente responsive, zona principal); / → DashboardPage con chequeo opcional /health y tarjetas contextuales	Cum ple
Menú	Ítems comunes (/ , /documentos); secciones Administración + Catálogos solo si user.roles incluye ADMIN (MainLayout.tsx)	Cum ple
Rutas protegi das	ProtectedRoute → redirección a /login con state.from si no hay usuario; loaders de sesión (SessionGate en App , AuthProvider)	Cum ple
403	/forbidden ; RoleRoute redirige aquí cuando el rol no califica (RoLeRoute.tsx)	Cum ple
404	Catch-all <Route path="*"> → NotFoundPage (App.tsx)	

Entregable	Evidencia	Estado
		Cumple
Estados error / red	AppNotifications + notifyGlobalError (sin respuesta del servidor → aviso backend caído; sesión perdida tras refresh fallido → mensaje explícito) (AppNotifications.tsx, api/client.ts)	Cumple
Breadcrumbs	getBreadcrumbsForPath, LayoutBreadcrumbs, etiqueta opcional desde BreadcrumbDetailProvider (detalle documento)	Cumple base

Rutas públicas vs protegidas (resumen)

Ruta	Papel
/login, /recuperar, /restablecer	Sin layout shell completo típico; autenticación / recuperación
/forbidden	Visible sin MainLayout; acceso tras denegación por rol
/* dentro de ProtectedRoute + MainLayout	Aplicación autenticada (inicio, documentos, admin/catálogo si ADMIN)
*	404

Fuera de alcance declarado de ETAPA 4

- **Temas institucionales avanzados** de UI (design system exhaustivo): ver docs/25-ui-ux-diseno-sistema-institucional.md.
- **Permisos por acción** más allá de rol + RoleRoute: ETAPA 3 backlog / docs/07-modulo-roles-permisos.md.

Próximo hito oficial (roadmap)

ETAPA 5 — Catálogos: cierre formal en docs/34-etapa-5-cierre-y-evidencias.md; detalle modular en docs/08 – 11.

Fin del documento de cierre ETAPA 4.

34 etapa 5 cierre y evidencias

ETAPA 5 — Catálogos: cierre al 100 % (evidencias MVP)

Proyecto: SGD-GADPR-LM
Referencia roadmap: docs/00-roadmap-general.md (fila **ETAPA 5 — Catálogos**)
Modelo BD: tablas dependencias, cargos, tipos_documentales, series, subseries — docs/04-modelo-base-de-datos.md
Fecha de cierre formal: 2026-05-06

Actualización documental (2026-05-06): este documento conserva la evidencia de cierre del hito. Para el **estado vivo** del código y brechas institucionales: docs/README.md (snapshot), docs/22-changelog-tecnico.md, docs/28-listado-lo-que-deberia-tener-el-sistema.md.

Objetivo

Acreditar los **catálogos base** que alimentan el registro documental (dependencias institucionales, cargos, tipología, serie/subserie) con persistencia Prisma y UI de administración bajo rol **ADMIN**.

Ámbito MVP: lectura/anotación usable por **JWT** en varios endpoints de listado; **creación y actualización** restringidas a **ADMIN** en backend (@Roles('ADMIN') + RolesGuard en mutaciones).
Roadmap extendido (“estados”, “configuración” parametrizada global): parcialmente cubierto en otros documentos (17-modulo-configuracion.md) — no bloquean el cierre de **catálogos nucleares** descritos aquí.

Checklist vs roadmap (00-roadmap-general.md)

Catálogo	Backend (NestJS)	API base (/api/v1)	Frontend (solo ADMIN shell)	Docs funcional
Dependencias	dependencias/	GET /dependencias, `POST	PATCH` ADMIN	/catalogos/dependencias
Cargos	cargos/	GET /cargos, mutaciones ADMIN	/catalogos/cargos	09-modulo-cargos.md

Catálogo	Backend (NestJS)	API base (/api/v1)	Frontend (solo ADMIN shell)	Docs funcional
Tipos documentales	tipos-documentales/	GET /tipos-documentales , mutaciones ADMIN	/catalogos/tipos-documentales	10-modulo-tipos-documentales.md
Series	series/	GET /series , mutaciones ADMIN	/catalogos/series	11-modulo-series-subseries.md
Subseries	subseries/	GET /subseries , mutaciones ADMIN	/catalogos/subseries	11-modulo-series-subseries.md

Transversal: todas las páginas de catálogo viven tras `RoleRoute roles={['ADMIN']}` (`frontend/src/app/App.tsx`); mismo patrón de layout/breadcrumbs (`MainLayout`).

Comportamiento de seguridad verificable

- **JwtAuthGuard** en controladores de catálogo para cualquier método.
- **RolesGuard + @Roles('ADMIN')** en `POST / PATCH` (y equivalentes) según cada controlador — los **LIST/GET** suelen estar disponibles para personal autenticado (p. ej. formularios de documento y usuarios).

Fuera de alcance MVP ETAPA 5 (backlog expediente)

- Catálogo formal de **estados de ciclo vital** del documento (máquina de estados — ver `12-modulo-documentos.md` y backlog ISO 15489).
- Pantalla única de “**configuración del sistema**” con todos los parámetros (`17`).

Próximo hito oficial (roadmap)

ETAPA 6 — Gestión documental: cierre formal en `docs/35-etapa-6-cierre-y-evidencias.md` + `docs/12-modulo-documentos.md` .

Fin del documento de cierre ETAPA 5.

35 etapa 6 cierre y evidencias

ETAPA 6 — Gestión documental: cierre al 100 % (evidencias MVP)

Proyecto: SGD-GADPR-LM
Referencia roadmap: docs/00-roadmap-general.md (fila **ETAPA 6 — Gestión documental**)
Funcional: docs/12-modulo-documentos.md
Fecha de cierre formal: 2026-05-06

Actualización documental (2026-05-06): este documento conserva la evidencia de cierre del hito. Para el **estado vivo** del código y brechas institucionales: docs/README.md (snapshot), docs/22-changelog-tecnico.md , docs/28-listado-lo-que-deberia-tener-el-sistema.md .

Objetivo

Acreditar el **registro documental** con metadatos vinculados a catálogos, **lectura** para usuarios autenticados, **alta/edición** para **ADMIN**, y **trazabilidad mínima por dominio** (sub-entregable “6A”: documento_eventos).

Nota: Los endpoints de **archivos** adjuntos viven en el mismo controlador documentos ; el cierre **funcional y de evidencias** de esa capa está en docs/36-etapa-7-cierre-y-evidencias.md . Aquí solo se referencian como soporte al expediente digital.

Checklist vs roadmap (00-roadmap-general.md)

Entregable	Evidencia	Estado
CRUD documento (núcleo)	POST /documentos , PATCH /documentos/:id — RolesGuard ADMIN (documentos.controller.ts). GET lista y detalle — JwtAuthGuard	Cumple MVP
Metadatos + catálogos	DTOs CreateDocumentoDto / UpdateDocumentoDto ; FK en modelo Prisma a tipos/subseries/serie y usuario creador (schema.prisma)	Cumple
Estados	Campo estado (texto / valores de negocio MVP); sin máquina de estados institucional → backlog 12-modulo-documentos.md §2	Parcial (aceptado MVP)

Entregable	Evidencia	Estado
Historial / trazabilidad mínima (“6A”)	GET /documentos/:id/eventos ; tabla documento_eventos (DocumentoEvento), eventos CREADO / ACTUALIZADO con actor	Cumple

Frontend

Pantalla	Ruta	Rol
Listado + alta	/ documentos	Lista JWT ; crear ADMIN (DocumentosPage.tsx)
Detalle + edición + historial documento	/ documentos /:id	Ver JWT ; editar ADMIN ; historial documento visible (DocumentoDetallePage.tsx)

Modelo de datos

- documentos , documento_eventos — inventario en docs/04-modelo-base-de-datos.md .

Fuera de alcance ETAPA 6 (backlog)

- Control de acceso por documento** (dependencia/confidencialidad / anti-IDOR por recurso): 12-modulo-documentos.md §1 y 28-listado... .
- Estados formales + flujo de aprobación:** 12-modulo-documentos.md §2–3.

Próximo hito oficial (roadmap)

ETAPA 7 — Archivos: evidencia dedicada docs/36-etapa-7-cierre-y-evidencias.md (subida, descarga, versiones, borrado lógico, eventos documento_archivo_eventos). Detalle: docs/13-modulo-archivos.md .

Fin del documento de cierre ETAPA 6.

36 etapa 7 cierre y evidencias

ETAPA 7 — Archivos: cierre al 100 % (evidencias MVP)

Proyecto: SGD-GADPR-LM
Referencia roadmap: docs/00-roadmap-general.md (fila ETAPA 7 — Archivos)
Funcional: docs/13-modulo-archivos.md
Fecha de cierre formal: 2026-05-06

Actualización documental (2026-05-06): este documento conserva la evidencia de cierre del hito. Para el **estado vivo** del código y brechas institucionales:
docs/README.md (snapshot), docs/22-changelog-tecnico.md , docs/28-listado-lo-que-deberia-tener-el-sistema.md .

Objetivo

Acreditar la **gestión de adjuntos digitales** del expediente: validación, almacenamiento bajo storage/ , **versionado**, **descarga controlada**, **borrado lógico** y **trazabilidad** por eventos de archivo.

Checklist vs roadmap (00-roadmap-general.md)

Entregable	Evidencia	Estado
Subida	POST /documentos/:id/archivos — multipart/form-data , campo file , FileInterceptor límite 10 MB (documentos.controller.ts); lógica en DocumentosService.uploadArchivo (MIME/extensión, nombre seguro, SHA-256)	Cumple
Validación	Whitelist MIME/tamaño en servicio; sin servir carpetas estáticas públicas	Cumple (MVP)
storage/	Binarios bajo storage/documentos/<documentoId>/... (contenido en .gitignore ; .gitkeep en raíz storage/)	Cumple
Versiones	Columna version en documento_archivos ; regla incremental por documentoId + nombre original (migración 20260421194500_*)	Cumple

Entregable	Evidencia	Estado
Descarga con trazabilidad	GET .../archivos/:archivoId/download — JWT; prepareDownloadArchivo valida pertenencia documento ↔ archivo; evento DESCARGADO	Cumple
Borrado lógico	DELETE .../archivos/:archivoId — ADMIN; activo=false ; evento ELIMINADO	Cumple
Trazabilidad	Tabla documento_archivo_eventos ; GET .../archivos/:archivoId/eventos ; eventos SUBIDO / DESCARGADO / ELIMINADO	Cumple

API (prefijo /api/v1)

Método	Ruta	Acceso
GET	/documentos/:id/archivos	JWT
POST	/documentos/:id/archivos	JWT + ADMIN
GET	/documentos/:id/archivos/:archivoId/download	JWT
GET	/documentos/:id/archivos/:archivoId/eventos	JWT
DELETE	/documentos/:id/archivos/:archivoId	JWT + ADMIN

Frontend

- Sección **Archivos** en /documentos/:id (DocumentoDetallePage.tsx): listado, subida (ADMIN), descarga, historial por archivo, eliminación lógica (ADMIN).
- Cliente axios: FormData sin forzar Content-Type: application/json (frontend/src/api/client.ts).

Fuera de alcance ETAPA 7 (backlog)

- Antivirus institucional, cuotas por usuario, verificación SHA-256 en cada descarga automática.
- Autorización por **dependencia/confidencialidad** del documento (anti-IDOR “real” de negocio más allá de JWT + pertenencia doc ↔ archivo): 12 / 13 / 28 .

Próximo hito oficial (roadmap)

ETAPA 8 — Búsqueda: cierre formal `docs/37-etapa-8-cierre-y-evidencias.md` . Detalle: `docs/14-modulo-busqueda.md` .

Fin del documento de cierre ETAPA 7.

37 etapa 8 cierre y evidencias

ETAPA 8 — Búsqueda: cierre al 100 % (evidencias MVP)

Proyecto: SGD-GADPR-LM
Referencia roadmap: docs/00-roadmap-general.md (fila ETAPA 8 — Búsqueda)
Funcional: docs/14-modulo-busqueda.md
Fecha de cierre formal: 2026-05-06
Etapas anteriores: docs/36-etapa-7-cierre-y-evidencias.md

Actualización documental (2026-05-06): este documento conserva la evidencia de cierre del hito. Estado vivo y brechas: docs/README.md , docs/22-changelog-tecnico.md , docs/28-listado-lo-que-deberia-tener-el-sistema.md . **Nota técnica:** el listado GET / documentos aplica **filtrado por dependencia/confidencialidad** para no-ADMIN — el párrafo “Permisos” siguiente refleja el **alcance en el momento del cierre**; el comportamiento vigente está en 12 / 14 .

Objetivo

Acreditar **consulta y refinamiento** del registro documental: texto libre, filtros por metadatos, **ordenamiento, paginación**, y criterios sobre **adjuntos** (nombre/MIME/SHA-256), con **JWT** en el API y experiencia coherente en /documentos .

Permisos (texto histórico al cierre ETAPA 8): el listado se consideraba **solo consulta** con JWT autenticado; el refinamiento institucional de **anti-IDOR por documento** se formalizó después (migración 20260507153000_* , backlog actual en 28). **Estado vigente:** ver docs/14-modulo-busqueda.md .

Checklist vs roadmap (00-roadmap-general.md)

Entregable	Evidencia	Estado
Búsqueda simple / texto	Query q en GET /documentos (documentos.controller.ts); barra de búsqueda en DocumentosPage.tsx	Cumple

Entregable	Evidencia	Estado
Filtros avanzados	<code>estado</code> , <code>tipoDocumentalId</code> , <code>serieId</code> , <code>subserieId</code> , <code>fechaDesde</code> , <code>fechaHasta</code> , <code>incluirInactivos</code>	Cumple MVP
Búsqueda por adjuntos	<code>archivoNombre</code> , <code>archivoMime</code> , <code>archivoSha256</code> (coincidencia sobre adjuntos activos en servicio/listado)	Cumple
Ordenamiento	<code>sortBy</code> ∈ <code>codigo</code> <code>fechaDocumento</code> <code>estado</code> ; <code>sortDir</code> ∈ <code>asc</code> <code>desc</code> ; cabeceras de tabla clicables en UI	Cumple
Paginación	<code>page</code> , <code>pageSize</code> ; respuesta tipada { <code>page</code> , <code>pageSize</code> , <code>total</code> , <code>items</code> } desde backend	Cumple
UI	<code>/documentos</code> : filtros, orden, pagina Anterior/Siguiente . Botones de exportación sobre la misma pantalla se acreditan en ETAPA 9 (<code>38-etapa-9-cierre-y-evidencias.md</code>).	Cumple

API (referencia)

GET `/api/v1/documentos` — parámetros alineados a `docs/14-modulo-busqueda.md`.

Fuera de alcance ETAPA 8 (backlog)

- Índices adicionales en BD y benchmarks de rendimiento sobre tablas grandes.
- Búsqueda full-text institucional, facetas complejas o guardado de consultas favoritas.

Próximo hito oficial (roadmap)

ETAPA 9 — Reportes: evidencia `docs/38-etapa-9-cierre-y-evidencias.md`. Funcional: `docs/16-modulo-reportes.md`.

Fin del documento de cierre ETAPA 8.

38 etapa 9 cierre y evidencias

ETAPA 9 — Reportes: cierre al 100 % (evidencias MVP)

Proyecto: SGD-GADPR-LM
Referencia roadmap: docs/00-roadmap-general.md (fila ETAPA 9 — Reportes)
Funcional: docs/16-modulo-reportes.md
Fecha de cierre formal: 2026-05-06
Etapas anteriores: docs/37-etapa-8-cierre-y-evidencias.md

Actualización documental (2026-05-06): este archivo conserva la **evidencia de cierre** de la etapa 9. El código posterior añadió **AuditService** en exportes (`REPORT_EXPORTED`), reportes `/reportes/auditoria.{xlsx,pdf}` y `/reportes/pendientes-revision.{xlsx,pdf}` (**ADMIN/REVISOR** en el segundo). Detalle en docs/16-modulo-reportes.md , docs/22-changelog-tecnico.md y docs/README.md (snapshot).

Objetivo

Acreditar **exportaciones institucionales** del registro documental en **Excel** y **PDF** generadas en **servidor**, con los **mismos criterios de filtro** que la búsqueda (ETAPA 8), **control de rol ADMIN** en API, y disparo desde la UI `/documentos` (bloque filtros/exportación).

Nota histórica (contenido al cierre ETAPA 9): inicialmente las exportaciones de esta etapa no registraban bitácora unificada. **Estado vigente:** ver texto de actualización anterior y `reportes.controller.ts` (`logReportExport`).

Checklist vs roadmap (00-roadmap-general.md)

Entregable	Evidencia	Estado
Excel (ExcelJS)	<code>GET .../reportes/documentos.xlsx</code> — @Header spreadsheet, workbook + hoja Documentos , stream al cliente (<code>reportes.controller.ts</code>)	Cumple
PDF (pdfkit)	<code>GET .../reportes/documentos.pdf</code> — A4, listado texto por ítem (<code>reportes.controller.ts</code>)	Cumple

Entregable	Evidencia	Estado
Permisos	<code>JwtAuthGuard + RolesGuard + @Roles('ADMIN')</code> en <code>ReportesController</code>	Cumple
Filtros coherentes con búsqueda	Mismas queries que listado <code>GET /documentos : q, estado, tipoDocumentalId, serieId, subserieId, fechas ISO, adjuntos (archivoNombre, archivoMime, archivoSha256), incluirInactivos, sortBy, sortDir</code> (<code>ReportesService.findDocumentos</code>)	Cumple
Protección de escala	<code>take</code> máximo 5000 filas en <code>findDocumentos</code>	Cumple MVP
UI	<code>DocumentosPage.tsx</code> : Exportar Excel / Exportar PDF con <code>responseType: 'blob'</code> y mismos params que la consulta	Cumple

Endpoints de referencia

- `GET /api/v1/reportes/documentos.xlsx`
- `GET /api/v1/reportes/documentos.pdf`

(Parámetro de consulta opcional igual que ETAPA 8; ver `reportes.controller.ts`.)

Fuera de alcance ETAPA 9 (backlog original)

- Export de **usuarios** desde este módulo (sigue pendiente).
- Plantillas PDF institucionales, branding GADPR, firma electrónica, jobs asíncronos.

Hecho después del cierre formal: exports de **auditoría**, **pendientes de revisión** y `REPORT_EXPORTED` en `audit_logs` (ver 16, 22).

Próximo hito oficial (roadmap)

ETAPA 10 — Hardening y cierre: cierre formal `docs/39-etapa-10-cierre-y-evidencias.md`.
Referencia técnica: `docs/18-seguridad-y-hardening.md`.

Fin del documento de cierre ETAPA 9.

39 etapa 10 cierre y evidencias

ETAPA 10 — Hardening y cierre: evidencias MVP de tesis

Proyecto: SGD-GADPR-LM
Referencia roadmap: docs/00-roadmap-general.md (fila **ETAPA 10 — Hardening y cierre**)
Guía de controles: docs/18-seguridad-y-hardening.md , docs/19-mapeo-iso27001-iso15489-owasp-asvs.md
Fecha de cierre formal: 2026-05-07
Etapas anteriores: docs/38-etapa-9-cierre-y-evidencias.md

Actualización documental (2026-05-06): la evidencia de **ETAPA 10** permanece válida como hito. Tras este cierre se incorporaron, entre otros: UI /admin/auditoria , exports de auditoría desde reportes, lockout de cuenta, estados/transiciones (R-27) y flujo de revisión (R-28) con notificaciones SMTP opcionales (R-44). Consolidado en docs/22-changelog-tecnico.md y snapshot docs/README.md .

Objetivo

Acreditar que el **MVP de tesis** cuenta con una **línea base de hardening** revisable (controles técnicos documentados, límites de abuso en autenticación, bitácora transversal en backend y **cadena documental 0–10**), sin confundir este cierre con una **certificación** ni con el **alcance institucional completo** (28-listado-lo-que-deberia-tener-el-sistema.md).

Alcance honesto: mejoras como MFA, WAF, pentest formal, SIEM, políticas de retención operativas en producción y pantallas ADMIN para todos los informes quedan registradas como **backlog** en 21-riesgos-pendientes.md y en los módulos funcionales.

Checklist vs roadmap (00-roadmap-general.md)

Entregable	Evidencia	Estado MVP tesis
Revisión seguridad (referencia)	Controles resumidos en 18-seguridad-y-hardening.md ; mapeo ASVS/ISO en 19-mapeo-iso27001-iso15489-owasp-asvs.md	Cumple (referencia verificable)
		Cumple

Entregable	Evidencia	Estado MVP tesis
Headers y superficie HTTP	Helmet + desactivar x-powered-by donde aplica (backend/src/main.ts)	
Validación de entrada	ValidationPipe global (whitelist , forbidNonWhitelisted , transform)	Cumple
Rate limiting global	ThrottlerModule + APP_GUARD ThrottlerGuard — ttl 60s, limit 200 defecto (app.module.ts)	Cumple
Rate limiting auth (ASVS/ brute force)	@Throttle en login , refresh , session/restore , password-reset/* (auth.controller.ts)	Cumple MVP
Auditoría ante 429 por throttler	ThrottlerAuditFilter → AUTH_RATE_LIMITED vía AuditService (common/filters/throttler-audit.filter.ts)	Cumple
Bitácora transversal	Tabla audit_logs ; servicios integrados en flujos críticos (ver 15-modulo-auditoria.md)	Cumple backend
Consulta ADMIN de auditoría (API)	GET /api/v1/auditoria paginado + filtros (auditoria.controller.ts , AuditQueryDto)	Cumple
Consulta ADMIN de auditoría (UI)	Pantalla /admin/auditoria listado/export (evidencia post-cierre; ver nota inicial de este doc)	Cumple (extensión documentada)
Limpieza y documentación de entrega	Cierres 29 – 39 ; índices docs/README.md , README.md , EJECUTAR.txt , manual 27	Cumple MVP

Fuera de alcance ETAPA 10 (explicitado para no sobrevender el MVP)

- **Consulta institucional avanzada** de audit_logs (paneles BI, KPIs, retención legal, correlación SIEM): la **consulta ADMIN** existe por **API** y **UI** /admin/auditoria ; lo anterior sigue siendo backlog (15 , 21).
- Cobertura de **todas** las superficies sensibles no auditadas si el alcance crece (**PermissionsGuard**, ABAC extendido): ver 07 , 21 .
- Backups **operativos** automatizados, AV sobre binarios — ver scripts/README-backups-mysql-xampp.md , 21 .

Cierre del roadmap de implementación MVP (0 → 10)

Las etapas **0 a 10** quedan con evidencia formal en `docs/29-etapa-0-cierre-y-evidencias.md` ... `docs/39-etapa-10-cierre-y-evidencias.md` (este documento).

Continuidad recomendada del proyecto: priorizar filas **Alta** del backlog del `00-roadmap-general.md` y el documento **28** según política institucional.

Fin del documento de cierre ETAPA 10.

40 rendimiento post login web vitals

Rendimiento — prefetch post-login + LCP del panel principal

Objetivo

Documentar la mejora **solo de rendimiento** (rama `perf/post-login-prefetch-web-vitals`) que:

- 1. Identifica rutas típicamente más usadas: **panel principal** (`/`), **documentos** (`/documentos`) y **perfil** (`/perfil`).
- 2. Aplica **prefetch diferido**: chunks de esas pantallas + peticiones HTTP alineadas con lo que esas pantallas consumen al entrar.
- 3. Mide **LCP** en el panel y lo **registra** en `audit_logs` (`CLIENT_WEB_VITAL_LCP`) vía `POST /api/v1/client-perf/web-vitals` (JWT + throttling).

No introduce flujos de negocio nuevos.

Antes vs después (impacto esperado)

Asp ecto	Antes	Después
Carg a ini ci al	Code-split por ruta ya activo (<code>lazyPages.tsx</code>); primer acceso a <code>/documentos</code> o <code>/perfil</code> descarga el chunk en el momento del clic.	Tras tener sesión válida, <code>requestIdleCallback</code> (fallback <code>setTimeout</code>) dispara prefetch de <code>DashboardPage</code> , <code>DocumentosPage</code> y <code>PerfilUsuarioPage</code> , así el navegador suele tener el JS ya en caché al navegar.
APIs frec uent es	Sin precalentamiento: al abrir cada pantalla los <code>GET</code> arrancan desde cero tras el clic.	En ralentí se precalientan <code>/health</code> , <code>/dashboard/summary</code> , <code>/auth/profile</code> , lista <code>/documentos</code> con la misma query por defecto que la bandeja (fecha desc, página 1, 20 ítems) y los catálogos que usa <code>/documentos</code> (<code>tipos-documentales</code> , <code>subseries</code> , <code>dependencias</code>). ADMIN : también <code>/admin/ping</code> .
LCP pan el	Solo medición manual posible (Lighthouse, pane Performance).	<code>web-vitals</code> onLCP en <code>DashboardPage</code> + envío auditado (<code>valueMs</code> , <code>rating</code> , <code>navigationType</code> , <code>metricId</code> ; sin contenido sensible en <code>meta</code>).
Ries go	N/A	

Aspecto	Antes	Después
deduplicación		Las vistas siguen lanzando sus propios GET ; el servidor puede ejecutar trabajo duplicado a cambio de mejor latencia percibida. Se documenta así a propósito.
Auditoría volumen	N/A	Una fila CLIENT_WEB_VITAL_LCP por instancia LCP nueva (los reintentos con el mismo metricId pueden reducirse en cliente con deduplicación básica).

Cómo repetir una medición “antes/después” (metodología)

1. Chrome o Edge, DevTools → **Performance / Lighthouse** (solo “Performance”) o campo RUM backend.
2. **Antes:** checkout a `main` (sin prefetch/LCP registrado).
3. **Después:** checkout a la rama de rendimiento (o fusionar PR).
4. Escenario reproducible: mismo usuario, mismo rol, mismo host (`localhost` o LAN), ventana privada nueva; login → esperar ≥ 3 s ociosos (prefetch idle) → medir segunda navegación a `/documentos` y `/perfil` (Tiempo hasta respuesta/API y ausencia/presencia esperada de trabajo en paralelo previo).
5. LCP posterior: cargar `/` después de login; en **ADMIN** revisar Auditoría por acción `CLIENT_WEB_VITAL_LCP` (`meta_json` con `valueMs` , `rating`).

Código relacionado

Capa	Archivo
Prefetch rutas/API	<code>frontend/src/perf/postLoginPrefetch.ts</code>
Activación tras sesión	<code>frontend/src/app/PostLoginPerfScheduler.tsx</code> (+ montaje en <code>App.tsx</code>)
LCP panel	<code>frontend/src/perf/useDashboardLcpReporting.ts</code> (+ <code>DashboardPage.tsx</code>)
API RUM	<code>backend/src/client-perf/*</code>

Seguridad (ASVS / ISO 27001)

- **AuthN:** `POST /client-perf/web-vitals` exige JWT (mismo patrón que el resto de API autenticada).
- **Throttling:** límite dedicado en el endpoint (por encima del default global) para evitar abuso de escritura en `audit_logs` .

- **Datos:** no se envía DOM ni URL de recursos LCP; solo métricas agregadas y contexto de navegación.
 - **Fail secure:** fallo al registrar LCP no afecta la UI (error silenciado en cliente).
-

PR

Abrir **Pull Request** desde la rama `perf/post-login-prefetch-web-vitals` hacia `main` (no mezclar con otras features).

41 pendientes documentacion vs sistema

Pendientes de documentación vs estado actual del sistema

Propósito: registrar diferencias detectadas entre la documentación y el estado real del repositorio/código, para cerrarlas de forma controlada y auditables (ISO 15489).

Última actualización: 2026-05-08

Pendientes críticos (inconsistencias objetivas)

1) Inventario de migraciones Prisma desactualizado en algunos documentos

- **Situación real:** `backend/prisma/migrations/` contiene **22** carpetas de migración (al 2026-05-08).
- **Riesgo:** onboarding incorrecto (personas esperando “14/17/18” migraciones), confusión de alcance por etapa, deriva entre `docs/04` y otros docs.
- **Acción:** alinear todas las referencias de conteo de migraciones a la cifra real y dejar “fecha de snapshot” donde aplique.

Estado de corrección

- `docs/04-modelo-base-de-datos.md` : corregido a 22 (y actualizado el inventario).
- `docs/24-prisma-comandos-cli.md` : corregido a 22.
- `docs/31-etapa-2-cierre-y-evidencias.md` : corregido a 22.

Pendiente

- Revisar si existe alguna otra referencia “14/17/18 migraciones” fuera de `docs/` (READMEs, PDFs, anexos).
-

Pendientes importantes (alineación “snapshot” y fechas)

2) “Snapshot 2026-05-06” vs cambios posteriores

- **Situación:** varios documentos fijan snapshot “2026-05-06”, pero el repo tiene cambios posteriores (por ejemplo: migraciones adicionales y pantallas/admin de seguridad ya presentes).
 - **Acción:** donde el documento sea **vivo** (no “cierre de etapa”), actualizar la fecha y el contenido; donde sea “cierre”, mantener fecha de cierre y agregar nota de “estado vivo”.
-

Pendientes por cubrir (documentos por revisar)

3) Revisión completa uno-por-uno de documentos Markdown fuera de docs/

- README.md (raíz): validar que refleje scripts/puertos/Prisma y que no contradiga frontend/README.md.
 - backend/README.md : actualmente es el boilerplate de NestJS (no describe el sistema real).
 - frontend/README.md : mezcla sección útil (proxy/allowedHosts) con boilerplate; consolidar y evitar ruido.
 - scripts/README-backups-mysql-xampp.md : validar que concuerde con BACKUP_* y con UI / admin/respaldos.
 - backups/automated/README.md : validar ruta/retención/seguridad.
 - Nueva carpeta/*.md : identificar si son entregables “históricos” o “vigentes” y rotularlo.
-

Pendientes funcionales (no solo documentación)

4) Configuración: documento docs/17 era “No implementado” y ahora existe configuración de seguridad/respaldos

- **Estado:** docs/17-modulo-configuracion.md actualizado para reflejar:
 - UI /admin/configuracion y endpoints /auth/admin/security-*.
 - UI /admin/respaldos y endpoints backup / dashboard asociados.
- **Pendiente:** definir si se creará una configuración general tipo system_settings (backlog), y documentar el roadmap.

99 guía de prueba por módulos

Guía de prueba por módulos (formato obligatorio de cierre)

Este documento consolida una **guía de prueba** usando el **formato obligatorio** del proyecto (ver `.cursor/rules/aviso-finalizacion-y-guia-de-prueba.mdc`).

Fuente: planes existentes en `docs/05-modulo-auth.md`, `docs/13-modulo-archivos.md` y criterios en `docs/19-pruebas-y-validaciones.md`.

Estado

Listo para probar.

Módulo afectado

Pruebas transversales (Login/Roles/Documentos/Reportes/Respaldos).

Qué se terminó

Guías de prueba paso a paso (manual) para validar módulos críticos y dejar evidencia (auditoría/exportaciones).

Estándar o lineamiento aplicado

ISO/IEC 27001:2022, ISO 15489, OWASP ASVS.

Prerrequisitos para probar

1. Iniciar MySQL (XAMPP).
2. Backend levantado en `http://localhost:3000` con prefijo `/api/v1`.
3. Frontend levantado en `http://localhost:5173`.
4. Base de datos migrada y seed ejecutado si aplica (ver `README.md` y `docs/04-modelo-base-de-datos.md`).

Qué debe probar el usuario

1) Login / sesión / recuperación

1. Abrir `http://localhost:5173/login`.
2. Iniciar sesión con un usuario válido.
3. Verificar que el refresh funciona (dejar expirar el access token o forzar `401` y observar que el cliente renueva).
4. Cerrar sesión desde el menú.
5. Recuperación: probar solicitud con correo existente y no existente, y confirmar que el mensaje visible no permite enumeración.

2) Roles / acceso real (backend, no solo UI)

1. Con un usuario **sin** rol `ADMIN`, intentar abrir pantallas administrativas desde el menú.
2. Intentar ejecutar acciones administrativas (crear documento, subir archivo, exportar reportes, respaldos).
3. Confirmar que el backend responde `403` en operaciones protegidas y que la UI muestra un mensaje controlado.

3) Documentos (flujo básico + revisión)

1. Como `ADMIN`, crear un documento.
2. Subir un adjunto permitido y confirmar que aparece listado (versión/evento).
3. Descargar un adjunto y confirmar que registra evento.
4. Enviar a revisión el documento.
5. Resolver revisión como `REVISOR` (o `ADMIN`) si aplica.

4) Reportes (Excel/PDF)

1. Como `ADMIN`, exportar Documentos a Excel y PDF.
2. Como `REVISOR`, exportar Pendientes de revisión a Excel y PDF (si el rol está configurado).
3. Confirmar que cada export genera evidencia en auditoría.

5) RespalDOS (verificación + ejecución manual si aplica)

1. Como `ADMIN`, abrir `/admin/respaldos`.
2. Registrar una verificación OK/FAIL.
3. (Opcional) Ejecutar "run now" si está habilitado.
4. Confirmar que el dashboard refleja el último OK y el historial.

6) Rendimiento post-login (prefetch + LCP panel)

Referencias: `docs/40-rendimiento-post-login-web-vitals.md` , manual § 1.5.

1. Con sesión iniciada, esperar ~2–3 s sin navegar lejos (precarga en idle).
2. En pestaña Red del navegador, observar solicitudes paralelas esperables (chunks de página y GET frecuentes; ver doc 40) sin errores repetidos ni 429 masivos por LCP (POST .../client-perf/web-vitals está rate-limited).
3. Abrir el **panel principal** / y cargar hasta estabilizar.
4. Como ADMIN : **Auditoría** → filtrar por acción **CLIENT_WEB_VITAL_LCP** → confirmar al menos una fila con meta_json que incluye valueMs , rating (sin contenido sensible de negocio).
5. Navegar a **Documentos** y **Mi perfil** y comprobar que la primera visita después del idle suele percibirse fluida (caché de red; no equivalencia garantizada en todos los navegadores).

Resultado esperado

- Login crea sesión y el refresh se rota/renueva sin exponer el refresh token al JS.
- Acciones sin permisos fallan con 403 (defensa en profundidad).
- Se generan registros de auditoría para eventos críticos (authz 403, rate limit 429, exportaciones, respaldos).
- Reportes descargan archivos válidos y consistentes con los filtros.

Qué revisar si falla

- Backend apagado o proxy Vite apuntando a :3000 sin servidor (ver docs/19-pruebas-y-validaciones.md).
- CORS (CORS_ORIGIN) o cookies no viajan (credenciales) en refresh.
- Migraciones/seed pendientes (errores 500 en auth o módulos).
- Roles mal asignados en BD/seed (403 inesperados o permisos excesivos).

Evidencia que debe quedar

- Filas en audit_logs (acciones como AUTHZ_FORBIDDEN , AUTH_RATE_LIMITED , REPORT_EXPORTED , BACKUP_VERIFIED , CLIENT_WEB_VITAL_LCP y eventos de auth).
- Exportes *.xlsx / *.pdf descargados.
- Si se usan respaldos automatizados: artefactos en backups/automated/ con permisos adecuados (y no versionados).

Siguiente paso recomendado

Estandarizar el cierre de cambios por iteración: cada PR debe incluir esta guía (o su subconjunto) y dejar evidencia mínima (capturas + auditoría).

README

Documentación técnica — SGD-GADPR-LM

Índice de la carpeta `docs/` . Los documentos se actualizan **en cada iteración** que toque el área correspondiente.

Estado del sistema (snapshot — 2026-05-08)

Vista rápida del **código** frente a estos documentos. Lista de brechas y matriz 1–45: `28-listado-lo-que-deberia-tener-el-sistema.md` . Línea temporal de cambios: `22-changelog-tecnico.md` .

Pendientes de alineación documental detectados durante la revisión: `41-pendientes-documentacion-vs-sistema.md` .

Área	Implementado hoy (resumen)
Autenticación	JWT + refresh HttpOnly, rotación, inactividad (<code>last_used_at</code>), throttling global y en <code>/auth</code> , logout por cuenta (<code>AUTH_LOCKOUT_*</code>), recuperación de contraseña.
RBAC	Roles seed + <code>@Roles</code> para menú/UI; <code>@Permissions</code> + <code>PermissionsGuard</code> usando <code>permissions / role_permissions</code> (seed + UI «Matriz rol ↔ permiso» en Usuarios; API <code>/rbac/...</code> ; ver <code>07</code>).
Documentos	Estados normalizados y transiciones (<code>documento-estado.util</code>); flujo enviar a revisión / resolver (R-28); <code>dependencia_id</code> + <code>nivel_confidencialidad</code> en consulta/descarga/export.
Notificaciones	Correo SMTP opcional (nodemailer) en envío a revisión y al resolver (ver <code>12</code> , <code>28</code> R-44); sin SMTP el flujo sigue.
Auditoría	<code>audit_logs</code> ; API <code>GET /auditoria</code> (ADMIN); UI <code>/admin/auditoria</code> ; <code>AUTHZ_FORBIDDEN</code> en 403 autenticados; export Excel/PDF de auditoría.
Reportes	Documentos y auditoría → Excel/PDF (ADMIN); pendientes de revisión → Excel/PDF (ADMIN + REVISOR); cada export genera <code>REPORT_EXPORTED</code> .
Arranque dev	En <code>backend/</code> , <code>npm run start:dev</code> ejecuta <code>tsbuildinfo:clean</code> antes de <code>nest start --watch</code> para evitar salida <code>dist</code> inconsistente en Windows.

Las fichas **29–39** (“cierre al 100 %”) son **evidencia de hito**; pueden incorporar una nota que remite a este snapshot y a `22 / 28` para cambios posteriores al cierre formal.

General y arquitectura

Archivo	Contenido
00-roadmap-general.md	Fases 0–10 y orden de construcción
29-etapa-0-cierre-y-evidencias.md	Cierre ETAPA 0 al 100% — checklist vs roadmap y archivo del informe inicial
30-etapa-1-cierre-y-evidencias.md	Cierre ETAPA 1 al 100% — Vite/React/Nest base (API <code>/api/v1</code> , validación, CORS, proxy)
31-etapa-2-cierre-y-evidencias.md	Cierre ETAPA 2 al 100% — Prisma + MySQL (XAMPP), migraciones, <code>DATABASE_URL</code>
32-etapa-3-cierre-y-evidencias.md	Cierre ETAPA 3 al 100% — JWT, refresh HttpOnly, Argon2, guards RBAC, auditoría auth
33-etapa-4-cierre-y-evidencias.md	Cierre ETAPA 4 al 100% — layout, rutas protegidas, 403/404, menú por rol, alertas globales
34-etapa-5-cierre-y-evidencias.md	Cierre ETAPA 5 al 100% — catálogos dependencias/cargos/tipos/series/subseries (API + ADMIN UI)
35-etapa-6-cierre-y-evidencias.md	Cierre ETAPA 6 al 100% — documentos, eventos dominio, UI listado/detalle/historial
36-etapa-7-cierre-y-evidencias.md	Cierre ETAPA 7 al 100% — adjuntos, <code>storage/</code> , versión, descarga, borrado lógico, eventos archivo
37-etapa-8-cierre-y-evidencias.md	Cierre ETAPA 8 al 100% — filtros, orden, paginación, búsqueda por adjuntos, UI <code>/documentos</code>
38-etapa-9-cierre-y-evidencias.md	Cierre ETAPA 9 al 100% — Excel/PDF documentos, filtros ETAPA 8, rol ADMIN, UI exportación
39-etapa-10-cierre-y-evidencias.md	Cierre ETAPA 10 (MVP tesis) — hardening línea base, throttle+auditoría 429, cierre roadmap 0–10
01-arquitectura-general.md	Capas, entornos, contrato API
02-stack-y-convenciones.md	Stack cerrado, puertos, variables
03-estructura-de-carpetas.md	Monorepo, rutas clave
04-modelo-base-de-datos.md	Prisma, XAMPP, migraciones
24-prisma-comandos-cli.md	Referencia de comandos Prisma CLI

Módulos funcionales

Archivo	Módulo
05-modulo-auth.md	Autenticación y sesión
06-modulo-usuarios.md	Usuarios
07-modulo-roles-permisos.md	Roles y permisos
08-modulo-dependencias.md	Dependencias
09-modulo-cargos.md	Cargos
10-modulo-tipos-documentales.md	Tipos documentales
11-modulo-series-subseries.md	Series y subseries
12-modulo-documentos.md	Registro documental
13-modulo-archivos.md	Archivos y storage
14-modulo-busqueda.md	Búsqueda
15-modulo-auditoria.md	Auditoría
16-modulo-reportes.md	Reportes
17-modulo-configuracion.md	Configuración

Seguridad, calidad y entorno

Archivo	Contenido
18-seguridad-y-hardening.md	Controles, JWT, archivos, ASVS (referencia)
19-pruebas-y-validaciones.md	Comandos y criterios de prueba
19-mapeo-iso27001-iso15489-owasp-asvs.md	Explicación y mapeo (ISO/ASVS → código)
20-problemas-detectados.md	Registro de incidencias
21-riesgos-pendientes.md	Registro de riesgos
22-changelog-tecnico.md	Historial técnico y sesiones ngrok
23-entorno-local-xampp-ngrok.md	XAMPP, puertos, ngrok
25-ui-ux-diseno-sistema-institucional.md	UI/UX institucional, IA, design system, ISO/ASVS
26-cloudflared-tunnel.md	Exposición temporal del frontend (Vite) con cloudflared
28-listado-lo-que-deberia-tener-el-sistema.md	Gap vs checklist institucional (1–45)

Archivo	Contenido
40-rendimiento-post-login-web-vitals.md	Prefetch post-login, LCP del panel y registro RUM (antes/después)
99-guia-de-prueba-por-modulos.md	Guía de prueba consolidada (formato obligatorio de cierre)

Otros

Archivo	Contenido
27-manual-usuario-sgd-gadpr-lm.md	Manual de usuario (paso a paso)
etapa-0-auditoria-inicial-y-diagnostico.md	Informe de auditoría ETAPA 0 (histórico 2026-04-19); ver 29 para cierre vigente

Nota: el documento único de changelog técnico es **22-changelog-tecnico.md** .

etapa 0 auditoria inicial y diagnostico

ETAPA 0 — Auditoría inicial y diagnóstico técnico

Proyecto: SGD-GADPR-LM — Gestión documental institucional digitalizada (GADPR-LM)

Referencia: expediente `GADPR-LM-ETI-SGD-2026-001`

Fecha del informe: 2026-04-19

Alcance: inspección del repositorio, contraste con stack oficial y expediente, sin implementación de código en la sesión de auditoría.

Aviso de archivo (consulta estado vigente)

Este documento es un **snapshot histórico** del repositorio en **2026-04-19**. Las tablas siguientes (§2–10) **no** reflejan el estado actual del código (hay `frontend/`, Prisma, auth, dominio SGD implementados en etapas posteriores).

Evidencias de saneamiento ETAPA 0 cerrada al 100%: `docs/29-etapa-0-cierre-y-evidencias.md`.

Roadmap actual: `docs/00-roadmap-general.md`.

1. Objetivo del paso (ETAPA 0)

Auditar el repositorio, contrastarlo con el expediente técnico y el stack obligatorio, registrar brechas, problemas y riesgos, y dejar definida la documentación faltante y el primer bloque de implementación ejecutable posterior.

2. Análisis previo

2.1 Estructura real del workspace

Elemento	Estado
<code>backend/</code>	NestJS plantilla mínima (<code>AppModule</code> , <code>AppController</code> , <code>main.ts</code>).
<code>frontend/</code>	No existe (React 18 + Vite + MUI no está en el repositorio).
	No existe en <code>backend/</code> (no hay ORM ni modelo persistido).

Elemento	Estado
prisma/ / schema.prisma	
storage/	No aparece en la raíz (no hay carpeta de archivos aún).
docs/	Parcial: existen 01, 02, 03, 04, 22; faltan el resto de la lista obligatoria (00, 05 – 21, 23).
.env / .env.example	No hay archivos .env* visibles en la auditoría (coherente con no versionar secretos; falta plantilla documentada).
.gitignore en raíz	No localizado (riesgo de versionar .env o artefactos si no se añade).
README.md en raíz	No existe (solo el README por defecto de Nest en backend/).

2.2 Dependencias y scripts (backend/package.json)

- **Scripts:** build, format (Prettier), lint (ESLint), test (Jest), start:dev, etc.
- **Dependencias runtime actuales:** @nestjs/common, @nestjs/core, @nestjs/platform-express, reflect-metadata, rxjs.

Faltan respecto al stack oficial declarado para el producto: Prisma, JWT/cookies, Argon2, class-validator (u otra validación API acordada), ExcelJS, pdfkit, @nestjs/config, etc.

Conclusión: el backend es un esqueleto NestJS, no el API del SGD descrito en el expediente.

2.3 Código fuente (backend/src)

Archivos propios: main.ts, app.module.ts, app.controller.ts, app.service.ts, app.controller.spec.ts.

No hay módulos de dominio, guards, PrismaService ni rutas /api/v1.

- **Duplicidad de lógica de negocio:** no aplica aún.
- **Código muerto:** no se detectó más allá del boilerplate Nest (tests incluidos).

2.4 Documentación existente vs expediente

Los archivos en docs/ (01, 02, 03, 04) describen arquitectura y convenciones coherentes con el expediente (Nueva carpeta/expediente-tecnico-gestion-documental-gadpr-lm.md).

Inconsistencia detectada: en 01-arquitectura-general.md y 02-stack-y-convenciones.md se enlaza 17-seguridad-y-hardening.md, mientras que 22-changelog-tecnico.md menciona 18-seguridad-y-hardening.md. La especificación del proyecto exige **18-seguridad-y-hardening.md** — unificar numeración y enlaces al cerrar la base documental.

2.5 Conexión XAMPP / MySQL

No es posible comprobar desde el entorno de análisis que MySQL en XAMPP esté levantado ni que exista la base `gestion_documental_gadpr_lm` sin ejecutar un cliente SQL en la máquina del desarrollador.

Estado registrable: conexión no verificada en esta auditoría; pendiente validación local (`mysql` / `phpMyAdmin`) al iniciar ETAPA 2.

2.6 Alineación con restricciones de stack

No se detectó PostgreSQL, Firebase, Docker como base, ni otro ORM sustitutivo. El gap principal es la **ausencia de frontend, Prisma y módulos de seguridad**, no un stack alternativo.

3. Plan del primer bloque de implementación (post ETAPA 0 documental)

Nota: este plan está definido para ejecutarse en la siguiente iteración, no como parte de la sola auditoría.

Cuando se autorice el siguiente paso, el **primer bloque acotado** propuesto alinea con **ETAPA 1 — Base técnica:**

1. **Raíz del monorepo:** `README.md` con cómo levantar el backend, enlace a `docs/`, puertos de referencia.
2. `.gitignore` en la raíz (y revisión de `backend/.gitignore` si aplica): `node_modules`, `.env`, `storage/*` con excepciones seguras, `logs`, `dist`, etc.
3. **Carpeta `storage/`** con `.gitkeep` (o equivalente) y regla documentada de no versionar binarios reales.
4. **`backend/.env.example`:** `DATABASE_URL`, `PORT`, placeholders JWT/CORS (sin secretos reales).
5. **Scaffolding `frontend/`:** Vite + React + TypeScript; dependencias del stack: MUI, React Router, React Hook Form, Zod, axios; estructura de carpetas acordada a `03-estructura-de-carpetas.md`.
6. **Backend:** `ConfigModule`, validación global, prefijo global `/api/v1`, CORS hacia `http://localhost:5173`, estructura de carpetas por módulos (aunque vacíos). Opcional aislar Prisma en un **segundo sub-bloque** (ETAPA 2).

Variante de máximo control: limitar el primer bloque a los puntos 1–4 más actualización documental y dejar Vite para el bloque siguiente.

4. Implementación (esta sesión)

No se implementó código ni nuevos archivos de aplicación en la iteración de solo diagnóstico.

5. Limpieza técnica aplicada

No aplicable en esta iteración (solo auditoría).

6. Validaciones ejecutadas

Verificación	Resultado
Backend <code>npm run build</code> , <code>npm run lint</code> , <code>npm run test</code>	Ejecutados tras saneamiento mínimo (2026-04-19): OK; lint sin errores (warning resuelto en <code>main.ts</code>).
Frontend	No aplica aún (no hay <code>frontend/</code>).
Conexión MySQL XAMPP	No verificada desde el agente; validación manual pendiente.

Los comandos completos por paquete están en `19-pruebas-y-validaciones.md`.

7. Documentación — archivos `.md` a crear o actualizar

7.1 Crear (plantilla mínima: objetivo, alcance, estado actual, decisiones, pendientes)

Archivo	Estado (2026-04-19)
<code>docs/00-roadmap-general.md</code>	Creado
<code>docs/05-modulo-auth.md</code> ... <code>docs/17-modulo-configuracion.md</code>	Creados (baseline)
<code>docs/18-seguridad-y-hardening.md</code>	Creado (sustituye intento vacío <code>17</code>)
<code>docs/19-pruebas-y-validaciones.md</code>	Creado
<code>docs/20-problemas-detectados.md</code>	Creado
<code>docs/21-riesgos-pendientes.md</code>	Creado
<code>docs/23-entorno-local-xampp-ngrok.md</code>	Creado
<code>docs/README.md</code>	Índice de <code>docs/</code>

7.2 Actualizar

Archivo	Motivo
docs/01-arquitectura-general.md	Enlace a seguridad: 18-seguridad-y-hardening.md .
docs/02-stack-y-convenciones.md	Mismo ajuste; coherencia con numeración oficial.
docs/03-estructura-de-carpetas.md	Reflejar estado real (solo backend/ , sin frontend/ ni prisma/).
docs/04-modelo-base-de-datos.md	Sección estado actual: sin schema.prisma hasta ETAPA 2.
docs/22-changelog-tecnico.md	Entrada ETAPA 0: auditoría 2026-04-19.

Opcional: docs/README.md como índice de 00 – 23 .

8. Problemas detectados

ID	Descripción	Módulo / área	Estado
P-001	No existe aplicación React/Vite; stack frontend documentado no materializado	Repo / ETAPA 1	Abierto
P-002	No hay Prisma, DATABASE_URL ni migraciones	BD / ETAPA 2	Abierto
P-003	Backend sin autenticación, validación global ni prefijo API versionado	Backend / ETAPA 1–3	Abierto
P-004	Inconsistencia 17-seguridad... vs 18-seguridad... entre documentos	docs/	Cerrado (unificado en 18 ; refs en 01 / 02)
P-005	Sin .gitignore raíz detectado; riesgo de commits indebidos	Repo	Cerrado (.gitignore en raíz)
P-006	Sin .env.example en backend; onboarding frágil	Entorno	Cerrado (backend/.env.example)
P-007	Conexión XAMPP/MySQL no verificada en esta sesión	Infra	Pendiente verificación local

9. Riesgos pendientes

ID	Riesgo	Mitigación sugerida
R-001	Retraso si se mezclan ETAPA 1 y 2 sin orden	Mantener bloques: monorepo + convenciones primero; Prisma después.

ID	Riesgo	Mitigación sugerida
R-002	Documentación desincronizada del código	Actualizar 03 , 04 , 22 en cada entrega de features.
R-003	Secretos en Git sin .gitignore	Añadir reglas y revisar historial si ya se commiteó .env .

10. Siguiendo paso recomendado

- ETAPA 1 — Base técnica:** scaffolding frontend/ (Vite + React + TS + MUI + Router + RHF + Zod + axios); en NestJS: ConfigModule , prefijo global /api/v1 , CORS, validación global (class-validator), estructura de carpetas por dominio (sin pantallas de negocio aún).
- Crear backend/.env local a partir de .env.example y validar MySQL en XAMPP antes de instalar Prisma (**ETAPA 2**).

Referencias cruzadas

Documento	Relación
01-arquitectura-general.md	Visión de capas y entornos
02-stack-y-convenciones.md	Stack cerrado y variables de entorno
03-estructura-de-carpetas.md	Estructura objetivo vs real
04-modelo-base-de-datos.md	Prisma y XAMPP
22-changelog-tecnico.md	Registro de hitos y cambios técnicos

Fin del informe ETAPA 0.